

OVERVIEW

AUDIT PROGRAM #50-00-00

The release of this audit program to parties external to IBM requires the written approval of the Chief Auditor.

This program is intended as a guide for assessing risk management in this process through the performance of an audit or a similar engagement. Risk management is the process to identify, manage, and control potential events in order to provide reasonable assurance related to the achievement of IBM's business and control objectives. IBM's control objectives fall into five broad categories:

1. compliance with external laws and regulations, as well as IBM policies and procedures
2. accomplishment of business objectives
3. reliable information for financial reporting and decision making.
4. efficient operations, and
5. safeguarding both intellectual and physical assets.

The control assessment questions are intended to address process objectives from the categories above and the risks to achieving those objectives. Objectives and risks in the actual process under review may differ based on organizational, operational, regulatory, and economic factors. As such, individuals performing the engagement must formulate a test strategy based on risks relative to the actual process under review, regardless of whether the risks are identified within this program.

OVERVIEW

AUDIT PROGRAM #50-00-00

DATE CHANGED	SECTION #	SUBTITLE IN SECTION	CHANGED BY (NAME)	COMMENTS
September 2025	Planning	Audit Program Risk Alignment	CA&AS Ops	Changes made to audit risk levels from recent revalidation
June 2025	Planning	Audit Program Risk Alignment	Dee Burris	Updated RAE wording
March 2025	Planning, Control Assessment Questions	Audit Risk Alignment, Subsidiaries and Joint Ventures	Dee Burris	Additional text in Integration Compliance Integration Compliance (IC001.P)
January 2025	Planning, Control Assessment Questions	Audit Risk Alignment, Subsidiaries and Joint Ventures	Dee Burris	Added Integration Compliance for Subsidiaries and Joint Ventures
May 2024	Access Management, Data Privacy, and Data Security	Access Management, Data Privacy, and Data Security (AD001.P)	Carla Bacelar	-Remove reference to ITCS300, Computer Security and Use Guidelines and replace with Chapter 3: End User Acceptable Use Requirements, 3.1 General User Responsibilities. - Remove reference to ITCS104 and system group classification -Remove references to BISO, now reorganized into IBM Software Security Center of Excellence, Assurance Team (SSCoE)
May 2024	Asset Management	Asset Management (AS001.P)	Carla Bacelar	Leased assets excluded from the review since they are no longer managed in the eAMT tool.
May 2024	Product Development and Research Projects (when applicable)	Product Development & Research Projects (PD001.P)	Carla Bacelar	Integrated Product Development (IPD) change to Offering Management
May 2024	Procurement	Procurement (PR001.P)	Carla Bacelar	Removed Remove TEAs and MEAs.
April 2023	Data Security and Privacy	General - DS001.P	Don Dobrzelewski	Added Privacy Testing
April 2023	Access Mgmt, Data Privacy & Data Security	Laboratories – AD001.P	Don Dobrzelewski	Added Privacy Testing
February 2023	All	All	CA&AS	Converted from Notes into a Word document and into a Box folder

OVERVIEW

AUDIT PROGRAM #50-00-00

Table of Contents

PROCESS AND OBJECTIVE	7
PLANNING: Audit Program Risk Alignment.....	8
PLANNING: Data Analysis.....	10
PLANNING: Reference Material	16
PLANNING: Fraud Template.....	18
CONTROL ASSESSMENT QUESTIONS – GENERAL	19
Key Control Question: 1. Supplier Management / Procurement	19
Primary Test: Supplier Selection (SM001.P)	20
Primary Test: Purchase Order Process (SM002.P)	24
Primary Test: Contract Administration (SM003.P)	26
Primary Test: Approval of Commitments (SM004.P).....	29
Primary Test: Procurement Bypass (SM005.P)	30
Primary Test: Supplier Assessment (SM006.P)	31
Key Control Question: 2. Data Security and Privacy	33
Primary Test: Data Security and Privacy (DS001.P)	34
Key Control Question: 3. Separation of Duties	36
Primary Test: Separation of Duties (SO001.P)	37
Key Control Question: 4. Asset Management.....	39
Primary Test: Contractual Responsibility (AM001.P).....	41
Primary Test: Asset Management Process (AM002.P)	42
Primary Test: End of Asset Life (AM003.P)	43
Primary Test: Reconciliations (AM004.P).....	44
Primary Test: Physical Security of Assets (AM005.P).....	46
Key Control Question: 5. Access Management.....	47
Primary Test: Application and Data Access Authorization (AC001.P).....	48
Primary Test: Workplace Security (AC002.P)	49
Key Control Question: 6. Billing	50
Primary Test: Billing - Ship / Bill / Invoice Reconciliation - (BI001.P).....	51
Primary Test: Billing Measurements - (BI002.P)	53
Key Control Question: 7. Solution Design	54
Primary Test: Contract Design and Agreement (SD001.P).....	55
Primary Test: Solution Design Mandatories (SD002.P).....	57
Key Control Question: 8. Solution Delivery.....	58

OVERVIEW

AUDIT PROGRAM #50-00-00

Primary Test: Contract Proposal Acceptance and Fulfillment (DE001.P)	59
Primary Test: Special Contracts (DE002.P).....	61
Primary Test: Deliverables (DE003.P)	62
Primary Test: Contract Change and Request for Services (DE004.P).....	63
Primary Test: Labor Claiming and Work at Risk (DE005.P)	65
Key Control Question: 9. Financial Management / Revenue Recognition.....	66
Primary Test: Financial Management (FM001.P).....	67
Primary Test: Revenue Recognition (FM002.P)	69
Key Control Question: 10. Document of Understanding (DOU)	71
Primary Test: Document of Understanding (DO001.P).....	72
Key Control Question: 11. Trade Compliance	73
Primary Test: Integrated Product Development (TC001.P)	74
Primary Test: Supplier Selection (TC002.P).....	76
Primary Test: Denied Party List Screening (TC003.P).....	77
Primary Test: Education and Awareness (TC004.P)	78
Primary Test: Record Retention (TC005.P)	79
CONTROL ASSESSMENT QUESTIONS – LABORATORIES.....	80
Key Control Question: 1. Trade Compliance - Exports Regulation	80
Primary Test: Trade Compliance - Exports Regulations (TC001.P)	81
Key Control Question: 2. Procurement.....	82
Primary Test: Procurement (PR001.P)	83
Key Control Question: 3. Product Development and Research Projects (when applicable)	84
Primary Test: Product Development & Research Projects (PD001.P)	85
Key Control Question: 4. Government Operations.....	86
Primary Test: Government Operations (GO001.P)	87
Key Control Question: 5. Financial Management	88
Primary Test: Intercompany Recovery Rates (FI001.P).....	89
Primary Test: Internal Billing (FI002.P)	90
Primary Test: Ledger Review (FI003.P)	91
Primary Test: Over/Under Recovery Process (FI004.P)	92
Primary Test: Department Expenses (FI005.P)	93
Key Control Question: 6. Asset Management.....	94
Primary Test: Asset Management (AS001.P)	95
Key Control Question: 7. Access Management, Data Privacy, and Data Security	96

OVERVIEW

AUDIT PROGRAM #50-00-00

Primary Test: Access Management, Data Privacy, and Data Security (AD001.P)	97
CONTROL ASSESSMENT QUESTIONS – SMALL COUNTRIES	99
Key Control Question: 1. Ecosystem Management	99
Primary Test: Ecosystem Selection, Review, and Terminations (BP001.P)	101
Primary Test: Special Bids (BP002.P)	104
Primary Test: Transaction Agreements (BP003.P)	107
Primary Test: BP Compliance Reviews (BP004.P)	109
Primary Test: Inventory Management (BP005.P)	111
Primary Test: Disbursements (BP006.P)	113
Key Control Question: 2. Pension Benefit Management	115
Primary Test: Payments to Recipients (PB001.P)	116
Primary Test: Fees and Contract Administration (PB002.P)	117
Key Control Question: 3. Management of Disbursements - 3rd Party Expense/CTEBA	118
Primary Test: Payments and Reimbursements (MC001.P)	119
Primary Test: CTEBA Use and Monitoring of CEPAT Tool (MC002.P)	120
CONTROL ASSESSMENT QUESTIONS – SUBSIDIARIES AND JOINT VENTURES	121
Key Control Question: 1. Cost and Rate Management	121
Primary Test: Product Costing (PC001.P)	122
Key Control Question: 2. Integration Compliance	123
Primary Test: Integration Compliance (IC001.P)	124
CONTROL ASSESSMENT QUESTIONS – OTHER UNIQUE PROCESSES THAT COULD ARISE IN AN OVERVIEW REVIEW	126
Key Control Question: 1. Site Security	126
Primary Test: Access Controls and Badge (SS001.P)	127
Primary Test: Interior Access Controls (SS002.P)	128
Primary Test: Exterior Access Management (SS003.P)	130
Key Control Question: 2. Disaster Recovery and Business Continuity	131
Primary Test: Disaster Recovery and Business Continuity (DR001.P)	132
Key Control Question: 3. Parts Logistics	134
Primary Test: Supply Order Management (PL001.P)	135
Primary Test: Excess Surplus and Scrap (PL002.P)	137
Primary Test: Receiving (PL003.P)	139
Primary Test: Shipping (PL004.P)	140
Primary Test: Import Reconciliation (PL005.P)	141
Primary Test: Import Classification of Goods (PL006.P)	142

OVERVIEW

AUDIT PROGRAM #50-00-00

Primary Test: Denied Party List Screening (PL007.P).....	144
Key Control Question: 4. Employee Payments Review.....	145
Primary Test: Invalid Payments (EP001.P)	146
Primary Test: GEMCAPS Review (EP002.P)	147

OVERVIEW

AUDIT PROGRAM #50-00-00

PROCESS AND OBJECTIVE

Despite their size, IBM's smaller operations can represent an exposure to the corporation's worldwide image. They may operate in sensitive environments where it is important for IBM to be conducting its business in an ethical and well controlled manner. In addition, some small operations are in emerging markets with high growth potential (e.g. China, India). Early detection of control risks can help prevent greater exposures as these operations grow.

Performing an overview audit places numerous processes in scope including solution design and delivery of services, hardware, and software, business partner management, customer fulfillment, accounting, procurement, and human resources. Due to time and resource constraints for the audit team, it is essential to reduce the number of processes to be audited to a manageable level. A guideline would be three or four processes. Therefore, attention should be placed on audit preparation activities, universe analysis, and the process reviews in order to identify the most suitable ones.

The small size of the operations may make it more difficult to implement separation of duties and to take advantage of computerized systems' security to protect its assets. Additionally, government customers may represent a high proportion of sales, thus increasing the need to maintain the highest level of ethical business conduct.

For these reasons, it is important to ensure that there is an adequate and functioning system of financial and operational controls in smaller units.

For laboratories and subsidiaries/joint ventures, it is important that the ATL contact the focal point as soon as possible to understand the unique processes that are held separately for subsidiaries, and the particular process steps that each lab could have (most labs do not develop products but are part of a development and production chain). There is no rule for this, and the ATL may apply his/her best judgement and also consult with the internal audit focal point to discuss possible audit scopes.

*** If Human Resources (HR) processes are selected for testing, given global processes/auditable units, scope to be considered for HR: Benefits and Payroll.**

OVERVIEW

AUDIT PROGRAM #50-00-00

PLANNING: Audit Program Risk Alignment

Laboratory Operations

Defined Risk Area	Audit Risk Level	Key Control Question	Test Number
Access Management, Data Privacy, and Security	High	General: Access Management General: Data Security and Data Privacy	All All
Product Development and Research Projects	Medium		
Trade Compliance	Medium		
Government Operations	Medium		
Financial Management	Medium	General: Financial Management / Revenue Recognition	FM001.P - Only Other Income and Cost Allocations sections
Asset Management	Low	General: Asset Management	All
Requests to Procurement	Low		

Small Countries

Defined Risk Area	Audit Risk Level	Key Control Question	Test Number
Local Regulations and Oversight (General)	High		
Access Management and Data Privacy and Security (General)	Medium	General: Access Management General: Data Security and Data Privacy	All All

OVERVIEW

AUDIT PROGRAM #50-00-00

PLANNING: Audit Program Risk Alignment (Continued)

Subsidiaries and Joint Ventures

Defined Risk Area	Audit Risk Level	Key Control Question	Test Number
Local Regulation and Oversight	High		
Access Management and Data Privacy and Security	Medium	General: Access Management General: Data Security and Data Privacy	All All
Labor Claiming	Medium	General: Solution Delivery	DE005.P
Application Controls	Medium	General: Access Management	AC001.P
Integration Compliance	Medium	Integration Compliance	IC001.P
Solution Delivery and Financial Management	Low	General: Solution Delivery General: Financial Management / Revenue Recognition	All All
Solution Design	Low	General: Solution Design	All
Purchase Orders and Supplier Management	Low	General: Supplier Management / Procurement	All

OVERVIEW

AUDIT PROGRAM #50-00-00

PLANNING: Data Analysis

Data analysis should be a part of every engagement where data is available in databases or data warehouses that can be accessed through query programs. This concept enhances the risk-based auditing approach, makes the audit process more efficient, and increases the productivity of the audit team. When the audit team does not have the skills required to perform these tasks, assistance should be sought from the Technology team.

All data used for analysis must be reconciled to an independent source so that the auditor has confidence that the universe is complete.

The [Data Analysis engagement procedures in the Audit Manual](#) (link internal to CA&AS members only) provide further suggestions.

Overview can cover a myriad of scope areas. The table below provides a summary of some of the areas that can be reviewed under this type of audit and what analysis techniques can be used for each.

As stated above, since many areas can be covered in an overview audit, it is important that the ATL set a preplanning meeting with the focal point and ask about the processes executed in the area to be audited. Then, the ATL should select the top 3-5 areas to be audited. It will not be possible to cover all scopes included in this program.

In addition, please note this program has been defined by three relevant areas:

- Small Countries
- Laboratories
- Joint Ventures

Even when specific and general elements were included for each of these scopes, it is important to remember that it is the ATL's responsibility to go back to each of the audit programs referenced within Overview and use the most current version available. This program was updated as of May 8, 2013 and reflects the audit program updates up until this date.

This table shows what data can be reviewed and analysis techniques.

Data to be Analyzed	Analysis to be Performed	Concern
Access Management Obtain a list of all employees who left the company during the audit period, including accesses granted and access removal details.	Inappropriate accesses; access after separation or job change; inadequate level of access	Ineffective access control process could affect customer satisfaction, expose confidential information, lead to possible contract termination, and result in financial loss.
Labor Claiming Obtain a list of employees and contractors who claimed hours in the Intranet Labor Claiming Tool (ILC) for the projects and contracts associated with the services being provided.	Duplicate hour claiming; claiming hours on multiple contracts; hours claimed while on vacation; hours claimed for nonexistent or separated employees	Inaccurate and unauthorized hours charged to the external customer for the work being performed which could lead to customer dissatisfaction and legal issues.

OVERVIEW

AUDIT PROGRAM #50-00-00

PLANNING: Data Analysis (Continued)

Data to be Analyzed	Analysis to be Performed	Concern
Solution Design Universe of all contracts signed during the audit period should be provided, including: • Total contract value • BTT rating • Sector, country • Date of signature of contract	Select a sample of contracts to review the following: • Significant variances to pricing case • Quality assurance issues documented in QA reviews • Correct pricing approvals were in place (following pricing delegations) • Credit approvals were obtained for TCV before issuance of proposal to customer and were valid at time of contract signature • Legal approvals were in place for non-standard terms and conditions • Customer acceptance of contracts was in place and submissions to fulfillment on contract registration were sent with all required inputs.	• Proposals sent to the customer without all required approvals and not in accordance with IBM guidelines • Proposals or contracts which are not in compliance with the customer requirements or are associated to high risks and/or difficulties that pose a challenge when executing process delivery.
Solution Delivery Universe of all contracts managed should be provided, including: • Total contract value • BTT rating • Sector, country • Date of signature of contract • Whether contract status was classified as troubled • Customer sat result • PMR result	Select a sample of contracts to review the following: • Low customer satisfaction, material claims/settlements and complaints Financial indicators of risk including: • High amounts of aged debt, and disputed invoices • High value of write offs • Whether deliverables were properly tracked and executed according to the contract • Service level agreements (SLAs) were properly calculated and reported.	• Inadequate project execution in conjunction with lack of monitoring of service delivery could result in inconsistent delivery, financial loss and customer dissatisfaction. • Failure to properly identify and track risks could lead to customer dissatisfaction, inefficient allocation of project resources, impact IBM's image, and negatively impact the financial performance of the contract.

OVERVIEW

AUDIT PROGRAM #50-00-00

PLANNING: Data Analysis (Continued)

Data to be Analyzed	Analysis to be Performed	Concern
Procurement • Universe of all invoices paid during the audit period • Universe of all Purchase Orders • Universe of all non- PO transactions • Universe of all bypasses identified by Procurement during the period	Review purchase order and payment data: • Review invoices with purchase orders raised close to or after invoice dates. Review report of bypasses committed and identify repeat offenders: • Assess the actions taken by management to address repeat offenders	• Lack of procurement involvement may result in increased costs to IBM and indicate instances where "arm's length" relationships are not in place. • Continued bypass activity may indicate lack of monitoring of spend on a contract. • Where reliance is placed on third parties for the delivery of services, IBM may not have adequate contractual cover in situations where contracts are not in place on a continued basis. • Unidentified bypass offenders may result in further bypasses.
Revenue Recognition • Manual entries - request detailed ledger extract for all manual entries • Balance sheet account reconciliations - request list of all balance sheet accounts reconciled in and outside of ARMs.	Review ledger entries report paying attention to: • Material manual revenue and cost deferrals and accruals • Revenue reversals, negative revenue in the month after end of quarter • Manual credits and provisions • Contracts with negative revenue in the month following quarter end Perform analysis based on variance and content aging items, operational and variance balances, the timing reconciliations were performed and look at the same reconciliations month to month.	• Unsupported accounting entries, with insufficient review by either management or Accounting resulting in inaccurate revenue or GP, which could in turn impact incentive or commission payments. • Unidentified activity could be occurring in accounts. • Lack of sufficient documentation to explain and resolve variances could lead to financial misstatements.

OVERVIEW

AUDIT PROGRAM #50-00-00

PLANNING: Data Analysis (Continued)

Data to be Analyzed	Analysis to be Performed	Concern
Billing and Accounts Receivable • Universe of all invoices issued during the audit period • Universe of all credit notes issued during the audit period	Select a sample of invoices and credit notes using the following factors: • Excessive delays between original invoice and credit • Manual invoices or credits (ARCs/RRCs) • Credits processed near quarter end • High value credits • Duplicate amounts • Select reason codes classified as miscellaneous, and other nonspecific codes • Select invoices from months for which there were contract changes/amendments, which altered baseline billing amounts • Outstanding/unpaid invoices	• Untimely or inaccurate billing could result in financial impact, client dissatisfaction, financial misstatement. • Inadequate monitoring of new amendments or alterations to baseline could lead to incorrect billing (ARC/RRC) calculations, financial loss, inadequate revenue recognition, and client dissatisfaction. • Delays in collections of unpaid invoices could impact the cash flow. • High volumes of manual credits may indicate process issues with billing accuracy, and review and validation of invoicing.
Asset Management Hardware inventory: a full inventory should be provided of: • Assets owned by IBM • Assets managed by IBM that are owned by the customer or a third party Software inventory listings: obtain a full list of software assets under management. Include details of: • Software vendor • Number of licenses purchased and deployed • Whether maintenance agreements are in place for software licenses • Most recent reconciliation of software assets	The audit should concentrate upon revising existing inventories: Hardware inventory: • Concentration of assets (by value and by volume) • Locations subject to recent move of assets • Locations used for multiple customers/contracts • Locations used for customers with specific high risk contract requirements • Locations/assets where customers update asset records • Storage and stockroom locations at IBM or customer sites Software inventory: • Software alert type (which would identify non-compliant licenses) • Time frame to close software alerts (alerts which remained open for more than 180 days) • Alerts which were manually closed	Insufficient or untimely asset tracking could result in asset loss to remain undetected, inaccurate financial reporting, and customer dissatisfaction. Inappropriate and undetected use of SW licenses could result in financial exposure, could impair IBM ability to meet customer requirements, and result in legal exposure.

OVERVIEW

AUDIT PROGRAM #50-00-00

PLANNING: Data Analysis (Continued)

Data to be Analyzed	Analysis to be Performed	Concern
Management Approval of Disbursements (MAD) - 3rd Party Expense/Compliance with Transportation Entertainment, and Business Amenities (CTEBA) Obtain the following reports: - Global Expense Monitoring Compliance and Analysis (GEMCAP) program - Concur expenses submissions during the audit period. Parent Expense Type: 09. Client and Other External Party Expenses - The official CTEBA approval tool, a universe report of all CTEBA requests submitted for approval during the audit period showing all available fields A list of all IBM customers which has been identified as Government Owned Entity (GOE). Include customer name, customer number, contract number. Identify if the country/s being audited are considered as Commercial Parties in Certain Countries ("CPICC") as listed in FIN/LEG 168. Note: Exclude Marketing expenses/events	- Approvals were timely provided, based on a valid business reason and supporting documentation - Exceptions were reviewed and approved by management - Pre-approvals were timely obtained when applicable - Expenses were accurately categorized. - GOE customers were properly identified and CTEBA rules were followed. (Entity Identification, attendee collection and amenity definition, confirmation letter and post interaction activities) For additional information refer to Audit Program 18-05-00.	Non-compliance with CTEBA process coupled with insufficient monitoring over disbursements could result in violation of US Foreign Corrupt Practices Act (FCPA), fraud, bribery, financial loss, and impact to IBM's reputation.

OVERVIEW

AUDIT PROGRAM #50-00-00

PLANNING: Data Analysis (Continued)

Data to be Analyzed	Analysis to be Performed	Concern
Integration Plan Obtain the plan of record and integration plan for the auditable entity. Note: Excludes less than wholly owned entities (e.g., joint ventures, alternate structures, etc.)	• Verify FIN 122 compliance for Non-Integrated Subsidiaries that are required to have an integration plan. • Determine Global Process Owner engagement for Transfer of Controls (ToC). • Verify action plans and target dates are established if applicable. For any proposed change to the accepted Transfer of Employment (ToE) and Transfer of Business (ToB), validate there is a documented approval in accordance with the extension process outlined in FIN 122.	Insufficient or nonexistent integration plans may impose increased financial, legal, and reputational risk to the IBM Enterprise.

OVERVIEW

AUDIT PROGRAM #50-00-00

PLANNING: Reference Material

Pricing References

IBM Corporate Organization Letter 109 - Delegation of Authority, Pricing of Products and Services
<https://w3.ibm.com/ibm/corporate-documents/corporate-directives/corporate-organization-letters/col-109>

IBM Corporate Organization Letter 125 - Delegation of Authority - Terms and Conditions of Contracts for Offering Products and Services
<https://w3.ibm.com/ibm/corporate-documents/corporate-directives/corporate-organization-letters/col-125>

Accounting References

Accounting Policy and Financial Reporting
<https://w3.ibm.com/w3publisher/accounting-policy-financial-reporting>

Services Accounting Instructions
<https://w3.ibm.com/w3publisher/accounting-policy-financial-reporting/accounting-instructions>

Other useful links

Global Credit Directives
<https://w3.ibm.com/w3publisher/ibm-credit-organization/credit-directives-and-guidelines>

Legal Information System - International Transactions - Intercompany Agreements
<https://w3.ibm.com/w3publisher/ica-bratislava/our-instructions/ica-guidance>

IBM Business Conduct Guidelines
<https://w3.ibm.com/tools/bcg-program/bcg>

Procurement Policies and Practices (The Blue Book, Green Book, Federal Book)
<http://procure.sby1.ibm.com/gp/procurement.nsf/ContentDocsByCtryTitle/Global~Procurement+policies+and+practices>

Chapter 3: End User Acceptable Use Requirements, 3.1 General User Responsibilities.
<https://pages.github.ibm.com/ciso-psg/main/standards/itss.html#31-general-user-responsibilities>

Corporate Instructions References

Corporate Instruction – GRA 103 - Political campaign contributions and expenditures
<https://w3.ibm.com/ibm/corporate-documents/gra/gra-103?query=LER>

Corporate Instruction - Corporate Citizenship and Corporate Affairs CCR 101 - Corporate Responsibility
<http://w3-03.ibm.com/ibm/documents/corpdocweb.nsf/ContentDocsByTitle/Corporate+Instruction+CCR+101>

Corporate Instruction - Finance 154 - Foreign Corrupt Practices Act
<https://w3.ibm.com/ibm/corporate-documents/fin/fin-154>

OVERVIEW

AUDIT PROGRAM #50-00-00

PLANNING: Reference Material (Continued)

Corporate Instruction - Finance 181 - Bank Account Management

<https://w3.ibm.com/ibm/corporate-documents/fin/fin-181>

Corporate Instruction - LEG 168/FIN 168 - Business Amenities and Gifts

<https://w3.ibm.com/ibm/corporate-documents/fin/fin-168-leg-168>

Corporate Instruction - Finance 157 - Cash, investments, borrowing and hedging activities, other than transactions by or with regional treasury centers

<http://w3-03.ibm.com/ibm/documents/corpdocweb.nsf/ContentDocsByTitle/Corporate+Instruction+FIN+157>

Corporate Instruction - Finance 133 - Powers reserved to the IBM corporation regarding accounting requirements

<https://w3.ibm.com/ibm/corporate-documents/fin/fin-133>

Corporate Instruction - Finance 101 - Control of Disbursements

<https://w3.ibm.com/ibm/corporate-documents/fin/fin-101>

Corporate Instruction - Finance 182 - Management Self Assessment of Control

<https://w3.ibm.com/ibm/corporate-documents/fin/fin-182>

Corporate Instruction - Legal 115 - Defense Industry Initiative on Business Ethics and Conduct

<https://w3.ibm.com/ibm/corporate-documents/leg/leg-115>

Corporate Instruction - Finance 166 - Risk Documentation, Corporate Directive Deviations

<https://w3.ibm.com/ibm/corporate-documents/fin/fin-166>

Corporate Instruction - Finance 167 - Vendor Sourced Labor Services

<http://w3-03.ibm.com/ibm/documents/corpdocweb.nsf/ContentDocsByTitle/Corporate+Instruction+FIN+167>

Management of Disbursements - 3rd Party Expense/CTEBA

IBM Business Conduct Guidelines

<https://w3.ibm.com/w3publisher/trust-compliance/bcgs/bcg-program>

CTEBA Web site

<https://w3.ibm.com/w3publisher/cteba>

Corporate Instruction - LEG 168/FIN 168 - Business Amenities and Gifts

<https://w3.ibm.com/ibm/corporate-documents/fin/fin-168-leg-168>

General Data Protection Regulation (GDPR)

GDPR Readiness: <https://www.ibm.com/data-responsibility/gdpr/#4>

Compliance, Audit, Risk Mitigation and Management: <https://w3.ibm.com/w3publisher/dprc>

OVERVIEW

AUDIT PROGRAM #50-00-00

PLANNING: Fraud Template

Fraud is any intentional act or omission designed to deceive others and resulting in the victim suffering a loss and/or the perpetrator achieving a gain. Fraud can be categorized into fraudulent financial reporting, misappropriation of assets, and improper or unauthorized expenditures.

This fraud template was prepared using historical information from past substantiated investigations in Overview areas. It does not cover all risks inherent to the Overview program.

Description of fraud risk	Control to detect	Testing approach
Falsified or inappropriate employee expense submission	review GEMCAPs reports	Testing for approval of exceptions, verify that exceptions are tracked and monitored, and actions are taken on offenders
Labor Claiming	Claimed hours should be aligned with local requirements and regulations, exceptions should be approved and documented	Labor claiming testing. Overtime/vacation and leave of absence (LOA) testings. If guidelines are not followed, test if risks were assessed, the result was documented and approved by management. Testing should be addressed to management awareness on assumed risks
Misrepresentation	Information must be valid and accurate	This is an attribute in many testings, the auditor verifies if the supporting documentation is valid, accurate, opportune, and approved/reviewed by manager. Use of available analytics tools
Unapproved Pricing Commitments (UPC)	Last approval for business case, focused on pricing case	Determine if the proposal/offering has been internally approved before being sent to customer, including changes to previously approved cases. Focus also on special bids offerings and transaction agreements for applicable small countries
Conflict of interest	Activities performed by employees should be assessed by management to detect possible conflicts of interest	Risks related to separation of duties have been periodically (at least annually) assessed and documented by management, if conflicts were identified, actions were properly taken to mitigate. When testing access management, focus at least on update and approve accesses.
Falsification of records/documents	Documentation accuracy	Supporting documentation should be valid, accurate, and approved at the time of the transaction posting
Exposure of IBM and customer/suppliers information to unauthorized access or use	Information was classified and protected as designed	There are several testings on this area, for physical as well as internet data, workplace security, device security, encryption, access management, and control access systems testings. For laboratories, non disclosure agreements were properly signed with employees and suppliers.
Use of unapproved systems/processes by subsidiaries and joint ventures	The use of non IBM legacy systems and tools has been approved by management, and controls were implemented to mitigate risks	When non IBM legacy systems are in place, conflict of interest testing should be done, as well as a review of documented discussions with owner organizations to understand how risks were mitigated, test accordingly
Opportunity management	Opportunities were handled by one employee, and related incentives are not duplicated	Test to verify that the opportunity management system has been designed in a way that employees are owners of their assigned opportunities, and the same were not manipulated to duplicate quota assignments (mainly applicable to Digital operations)

Note: The probability and impact will vary depending on the organization/business unit that is being audited.

OVERVIEW

AUDIT PROGRAM #50-00-00

CONTROL ASSESSMENT QUESTIONS – GENERAL

Key Control Question: 1. Supplier Management / Procurement

Objective:

Global Procurement's role is to deliver value to IBM as a core element of the Integrated Supply Chain (ISC). This value derives from our people, processes, and technologies that secure goods and services in support of our internal partners and customers in the development and delivery of products and offerings. Procurement Policies and Practices must be followed by all members of Global Procurement and those organizations which have received a specific delegation of Procurement Authority from the Procurement Policy Executive.

Note: This testing would be only applicable in an overview audit for Subsidiaries and Joint Ventures where their own procurement process may defer to IBM's. It is neither applicable for small countries nor laboratories as they follow the general IBM procurement process and will be catch up in a Procurement engagement/audit review.

Risk/Exposure:

Failure to properly control the selection of suppliers can create excess expenditures, supplier relations exposures, and can lead to fraud.

Failure to adequately control the purchase order process could lead to unauthorized expenditures, increased costs, and supplier relations problems.

Failure to properly control the approval of commitments can create excess expenditures, legal problems, supplier relations exposures, and can lead to fraud.

Failure to adequately control and monitor the non-purchase order activities for bypass could lead to unauthorized expenditures, increased costs and supplier relations problems.

Suppliers may be used for bribe or do not qualify in terms of IBM standards, requirements, and terms and conditions (T&Cs).

OVERVIEW

AUDIT PROGRAM #50-00-00

CONTROL ASSESSMENT QUESTIONS – GENERAL

Key Control Question: 1. Supplier Management / Procurement

Primary Test: Supplier Selection (SM001.P)

Objective:

To validate that controls supporting the supplier evaluation and selection process were adequate to protect IBM's interests when originally entering into a contractual relationship with a supplier and selecting a supplier for a specific purchase opportunity. In addition, verify that goods and services were procured at the best value for IBM.

Approach:

Utilizing commodity or country spend reports, identify high risk segments and commodities being purchased. In addition, identify situations where IBM Business Partners are also suppliers.

Identify a list of new suppliers and what kind of services/products were bought. Identify suppliers that are new and with low value or a low number of transactions.

Select a sample of specific purchasing transactions from these high-risk areas purchased during the audit period. The sample should contain purchase orders or parts with a rolling 12 month spend exceeding the established procurement clip levels for supplier selection, but also small samples with single purchases or low volume for a supplier.

Test against the following criteria to validate the control risk assessment (CRA) data for unapproved sourcing techniques.

NOTE: Any exceptions observed during a rolling 12-month spend period need to be validated against the established annual 'clip levels'. This is done on a January to December timeline, not on a rolling 12-month period. Additional supplier selection criteria may be required to satisfy the specific requirements for the commodities being sourced. These criteria should be determined through process reviews and tested in addition to the general testing requirements listed below.

Supplier Selection

1. Competitive evaluation - with or without price:

- a. Were the relevant criteria and weighting factors predetermined by the cross-functional team?
- b. If price represented less than 50% of the evaluation criteria, was the justification clearly documented and was procurement management approval received?
- c. Were the suppliers ranked and was the final selection approved by all members of the cross-functional team?
- d. Was justification and procurement management approval provided when awards were granted to suppliers other than the one that was evaluated as best?
- e. Was there a minimum of two suppliers?
- f. Was procurement and the requestor part of the cross functional team?
- g. Was a summary of the source selection analysis and decision documented (electronically or hardcopy)?

2. Competitive bidding:

- a. Were the requirements communicated to all suppliers at the same time?
- b. Was a minimum of three valid responses received? If not, were required approvals received?
NOTE: Small and emerging countries require two responses.
- c. Was justification provided and management approval given when awards were granted to suppliers other than the lowest bidder?

OVERVIEW

AUDIT PROGRAM #50-00-00

CONTROL ASSESSMENT QUESTIONS – GENERAL

Key Control Question: 1. Supplier Management / Procurement

Primary Test: Supplier Selection (SM001.P)

(Continued)

- d. Were any updates to the requirements or extensions of the due date communicated to all participating suppliers at the same time?
 - e. Did late responses have procurement management approval in order to be included in the selection process?
 - f. Were suppliers advised of their selection or non-selection on a timely basis?
 - g. Was a summary of the source selection analysis and decision documented (electronically or hardcopy)?
- 3. Reverse auctions - A reverse auction is a type of auction where the buyer specifies what they want to buy, and the suppliers bid for the business. They're based on the assumption that multiple suppliers are capable of providing the required product or service and the supplier selection can be based 100% on obtaining the best price.
 - a. Was the incumbent supplier included? If not, was the reason documented?
 - b. Was there a minimum of three acceptable bidders (two for small and emerging countries)?
 - c. Were initial requirements communicated to all suppliers at the same time?
 - d. Were suppliers notified of their participation in the reverse auction?
 - e. Were the results of the analysis and decision documented?
- 4. Sole-source or only source decisions:
 - a. Did documentation exist to indicate that there were no other alternatives available?
- 5. Customer directed suppliers:
 - a. Was there documentation (e-mail or letter) from the external customer available to support that the supplier was customer specified? If not, was there documentation from the IBM marketing/sales team to the external customer confirming the customer's request to use a specific supplier? Was procurement copied on the e-mail or letter? See exceptions in the Blue Book under Customer Directed Suppliers for government accounts and personal computer purchases.
 - b. If a more competitive solution was available, did procurement offer it to the marketing or sales team ("client")?
 - c. If the client declined the solution, was there adequate approvals received from IBM client's executive (director level and higher) and Finance line executive (director level and higher)?
 - d. Did procurement document and execute according to the client's direction?
 - e. Did procurement perform supplier assessment on POs with customer directed suppliers? If not, was there documentation that supplier assessment was performed within sixty (60) calendar days of order placement?
- 6. IBM Business partners, alliance partners or suppliers' identification in market opportunities:
 - a. Was justification to use the business partner, alliance partner, or other third documented?
- 7. Verify that annual spend against exceptions does not exceed the criteria for the organization's analysis? Confirm that the 80% coverage has not been impacted by this exception.
- 8. Determine that commitments were not made against requests for information (RFI).

OVERVIEW

AUDIT PROGRAM #50-00-00

CONTROL ASSESSMENT QUESTIONS – GENERAL

Key Control Question: 1. Supplier Management / Procurement

Primary Test: Supplier Selection (SM001.P)

(Continued)

9. For U.S. based suppliers, was at least one diversity supplier included in any competitive selection technique?
10. Was proliferation screening performed prior to transacting business with the supplier?
11. For continuity of services re-evaluations, did the extension exceed the length of time for the original commitment of fair value?

Fair Value Analysis

If Competitive Evaluation with price or Competitive Bidding was used for supplier selection, a separate fair value analysis is not required. Fair Value Analysis may be performed by using analytical technique - price comparison or cost buildup.

1. Cost Comparison:
 - a. Was valid industry data or benchmark pricing information for the same or similar product or service used for the price comparison?
 - b. Was price of another IBM product or service for which the fair value had already been determined used in the comparison?
 - c. Was the pricing information used in the comparison current and relevant to the country/geography and time period of the comparison?
 - d. Was a summary of the price comparison analysis and decision on the competitiveness of the price documented (electronically or hard copy)?
2. Cost Buildup:
 - a. Was current and relevant industry/benchmark material costs and labor rates used to ensure the most competitive cost?
 - b. Were agreements with specified prices lists which were put in place by Sourcing Councils or other IBM locations used as part of the analysis?
 - c. Was the analysis performed by an independent individual or team (for example, a cost engineer or a cross-functional team which includes Procurement). If not, did the Procurement manager must approve the Fair Value determination?
 - d. Was the summary of the Cost Buildup analysis and decision on the competitiveness of the price documented (electronically or hard copy)?
3. Competitive evaluation with price - Separate Fair Value analysis not required.
4. Competitive evaluation without price:
 - a. Was analytical technique (either price comparison or cost buildup) used to ensure a fair value determination?
5. Competitive bidding and reverse auctions - Separate Fair Value analysis not required except in cases where the required minimum responses were not received, and it is not possible to re-bid.
 - a. Was the approval of the Global Commodity Chair or Country Procurement manager obtained?
 - b. Was the justification and reasons documented and fair value analysis performed using the approved analytical technique?

OVERVIEW

AUDIT PROGRAM #50-00-00

CONTROL ASSESSMENT QUESTIONS – GENERAL

Key Control Question: 1. Supplier Management / Procurement

Primary Test: Supplier Selection (SM001.P)

(Continued)

6. Sole or Only Source:
 - a. Was analytical technique (either price comparison or cost buildup) used to ensure a fair value determination?
 - b. If the final price does not represent fair value, did the documentation demonstrate that the requestor was notified?
7. IBM Business Partner, Alliance Partner or Supplier identifies opportunity (includes marketing alliances):
 - a. Was analytical technique (either price comparison or cost buildup) used to ensure a fair value determination?
 - b. If the fair value determines the Business or Alliance Partner is not competitive, did the procurement advise their client or the Business or Alliance Partner that if they don't become competitive, they may not be awarded future business?
 - c. Were the results of the fair value determination fully documented?
8. Customer Directed:
 - a. Was analytical technique (either price comparison or cost buildup) used to ensure a fair value determination?
9. For continuity of service re-evaluations, did the extension exceed the length of time for the original commitment of fair value?
10. If an evergreen contract was used, were there specifications for how often fair value should be performed? If a contract had a specific expiration date, was fair value performed at the point of any extension?
11. Was there a documented process in place to monitor supplier spend to consider when to renegotiate the prices, terms, or conditions?

OVERVIEW

AUDIT PROGRAM #50-00-00

CONTROL ASSESSMENT QUESTIONS – GENERAL

Key Control Question: 1. Supplier Management / Procurement

Primary Test: Purchase Order Process (SM002.P)

Objective:

To determine if controls over the purchase order (PO) process were effective to ensure commitments were made to valid suppliers, confirm that purchases were valid, verify approvals, and protect IBM's interests.

Approach:

Using data analysis and risk-based auditing techniques (see Sampling) select a sample of purchase orders.

Test for the following attributes:

1. Was there a valid business purpose? Was the appropriate commodity code used?
2. Was the PO committed to a valid supplier?
3. Were requester and proper procurement (or delegated) approvals obtained prior to commitment to a supplier? If procurement approvals were obtained after the commitment, but within ten days, was there a justification for the post-approval?
4. Was the price equal to the accepted arrangement (contract, price list, quote, or cost estimate)?
5. Did the PO specify terms for invoicing, payment, and delivery?
6. Did the PO commitment amount equal the actual payment(s) amount?
7. Was the PO issue date prior to the accounts payable invoice date? If not, was the PO coded as a bypass and was there a valid reason for this exception?
8. Was the purchase order properly coded? Was there a process to validate the accuracy of source codes entered into the PO system? If inaccurate sources codes were identified, were they corrected in a timely manner and were actions taken as appropriate?
9. Was fair value determination performed for those purchase orders identified as bypasses, which were over the organization's clip level?
10. Were all changes processed based on alterations properly approved by the requester, requester's manager, and proper level of procurement?
11. Were cancellation charges properly approved?
12. Were any premium charges such as premium freight and overtime approved by the requester and procurement?
13. Were delegations and/or clip levels circumvented by placing multiple purchase orders to the same suppliers?

OVERVIEW

AUDIT PROGRAM #50-00-00

CONTROL ASSESSMENT QUESTIONS – GENERAL

Key Control Question: 1. Supplier Management / Procurement

Primary Test: Purchase Order Process (SM002.P)

(Continued)

14. Obtain the Requisition Cycle Time Report to determine POs with large cycle time between requisition and PO placement. (Requisition processing more than 20 days). Determine if the requisition cycle time was greater than a specified local target (i.e., 10 days). Determine the causes for the delays.
15. Obtain a report showing all POs for this organization that were changed from an exception code (PX, BX, PU, BU). Determine that these values were being counted in monthly exception spending measurements. Post approval should only be done when buyers are presented with short lead-time to place the order. Verify that management had reviewed these reports and had tested that fair value had been performed. From the reports, select a sample of POs that had fair value analysis performed after PO placement. Verify appropriate fair value documentation and that short lead-time pressures had existed.
16. If unit-less purchase orders were used (the unit designation in SAP is 'UL'), request a list and select a sample for testing. Samples should focus on high-dollar value, purchases that were paid with multiple invoices, and purchases with descriptions that could be itemized into individual units. For each PO determine if:
 - a. The use of the UL designation was appropriate. Could the purchase have been defined in units?
 - b. Procurement was able to determine exactly what was purchased and performed any required fair value analysis.
 - c. Management implemented regular UL PO reviews. Review the methodology for selecting UL POs for this testing to ensure complete coverage of UL activity.
 - d. Controls were in place to verify that IBM received and was billed for only what was ordered through proper procurement channels. (The negative confirmation process with accounts payable is not sufficient since this will go to the requester.)
 - e. The measurements and use of UL designations complied with Procurement requirements.
(See Procurement Policy letter at:
<http://sbygad02.sby.ibm.com/gp/procurement.nsf/ContentDocsByCtryTitle/Global~Policy+Using+UL+or+Blanket+Purchase+Orders+Without+Positive+Confirmation+-+May+21,+2002>)
17. For any POs where early payment terms had been agreed to with a supplier, verify that procurement guidelines on discounts for early payments were followed?
(See Procurement Policy letter at:
<http://sbygad02.sby.ibm.com/gp/procurement.nsf/ContentDocsByCtryTitle/Global~Guideline+on+discounts+for+early+payment+-+December+20,+2005>)
18. Review the local work authorizations (WAs) process and request a list of all WAs issued to suppliers during the audit period.

OVERVIEW

AUDIT PROGRAM #50-00-00

CONTROL ASSESSMENT QUESTIONS – GENERAL

Key Control Question: 1. Supplier Management / Procurement

Primary Test: Contract Administration (SM003.P)

Objective:

To determine if contracts include detailed scopes of work, appropriate business and legal clauses, definition of supplier performance measurements, and supporting documentation which demonstrate an effectively managed contractual supplier relationship. In addition, determine the validity of the data reported for the agreement management measurement.

Approach:

Obtain a listing of all contracts (including contracts acquired from other organizations) that were in effect during the audit period and select a judgmental sample based on high risk (core, regional/niche, nonstrategic, sensitive, high-dollar, high-exposure, diversity suppliers). Review the contracts selected against the following criteria:

1. Did all contracts for the organization (base contracts, statements of work (SOW), confidentiality agreements, equipment loan agreements) have appropriate approvals from line management, finance, legal, and procurement before the effective date? If not, was there any activity on the contract before the last signature was obtained? Were approvals within delegated commitment authority? If a model agreement was not used, were legal approvals obtained before submitting a contract to the client?
2. Was there a process in place to ensure contract files received from other organizations were in compliance with Procurement Policies and Practices - the Blue Book? Did contract files acquired from other organizations contain proper documentation and adherence to the Procurement Policies & Practices? If the contract file was determined to be unsatisfactory, what did the procurement organization do to develop an action plan to update these contracts?
3. Did the contract have all required terms and conditions?
4. Was the scope of work clearly defined and were rates clearly identified? Specifically, did the scope of work include:
 - a. Defined job classifications for time and materials contracts
 - b. Defined job responsibilities for contractors
 - c. Reporting requirements to provide data for confirmation of services performed
 - d. Clauses regarding the use of subcontractors
 - e. Invoicing requirements
5. Did the contract comply with corporate requirements for doing business with former IBMers, close personal friends, or relatives? If any IBM employees were permanently located at the supplier, or vice versa, did the contract protect IBM from joint-employer relationship exposures?
6. Were deliverables specified in the contract?
7. Was a change control process in place to identify who was authorized to update the contract and the scope of work?

OVERVIEW

AUDIT PROGRAM #50-00-00

CONTROL ASSESSMENT QUESTIONS – GENERAL

Key Control Question: 1. Supplier Management / Procurement

Primary Test: Contract Administration (SM003.P)

(Continued)

8. Was a firm, fixed, not-to-exceed price stipulated in the contract? If not, was there clear documentation as to how price would be determined?
9. Were all actual costs incurred, including overtime, extra charges etc., being measured against the costs specified in the contract or purchase order (PO)?
10. Were cancellation terms and costs, and the methodology for determining settlement, clearly defined in the contract?
11. Were contract terms in accordance with quoted terms for price, delivery, quality, and discount?
12. If the audit clause had been exercised, were the results reviewed and actions taken where necessary?
13. Were contracts processed and loaded into Contract On-Line Tool (COLT) in a timely manner, i.e., were they held 'in-prep' greater than local targets (most procurement looks for contracts to be loaded into COLT Nextance within 180 days)?
14. Had the procurement contract owner established a process for validating that both IBM and the supplier had met all the commitments established in the contract? (This includes, but isn't limited to product deliverables, quality standards, timeliness of delivery, and safety and security location reviews that were required by the contract) If the procurement contract owner did not have direct control, determine if they required that the organization that did have direct control, also had established an auditable process to monitor both IBM's and the supplier's performance against commitments.? Or, had potential business risks been identified that could occur without this process in place?
15. Was there a means of comparing the current projected value of a contract against its original projected value? Review those contracts where the current projected value exceeds the original projected value by 20% or more and the delta is greater than \$1 million. Were these contracts re-evaluated to determine if the price, terms or conditions should be renegotiated? If there were exceptions to this requirement, were they reviewed by the procurement manager? NOTE: This question is applicable to only those contracts that identify a deliverable, usually the SOW (not the base agreements).

Also, compare contracts with similar deliverables to verify that rate schedules are consistent for like services. NOTE: Can also compare pricing in the Procurement Contract Management System (PCMS), if used, to prices outlined in contracts.

16. Was there a process to review and approve contract change costs and cancellation costs?
17. Were the rates contained in the invoices consistent with the rates identified in the contracts and POs?
18. Were delivery and payment terms consistent with those in the contracts?

OVERVIEW

AUDIT PROGRAM #50-00-00

CONTROL ASSESSMENT QUESTIONS – GENERAL

Key Control Question: 1. Supplier Management / Procurement

Primary Test: Contract Administration (SM003.P)

(Continued)

19. Were contracted rates similar for contracts with similar deliverables?
20. Were agreements to protect the privacy of IBM and supplier data in place for all e-procurement relationships?
21. Were all active procurement agreements, including customer supplier agreements in an outsourced arrangement, loaded into COLT Nextance? If the contract was not scanned into COLT Nextance, was there sufficient information provided to locate the contract in a timely manner? Was a procurement approved template used for all documents? NOTE: If there is no system capability to use COLT Nextance, then the requirement to store final agreements in COLT Nextance is waived.
22. Verify that all terms and conditions of the contract were being monitored and executed properly. If a contract clause required activity by IBM or the supplier, was that activity being performed (ex. insurance certificates, measurements, deliverables).
23. If this purchasing organization establishes, maintains, or owns contracts with external groups that provide contractors to IBM, verify Procurement has a process in place to educate contractor management and supervisory personnel on IBM's contractor guidelines. Select a sample of active agreements involving contractors and verify this education took place. This education should take place before contractors come to an IBM facility and again as necessary to maintain proper awareness of the IBM contractor guidelines.
24. Review agreement management measurements for three consecutive months or quarters to identify agreements that were not properly executed and/or expired with current activity. Also, review trends for aged-in-prep and aged expired agreements.

OVERVIEW

AUDIT PROGRAM #50-00-00

CONTROL ASSESSMENT QUESTIONS – GENERAL

Key Control Question: 1. Supplier Management / Procurement

Primary Test: Approval of Commitments (SM004.P)

Objective:

To verify that there were adequate controls over the process for committing funds for IBM.

Approach:

Obtain copies of local procedures for committing funds. Validate that the procedures comply with Corporate Instruction FIN 101 by requiring a minimum of two independent approvals: (1) requester approval authorizing the release of IBM funds, and (2) procurement approval authorizing the supplier selection, price, and terms and conditions. In addition, did procedures specify that approvals for alterations are based on the difference in the committed amount? Test for proper approvals in "Purchase Order Process (SM001.P) "

Obtain copies of letter of procurement delegation from the IBM Chief Procurement Officer. Adherence to these delegations will be tested in "Purchase Order Process (SM001.P)."

Obtain listings of all organizations to whom the procurement manager had delegated procurement authority. Obtain and review the document (DOU) between the two organizations. Determine if the procurement manager had established a review process which assures compliance to the DOU.

Determine that processes have been established to confirm that levels of approval have not been exceeded as contracts are updated, renewed, or scope of work is changed.

OVERVIEW

AUDIT PROGRAM #50-00-00

CONTROL ASSESSMENT QUESTIONS – GENERAL

Key Control Question: 1. Supplier Management / Procurement

Primary Test: Procurement Bypass (SM005.P)

Objective:

To determine whether procurement had a process for monitoring bypasses and circumvention of procurement through check requests, expense accounts, including electronic check requests, for attempts to circumvent the normal procurement process.

Approach:

Obtain a listing of all check requests, corporate purchase card transactions, invoice only payments and expense account exceptions for the audit period for the line organization being audited and select a sample for review.

1. Confirm that check requests were for valid business purposes?
2. Was there a process for monitoring check requests to identify purchases that should have been made using purchase orders?
3. For purchases made using the procurement credit card, verify that multiple purchases of the same product were not made from the same supplier within the same time period.
 - a. Confirm that supporting documentation existed to validate the receipt of goods or services.
 - b. Determine if a process was in place to reconcile monthly statements received by management and that timely corrective action was taken for identified discrepancies.
4. For expense account exceptions, examine transactions for purchases that should have been made through procurement. The focus of the test is solely on procurement bypass. Any other expense account errors should be documented and presented locally to management; however, full testing of expense account transactions would occur during an Employee Payables engagement. Verify that:
 - a. There were no improper charges for entertainment of supplier personnel.
 - b. Goods and services were not paid for on an employee expense reimbursement that should have been procured using a purchase order.
5. For invoice only payments, determine if there a process to notify the line organization of any improper purchases made without purchase orders?
6. For the purchase orders tested in the sample, were all POs that were coded as a bypass, listed on the bypass report?
7. For all instances of noted bypass (purchase orders, expense accounts, check requests, etc.) was the initiator of these requests contacted by management with a request to use procurement services?
8. Were notifications sent to bypass offenders and their management chain, per the Blue Book?
9. Did bypasses above the delegated clip levels have documentation to support fair value analysis and management approvals?
10. Were bypass recodes (when the source selection code is changed from a bypass activity to a non-bypass activity) valid and properly approved?
11. Was fair value analysis performed for bypasses that were over the appropriate clip level?
12. Were all bypasses reported in the Bypass (CRA2) measurement?
13. Was quarterly testing of non-purchase order categories performed, as required per the Blue Book?

OVERVIEW

AUDIT PROGRAM #50-00-00

CONTROL ASSESSMENT QUESTIONS – GENERAL

Key Control Question: 1. Supplier Management / Procurement

Primary Test: Supplier Assessment (SM006.P)

Objective:

Do controls over the supplier assessment process to protect IBM's interests and verify that the best value was received for IBM?

Approach:

1. Was the supplier checked against the denied parties, unapproved supplier, sensitive customer, and partnership program lists prior to commitment?
 - a. If a supplier was on one of the lists, was prior approval to use the supplier obtained?
 - b. If a supplier was on the partnership program list, was the partnership executive notified, for significant activity, of the decision to use the supplier?
2. Had the suppliers been evaluated for ISO 14001 and ISO 9001 certification? If a company was not ISO-certified, were they encouraged to obtain certification?
3. Was an environmental evaluation of the supplier performed as required in Corporate Instruction 109: Environmental Evaluation of Suppliers. If not, how was the decision not to perform this evaluation determined? Was an evaluation of the supplier's quality management system performed?
4. Did procurement provide suppliers with Shipping Procedural Instructions (SPIs) for every country to which supplier shipped to?
5. Was the Supplier Assessment form and Supplier Questionnaire on the Procurement Web Site completed for all new IBM suppliers?
6. Was supplier conduct principles letter agreement signed for new Core/Strategic, Emerging, and Regional/Niche external suppliers signed?
 - a. If the supplier was not in compliance, was there a documented action plan to achieve compliance within six months and was it sent to the Supply Chain Social Responsibility department?
 - b. For exception beyond six months, was there approval of the IBM Integrated Supply Chain (ISC) Supply Chain Social Responsibility executive?
7. Were current financial reports used to evaluate suppliers (Dun & Bradstreet)? Had procurement determined what levels of financial risk were acceptable? If a company was over the level of acceptable risk, were plans established to monitor a potential supplier's solvency and business justification documented?
8. Were new supplier evaluated to determine their ability to meet the following criteria: financial solvency, adherence to government regulations (including Export regulations, as applicable), meet IBM technology and quality standards, and ability to meet IBM capacity requirements.
9. Was the IBM Security Letter Agreement (SECLA) signed as outlined in the Blue Book?

OVERVIEW

AUDIT PROGRAM #50-00-00

CONTROL ASSESSMENT QUESTIONS – GENERAL

Key Control Question: 1. Supplier Management / Procurement

Primary Test: Supplier Assessment (SM006.P)

(Continued)

10. Safety and environmental requirements (NOTE: these are mainly applicable in production procurement commodities).
- a. Were all purchases of chemicals and other hazardous materials accomplished with the approvals of the site Chemical Coordinator?
 - b. When IBM requests a supplier to use hazardous material or equipment involving hazardous material, was an environmental evaluation performed?
 - c. Were the contracts with hazardous waste disposal vendors in line with procurement guidelines?
 - d. Did all purchases meet the applicable IBM and regulatory health and safety requirements? Look for purchases of commercial electrical products; non-product equipment for IBM internal use; equipment involving hazardous materials, radioactive sources or lasers; contracts for on-site contractor file services.
 - e. Were all suppliers in compliance with the IBM policy regarding Ozone-Depleting Chemicals (ODC)? IBM will no longer accept any product or part from a supplier that contains or was manufactured using Class 1 ozone depleting chemicals known as chlorofluorocarbons, halos, methyl chloroform, and carbon tetrachloride. If a supplier is not in compliance or is unable to comply with this ODC policy, then they are held responsible to contact IBM to have their situation reviewed. All exceptions must be pre-approved by the Chief Procurement Officer, documented and maintained on file for periodic review. In addition, CHQ tax and CHQ distribution must be copied on all exceptions granted by procurement.
 - f. Were potential contractors evaluated against safety performance objectives? Look for submissions of company OSHA rates, insurance experience modification rates, written safety programs, and past safety performance on IBM premises (outside the US equivalent country data should be used).
11. If we used the supplier only for small amounts or a low number of transactions, identify the reason why we could not use our core suppliers. Verify for fraudulent activities, especially in areas where we have purchased consulting services. Especially watch for suppliers that were sole source or customer directed.

OVERVIEW

AUDIT PROGRAM #50-00-00

CONTROL ASSESSMENT QUESTIONS – GENERAL

Key Control Question: 2. Data Security and Privacy

Objective:

To ensure that access to systems used to deliver services to external customers is controlled in a timely manner, and to prevent unauthorized access to applications and information. Appropriate management approvals should be granted and documented according to business need. Ensure adherence to Information Technology Security Standards and Chapter 3: End user Acceptable Use Requirements, 3.1 General User Responsibilities.

Risk/Exposure:

Unauthorized persons may gain access to the application and its resources enabling them to enter unauthorized transactions or to make unauthorized changes to data or programs.

Ineffective control of customers application may result in financial loss to IBM and customers.

OVERVIEW

AUDIT PROGRAM #50-00-00

CONTROL ASSESSMENT QUESTIONS – GENERAL

Key Control Question: 2. Data Security and Privacy

Primary Test: Data Security and Privacy (DS001.P)

Objective:

To ensure that access to systems used to deliver services to external customers is controlled in a timely manner, and to prevent unauthorized access to applications and information. Appropriate management approvals should be granted and documented according to business need. Ensure adherence to Information Technology Security Standards and Chapter 3: End user Acceptable Use Requirements, 3.1 General User Responsibilities.

To verify that a process is in place to safeguard data that is reviewed or stored as part of delivering services to external customers.

Approach:

Review list of applications and databases used to deliver services to external customers.

Were all necessary ASCA certifications in place for IBM applications, databases, and spreadsheets used as a trusted source of information.

Access Control

1. Review the access controls lists to IBM managed applications and systems to validate that users have an appropriate business rationale.
2. Review access lists to establish business need and verify that periodic continued business need was performed and complete.
3. Verify that management controls and authorization of all access to the application and data can be demonstrated with management awareness and removal of such access is processed when there is no longer a business justification.
4. For systems used in the delivery services, were controls in place to guarantee physical and logical security?
5. Were system controls and execution in accordance with the contract signed with the customer?
6. Review IBM employee access to customer applications to verify that IBM is approved by the customer (and the company licensing the application, if applicable) to use the applications.

Data Privacy

1. Review the customer's definition of data privacy and the customer's documentation requirements to protect customer and end users' information. Validate that there are controls around this process to certify that IBM is sufficiently protecting information per customer requirements.
2. Review documentation to ensure proper classification of information. Customer requirements for classification of customer confidential documentation should be identified in the signed contract. Ensure that there are controls in place to follow customer guidelines for information.

Test: Privacy

Objective:

Privacy laws impose requirements on how IBM and its Clients process Personal Information (PI). The Global Privacy Control Assessment Questions are composed with two key areas of the business to help address compliance with these various high-level laws.

OVERVIEW

AUDIT PROGRAM #50-00-00

CONTROL ASSESSMENT QUESTIONS – GENERAL

Key Control Question: 2. Data Security and Privacy

Primary Test: Data Security and Privacy (DS001.P)

(Continued)

- **IBM as a Controller** – The Enterprise Privacy Baseline – Controller establishes the high-level requirements that IBM must meet when acting as a Controller of Personal Information (PI). That is, PI that IBM collects and processes for its own purposes, such as Business Contact Information that IBM holds on its existing or potential customers or suppliers.
- **IBM as a Processor** – The Enterprise Privacy Baseline – Processor establishes the principles and requirements that IBM must meet when acting as a Processor of Client Personal Information (PI) and applies to all products, offerings, and services (including their components) that IBM provides to Clients, regardless of whether IBM develops or re-brands them, or provides them for a fee or on a beta, trial, or no-charge basis.

Approach:

Review the Data Privacy responses provided from the Initial Data Request. Determine if IBM is Controller or Processor of PI/SPI data in the process.

Testing:

IBM as Controller

If IBM is Controller, request a risk-based sample of Global Privacy Assessments for the processes and/or assets. Complete the testing from the following link: <https://ibm.ent.box.com/file/1198251968388>

IBM as Processor

If IBM is Processor, select a sample of products/offerings/services provided for the in-scope activities. Complete the testing from the following link: <https://ibm.ent.box.com/file/1198263127550>

IBM as both Controller and Processor

Test either IBM as Controller or Processor, do not test both. Consider the volume and sensitivity of the controller and processor data and select the higher risk.

OVERVIEW

AUDIT PROGRAM #50-00-00

CONTROL ASSESSMENT QUESTIONS – GENERAL

Key Control Question: 3. Separation of Duties

Objective:

Was the location organized and operating in a manner that ensures appropriate separation of duties? Are controls effective in preventing unauthorized accesses?

Risk/Exposure:

Separation of duties involves the assignment of responsibility for a transaction in a manner so that the duties of one employee automatically provide a cross-check on the work of one or more other employees. The primary purpose of separation of duties is the prevention and prompt detection of errors or irregularities in the performance of assigned responsibilities. Functions are considered to be incompatible from a control standpoint when it is possible for an individual to commit errors or irregularities in the normal course of his duties and to prevent their detection by the system. Individuals with incompatible job responsibilities and system access capabilities are an exposure to IBM.

Failure to monitor and control all capabilities to add, change, or delete billing data creates an exposure to loss and/or misappropriation.

OVERVIEW

AUDIT PROGRAM #50-00-00

CONTROL ASSESSMENT QUESTIONS – GENERAL

Key Control Question: 3. Separation of Duties

Primary Test: Separation of Duties (SO001.P)

Objective:

To determine if any individuals have incompatible responsibilities that would allow the system of internal controls to be circumvented.

To determine if appropriate separation of duties exist to ensure that capabilities to change, add, or delete data is strictly controlled. To ensure that usage of these capabilities is restricted and approved by management.

Approach:

Request an organization chart listing the responsibilities of each employee to assist in determining if any separation of duties exposures exist.

Review for critical processing transactions and access control listings to ensure proper separation of duties exist and access has been properly authorized.

Ensure that controls exist to protect all systems from unauthorized access or use.

- Obtain a copy of the organization's SOD assessment.
- Review application system mnemonics to identify transaction conflicts (i.e., billing, accounts receivable, customer / number records, inventory, and accounting)
- If conflicts have been identified or exist in either of the above, review secondary controls or risk acceptances as appropriate. In addition, if conflicts exist, the auditor must decide if transactions processed by the individuals with conflicts should be tested.

Some common conflicts to test for

Employees with Billing capability should not have:

- A/R processing responsibility
- Responsibility to adjust billing that they generate
- Access to customer number processing

Employees with cash application capability should not have:

- Capability to process bank adjustments, create billing, issue credits or change or create customer master records
- Responsibility to reconcile bank accounts
- Access to unendorsed checks
- Accounts Payable processing capabilities/responsibilities
- Access to inventories of blank checks or other invoice documents

Employees with A/R responsibility should not have:

- Billing or adjustment processing responsibilities
- Price override authority
- Cash application or cash adjustment capability

Employees with customer master record responsibility should not have:

- Price override
- Billing or A/R responsibilities
- Order entry / management authority

OVERVIEW

AUDIT PROGRAM #50-00-00

CONTROL ASSESSMENT QUESTIONS – GENERAL

Key Control Question: 3. Separation of Duties

Primary Test: Separation of Duties (SO001.P)

(Continued)

Employees who balance the daily cash receipt should not have the responsibility for recording the receipt and application of cash.

Employees who order cash receipt books or blank invoices should not have disbursement control responsibility.

If approved risk acceptances are in place to address SOD issues, ensure that the secondary controls are adequate and executed.

OVERVIEW

AUDIT PROGRAM #50-00-00

CONTROL ASSESSMENT QUESTIONS – GENERAL

Key Control Question: 4. Asset Management

Objective:

Asset Management (AM) is the process for capturing, integrating, and maintaining technical and financial information about hardware and software assets from acquisition through to disposal. In April 2009, an agreement was reached to a phased integration of AM and Customer Fulfilment. As a result, the management responsibility for asset management moved from the Integrated Technology Delivery (ITD) to the Integrated Supply Chain, Customer Fulfilment (CF) organization. Processes can be in support of both external and internal customers and relate to both hardware and software.

The AM process starts with an assessment of the business requirements, which may require the transfer of assets from a customer to IBM, purchase, or lease of a new asset and/or reuse of existing assets. Having validated whether existing assets can be reused or not, and a decision to purchase / move an existing asset from one contract / account / business area is made then approvals are obtained to process the order, receive, track physically and financially. Any disposals are managed through a similar approach. This audit program focuses on the responsibilities for asset management as a stand-alone audit as opposed to asset management within other audit programs (typically CRM for Services audits).

The AM competency defines their main processes through 10 best practices (BP). Note that BP 10 (SW Financial Reconciliation Process) was retired and is no longer a service provided by the AM competency).

Risk/Exposure:

1. Inaccurate inventory records either hardware assets or software licenses could result in customer disputes.
2. Project timeline to transition AM services to IBM is insufficient to meet deliverables. Reliance on other teams to complete activities (including inventory baselines) may impact AM delivery.
3. Inaccurate inventory records could lead to loss of assets.
4. Incomplete identification and monitoring of hardware assets may result in missed or delayed decision relating to replacement of assets and asset scrapping and could lead to breach of contractual requirements and penalties.
5. Inadequate controls to ensure that IBM assets are adequately protected could result in loss of assets and financial loss. (Note: ITD would own the physical controls in most cases)

Missing processes to ensure effective actions are taken to investigate and resolve inventory discrepancies could allow lost assets to remain undetected and result in financial loss.

Scrapping of assets without the required business and financial approvals and not recording the scrapping of assets could result in unauthorized scrapping of equipment, inaccurate asset records and reporting within IBM and to customers, and increased cost to IBM.

Lack of periodic physical inventory checks (W2W, F2B, B2F) in accordance IBM best practices may result in inaccurate asset records, lost and stolen assets remaining unidentified and breach of contracts.

Incomplete book to book reconciliations could result in inaccurate inventory data and could lead to loss of machines or incomplete financial records.

OVERVIEW

AUDIT PROGRAM #50-00-00

CONTROL ASSESSMENT QUESTIONS – GENERAL

Key Control Question: 4. Asset Management

(Continued)

Buy-backs - have we followed the process - do we pay more for buy-backs more than we originally paid - round tripping - CRM or Asset Management 07-25-03. Also, where IBM has paid significantly more than the fair market value of assets, are contractual terms in place to protect IBM's involvement in third party financial reporting impacts. Asset management does not own the assets.

Asset Utilization - There is an increased cost to IBM if assets are not utilized fully.

Assets not identified for reuse result in additional purchase - Is there a process in place when a new contract or internal asset requirement is identified to re-utilize existing assets?

Under-used assets could result in additional purchases and therefore additional cost - Is there a process in place when a new contract or internal asset requirement is identified spare capacity on existing assets?

What processes are in place to provide management with information to make a decision whether assets are fully utilized in support of a purchase or re-use decision?

Funds are committed without authorized approval (low risk area with all of the financial controls on capital and the procurement controls on ordering).

Requested items are not ordered or delivered in time (order is incomplete, requirements are not correct).

IBM provided payments for assets ordered, but not received, or for incomplete and/or incorrectly filled orders (note this is more of an issue with the procurement and accounts payable processes).

Incomplete or untimely adjustments for contract terminations and decisions related to end-of-use situations may have financial impact. Lack of technical support due to lapsed maintenance.

Unlicensed software. Watch for use of trial software - must be used for limited amount of time, removed promptly if not purchased.

Adherence to the corporate and AM processes related to incident reporting for lost or stolen assets when there are potential data privacy issues.

OVERVIEW

AUDIT PROGRAM #50-00-00

CONTROL ASSESSMENT QUESTIONS – GENERAL

Key Control Question: 4. Asset Management

Primary Test: Contractual Responsibility (AM001.P)

Objective:

Determine IBM's contractual responsibility and associated Service Level Agreements and associated financial implications.

Approach:

1. Review the contract and its associated schedules to determine whether there are contractual requirements for asset management activities.
2. Are the terms and conditions clear and unambiguous?
3. Determine ownership and responsibility of the assets
 - a. IBM ownership: IBM responsibility
 - b. Third Party ownership: IBM responsibility
 - c. Customer ownership; IBM Responsibility
4. Determine whether there are Service Level Agreements (SLA) associated with the contract and whether there are penalties associated with not attaining the SLA agreement.
5. Determine whether there is any financial impact associated with asset management activities, i.e., where billing is dependent on assets or service level agreement penalties are imposed.
6. For contracts less than a year old:
 - a. Validate that a signed "bill of sale" existed for assets which were acquired at the beginning of the contract.
 - b. Verify that the initial asset values of purchased assets are reflected in the negotiated contract. The signed "bill of sale" should indicate this.
 - c. Verify what terms are in place to protect IBM when the final inventory is different to what was agreed in the negotiation.
 - d. Ensure that IBM's ownership of the assets can be demonstrated and that the amount paid did not exceed the fair market value (FMV), FMV can be provided by IBM Global Financing (IGF).
 - e. Was the transfer of assets from the customer to IBM detailed in the transition plan?
 - f. Were all HW assets listed and reconciled to the contract?
 - g. Are there situations where customer owned assets not yet transferred to IBM have been upgraded with IBM assets. Evaluate management of these assets including the recording of book values and effective management of disposal.
 - h. Were assets purchased physically verified, and was this a requirement of the agreement of the inventory?
7. For contracts over one year old:
 - a. Obtain the most recent inventory listing and compare against the appropriate contract schedule for accuracy and current status.
 - b. The inventory listing should indicate the location of all assets, e.g., IBM site, customer site, other site.
 - c. Determine whether these assets were outright purchases or leases. If leases, review terms and conditions of lease agreements to understand IBM's liability of assuming.
 - d. Leases (this can be ascertained from base agreement or schedules/appendices). A plan should be in place to ensure that leases do not default to automatic renewal.

OVERVIEW

AUDIT PROGRAM #50-00-00

CONTROL ASSESSMENT QUESTIONS – GENERAL

Key Control Question: 4. Asset Management

Primary Test: Asset Management Process (AM002.P)

Objective:

Does a process exist to cover all asset management activities, i.e., Approval, Order, Tracking, Updates, Changes, Reporting, End of Asset life?

Approach:

Is there a documented process to cover all asset management activities?

Have approvals been made and processing timeliness met for asset purchases, redeployment, and retirement?

Consider the following aspects of the process steps:

1. Did the account lease versus buy a new asset and did the decision meet the financial criteria?
2. Capital approval for purchases: Are all capital expenditures appropriately planned and approved?
3. Order Management - Is there a procurement process for OEM products?
4. Receipt of assets - Was the receipt of the asset handled efficiently? Consider:
 - a. Were assets signed for, verified in line with order, checked for damage?
 - b. What was the escalation process if discrepancies?
 - c. How were incorrect receipts resolved?
5. Asset Tracking - How were assets tracked once received into IBM
Were asset records updated in the relevant asset repositories with all relevant fields, i.e., type, model, serial number, street name, location, owner, user?
6. Asset Updates - When physical changes were made to assets, e.g., change in physical location, was there an effective process in place to record the changes? Consider:
 - a. When changes were made to the asset databases?
 - b. Had the changes been approved correctly?
 - c. How are unauthorized changes detected?
 - d. Were reconciliations performed on a regular basis, were discrepancies highlighted, and had relevant actions taken place?
 - e. Was physical tracking performed on a regular basis, were discrepancies highlighted and had relevant actions taken place?
7. Control Changes, e.g., Commissioning assets into service, was there an effective process to ensure that the correct assets were commissioned, and databases were updated correctly?
Consider:
 - a. Was the change evaluated and categorized correctly?
 - b. Was the change approved by an authorized approver?
 - c. Was the change completed and recorded correctly?
8. Asset Reporting - Do the reports provided satisfy all legal and contractual requirements?

OVERVIEW

AUDIT PROGRAM #50-00-00

CONTROL ASSESSMENT QUESTIONS – GENERAL

Key Control Question: 4. Asset Management

Primary Test: End of Asset Life (AM003.P)

Objective:

Determine whether a process was in existence and could be demonstrated to evaluate whether assets had come to the end of their life.

Approach:

Evaluate the following:

1. Whether for assets whose maintenance and warranty were due to expire was there a process to monitor those assets and give adequate notice to either renew or cancel the service? Any End of use assets including mid lease disposal of asset, and selling / scrapping of a disposed asset: Is there a mechanism to flag that an asset is coming to end of use? Is the decision appropriately approved to either scrap or sell the asset?
2. For assets that were scrapped:
 - a. Has approval been gained to scrap the asset from the asset owner?
 - b. Was all data removed from the asset prior to scrapping?
 - c. Have any software licenses been cancelled?
 - d. Has confirmation been received that the asset has been scrapped?
 - e. Have the relevant asset databases been updated to reflect the scrapping?
3. For assets that were sold:
 - a. Was all data removed from the asset prior to sale?
 - b. Were the relevant asset databases updated?
 - c. Was the sale recorded correctly in IBM's financial statements?

OVERVIEW

AUDIT PROGRAM #50-00-00

CONTROL ASSESSMENT QUESTIONS – GENERAL

Key Control Question: 4. Asset Management

Primary Test: Reconciliations (AM004.P)

Objective:

Determine whether a process exists to reconcile information between different asset management data repositories.

Approach:

1. Perform Book to Book (B2B) Reconciliations: A key reconciliation is the one between IBM's financial ledger (eAMT) and any database that is used to either charge the customer or is contractually required (local database). The steps to reconcile are:
 - a. Assets in IBM's financial ledger are identified and compared to the local database
 - b. Assets in the local database are compared to IBM's financial ledgers
 - c. A variance report is created, and each variance needs to be resolved in a timely manner
 - d. The reconciliation should be performed on a regular basis as a minimum every year
2. Periodic Physical Inventory Reconciliation: There are two stages in the life cycle of assets where a physical inventory reconciliation is required. The transition stage and the steady state or business as usual (BAU) stage:
 - a. Transition stage: A physical inventory is performed to create a "baseline" inventory database, this is to identify the machine that IBM own and customers own and for which IBM are responsible. The inventory is required to be at machine type, model number, serial number, and physical location level and is conducted at transition / transformation (T&T) stage. Note: In Transition the timeframe for completing, loading, and reporting the initial physical inventory is 90 days after contract signing. This time frame can only be extended to 180 days, if a Risk Acceptance is provided to the Finance Transition Manager.
 - b. BAU: On a periodic basis, a physical inventory or sampling of existing inventory is performed to detect and resolve any variances by a Book to Floor (B2F) reconciliation and a Floor to Book (F2B) (every year) and F2B (every second year). Typical issues are:

B2F issues - have machines been moved or scrapped and the database has not been updated.

F2B issues - assets found have not been recorded in the appropriate asset management database. In addition, if there are significant issues identified as part of the asset tracking process one may be conducted or if there is a requirement for a physical inventory review may be a contractual requirement. In the event this is not clearly defined, agreement should be reached with the customer on the following:
 - c. Clearly identify the meaning of the contract (Joint Verification).
 - i. Determine an overall scope for an approved physical inventory if the contract was unclear on that subject.
 - ii. Agree and document the exit criteria for the physical inventory in an exit criteria agreement/document. Exit criteria are:
 1. The completeness is ascertained if the site customer contact affirms the inspection of all sites concerning asset inventory.
 2. The correctness is ascertained if the Physical Inventory proceeds in a syntactical correct manner. All acting complies with the standard and rules. The scope is maintained.

OVERVIEW

AUDIT PROGRAM #50-00-00

CONTROL ASSESSMENT QUESTIONS – GENERAL

Key Control Question: 4. Asset Management

Primary Test: Reconciliations (AM004.P)

(Continued)

3. The quality is ascertained if the gap between expected and collected assets is within the defined tolerance.
4. Agree with the customer about the management of assets not listed but found during the wall-to-wall inventory and assets not found but listed in the asset schedule of the contract.

3. Develop Plan and Prepare for Physical Inventory Reconciliation

Consider whether the inventory reconciliation is to take place at an IBM site or a customer site. Notice periods may be required in the contractual terms.

In preparing for an inventory, a Physical Site Layout needs to be obtained. The first contact should be either the local support engineer or the site Facilities and Property representative. Physical layouts should be as much detailed as possible either using grid coordinates or numbering of racks or desks. If a site layout is not available, an approach for creating layouts has to be defined, e.g., grid coordinates. A plan for the inventory should then be prepared detailing logistics relating to the activity (locations, staffing requirements, access requirements). A full Physical Inventory or sample Inventory is then performed.

For IT Delivery Owned Hardware

- Verify if inventory has been performed and book-to-floor and floor-to-book reconciled according to the Worldwide Asset Management Inventory Guidance at least annual for IT Delivery owned hardware.
- Verify if inventory has been performed and floor-to-book (physical inventory vs. e-AMT) reconciled according to Pan-Europa AM Inventory Guidance at least annually for IT Delivery owned HW.
- Check if evidence of inventory and reconciliation is documented in the Account Control Book and signed by DPE.

For Customer Owned Hardware

- Verify if inventory has been performed according to contractual obligation and within the contractual agreed period, but minimum at least annual for customer owned hardware.

For Customer Owned Hardware in IBM Datacenters

- Verify if inventory has been performed and book-to-floor and floor-to-book reconciled according to Worldwide Asset Management Inventory Guidance at least annually for customer owned assets on IBM premises.
- Check if evidence of inventory and reconciliation is documented in the Account Control Book and signed by DPE.

Issue resolution following the inventory:

An action plan is required, with approval to include details of the issues, the remediation action per issue, target resolution dates, action owners.

OVERVIEW

AUDIT PROGRAM #50-00-00

CONTROL ASSESSMENT QUESTIONS – GENERAL

Key Control Question: 4. Asset Management

Primary Test: Physical Security of Assets (AM005.P)

Objective:

For IBM Managed sites with one or multiple customers, for Customer sites with one or multiple suppliers, and for satellite sites (e.g., bank branches, retail outlets), determine whether appropriate actions have been taken to secure assets. If assets go missing or are stolen, were contractual obligations met and were incidents reported to IBM security.

Approach:

Physical inspection of a location to ensure appropriate physical security and the necessary barriers are in place to stop unauthorized access especially for locations where assets are held as stock.

Note it is easily identified if certain assets go missing, i.e., those in service 24 hours a day, e.g., if router switches are stolen, the system will be unavailable.

However, risk areas are stock rooms - determine whether physical barriers exist and whether an inventory management process exists to control and track stock levels.

If an asset is stolen, are there any specific contractual requirements in reporting the asset stolen. Was the IBM security process followed.

Consider stores of assets used for replacement / backup that are not connected to the network.

OVERVIEW

AUDIT PROGRAM #50-00-00

CONTROL ASSESSMENT QUESTIONS – GENERAL

Key Control Question: 5. Access Management

Objective:

Are there adequate access and update capability controls to prevent unauthorized changes to programs or fraudulent transaction processing.

Risk/Exposure:

Unauthorized persons may gain access to the application and its resources enabling them to enter unauthorized transactions or to make unauthorized changes to data or programs. Lack of separation of duties may allow an individual to make unauthorized changes to the application or process unauthorized transactions.

Ineffective control of sensitive program changes may result in financial loss to IBM and customers.

Workstations used in support of critical applications which are not protected could result in the unauthorized access, loss, or misuse of a critical application and associated data.

OVERVIEW

AUDIT PROGRAM #50-00-00

CONTROL ASSESSMENT QUESTIONS – GENERAL

Key Control Question: 5. Access Management

Primary Test: Application and Data Access Authorization (AC001.P)

Objective:

Understand AS contractual requirements and use IBM standards as guidelines and best practices.

Verify that management controls and authorization of all access to the application and data can be demonstrated with management awareness.

Verify that removal of such access is processed when there is no longer a business justification (e.g., at separation or change of assignment).

Verify that a valid business need for privileged userids exists and is current.

Verify that an accountability for shared user ids can be established.

Verify that processes have been implemented to perform application security assurance reviews.

Verify that sensitive programs and associated sensitive data are identified and protected accordingly, including proper authorization for access and use.

Verify privileged access is logged and audit trails are kept at least 60 days.

Approach:

Review the processes for user access administration to ensure the process included the following and are in compliance with customer requirements:

- Defined business need criteria to access application user profiles and data
- Procedures for the removal of access and password resets
- Procedures for the annual revalidation of users' continued business need (CBN)
- Procedures for quarterly employment verification
- Procedures for maintaining a log of individual accountability for usage of shared userids (if applicable)
- Clear documentation of the control points within the access management process
- Appropriate approval by management or customer representative
- Ensure privacy assessments have been done on customer data and appropriate controls put in place
- Ensure problem data has been analyzed for customer sensitive information and properly protected

OVERVIEW

AUDIT PROGRAM #50-00-00

CONTROL ASSESSMENT QUESTIONS – GENERAL

Key Control Question: 5. Access Management

Primary Test: Workplace Security (AC002.P)

Objective:

To ensure that controls are in place to safeguard proprietary, sensitive, and personal information against unauthorized disclosure in a customer environment where AMS employees work. All scope areas below need to be compared to contractual requirements for IBM.

Approach:

Review workstation security procedures and monitoring.

Review workplace security procedures and perform onsite inspection if necessary. Inspection of work area to ensure that IBM confidential as well as customer data is secured. They should include the following inspections:

- Unprotected documents that contain classified IBM or customer confidential information
- Unprotected personal information about former, prospective, and current employees (information someone has about someone else)
- Unprotected personal information about customers and suppliers
- Unclaimed IBM Confidential information, or other sensitive output located on printers, copiers, in nearby output racks, confidential disposal units, or recycle bins which are accessible to general site users (e.g., in IBM internal space which can be accessed by anyone with a general access badge for the site, or in a secured area to which there is also general access). Also review the policies and procedures for the removal or disposal of material in confidential disposal units. If bins are used, select a sample of bins for inspection as to their integrity (locks, hinges, etc.)
- Unprotected workstations (e.g., workstations with no power-on or screen-saver password). When workstations are found to be running after hours, they should not be powered down until the reviewer has established that there is not a critical business need for them to be running
- Unsecured laptops, portable peripherals, and other handheld devices
- Unprotected computer media (e.g., diskettes, CD-ROMs, hard drives, extra computer equipment, etc.) that are labeled IBM Confidential

For accounts where AMS managed practitioners connect their laptops to the customer networks, ensure ITCS303 is being followed for encryption of IBM Confidential data.

For accounts where AMS managed practitioners connect their laptops to the customer networks, ensure customer data is being protected.

OVERVIEW

AUDIT PROGRAM #50-00-00

CONTROL ASSESSMENT QUESTIONS – GENERAL

Key Control Question: 6. Billing

Objective:

To determine if controls were sufficient to ensure complete, timely, and accurate processing of all billing transactions.

Did controls include key measurements that gave management visibility to the quality and timeliness of all phases of the billing process? Did controls ensure the accurate processing of transactions to be billed, and could all transactions submitted for billing be tracked back to valid orders processed via management approved order entry systems?

Are exception transactions like customer claims, credit notes, and adjustments (revenue reversals including sales concessions) for customers reasonable, processed accurately, promptly, and properly approved by management? This should include adjustments or claims for customers classified as political parties, government, quasi-government, etc.

Risk/Exposure:

The absence of complete controls could create an exposure to omitted billings, which could impact IBM's cash flow and the accuracy of the financial statements. These controls also alert management to the possibility of file tampering. Unacceptable or deteriorating billing timeliness / accuracy adversely impacts IBM's image, cash flow, results in increased administrative costs, and adversely impacts the financial statements. Delayed and inaccurate billing directly affects IBM's cash flow, increases administrative costs, and adversely impacts the accounts receivable process, the integrity of financial statements, the corporation's image in the marketplace, and customer satisfaction. Adequate measurements and reporting facilitate management's monitoring and timely reaction to these situations.

Credits and adjustments are a sensitive phase of the billing process, and if not properly controlled, could impact compliance with IBM's management and business practice guidelines, create exposures to irregularities, impact processing efficiencies and cost, and negatively impact customer satisfaction.

OVERVIEW

AUDIT PROGRAM #50-00-00

CONTROL ASSESSMENT QUESTIONS – GENERAL

Key Control Question: 6. Billing

Primary Test: Billing - Ship / Bill / Invoice Reconciliation - (BI001.P)

Objective:

To determine if a billing and invoice records exist for every shipment or services transaction processed.

Approach:

Tailor the approach based on the environment:

General considerations

- To ensure complete understanding of all aspects of the billing process, consider flow-charting the complete billing process and documenting needed and existing control points.
- Review local process documentation and process flows. Determine if documents of understanding are required and executed correctly.
- Review peer audit / self-assessments for identified exposures and the effectiveness of action plans implemented to correct them.
- Review all shipped-not-billed and installed-not-billed reports for the audit period. If there are negative trends, select a sample of aged high-value transactions and validate the reason for not being billed. This attribute can be combined with review of control reports in the Backlog Management test.
- Review the Pended Billing reports for all items greater than 15 days. Select a sample of aged, high value transactions to determine if the reasons for not billing are justified and reasonable.
- Determine the level of manual billing and obtain the universe of manual transactions. The auditor should determine if a risk-based sample is to be selected.
- If the entity applies cancellation charges, ensure there is a process to ensure they are applied consistently.
- Determine what controls are in place to ensure proper invoicing of partial shipments.
- Ensure that the entity has a viable approach for applying taxes for orders with multiple ship-to addresses.

Contract / Invoice sample

- For contracts and / or invoices, use the main sample defined in the Contract / Order Management test.
- Ensure that all elements of the contract have been billed.
- Ensure that transactions submitted for billing can be tracked back to valid orders with correct and authorized prices.

Ship / Bill / Invoice reconciliation

- Review reconciliation controls, reports to management of un-reconciled items, and shipment and installation files to ensure complete receipt of billing, i.e., ensure that the transfer of billing records to financial systems is accurate, timely, and complete.
- Obtain a list that compares items billed but not received. In addition, obtain a list that compares items received, but not billed. For each listing, verify that there is a billing record for every shipment or services transaction. Review exceptions or select a judgmental sample, with a dollar limit to be determined by the auditor, and determine if exceptions are resolved, processed, and billed.
- Obtain a list of shipments for a period to be defined by the auditor; use data mining and determine if there is a billing record for all shipments. The auditor should define value and / or products to be reviewed. Based on the number and value of exceptions, decide if all or a sample of the exceptions will be validated.
- Obtain a list that compares the billing and invoice files and provides counts of invoices with no matching billing, billing with no matching invoice, and counts and amounts where the invoice is not equal to the billing amount. Review exceptions or select a risk-based sample with parameters to be determined by the auditor and determine if exceptions are resolved, billed, and invoiced.

OVERVIEW

AUDIT PROGRAM #50-00-00

CONTROL ASSESSMENT QUESTIONS – GENERAL

Key Control Question: 6. Billing

Primary Test: Billing - Ship / Bill / Invoice Reconciliation - (BI001.P)

(Continued)

- Obtain system reconciliation / tie-out records for both bill to invoice and invoice to ledger (or sub-ledger) reconciliations for a time period determined by the auditor. Determine if there were exceptions and if these exceptions were identified and resolved in a timely manner.
- Determine if records can be suspended or held intentionally or unintentionally within the billing application, and how this situation is known and resolved. Determine if this has happened and if any "write-offs" of unresolved transactions have occurred.
- Determine if management had visibility to all unbilled transactions, if root-cause analysis was performed, and if corrective actions were taken to ensure completeness of all billing transactions.

OVERVIEW

AUDIT PROGRAM #50-00-00

CONTROL ASSESSMENT QUESTIONS – GENERAL

Key Control Question: 6. Billing

Primary Test: Billing Measurements - (BI002.P)

Objective:

To determine if the effectiveness of the process is being measured and if management has visibility to the quality and timeliness of all phases of the billing process.

Approach:

Determine what billing measurements are used by management to assess the effectiveness of the process with regard to timeliness and accuracy.

Obtain local measurement reports for a period to be determined by the auditor. Local reports should include the following types of activities / transactions: billing quality, billing release timeliness, details of daily billing activity, installed-not-billed, shipped-not-billed, and pending billing.

Review attainment against objectives to identify trends. Validate performance attainment and examine negative trends.

If attainment is consistently sub-standard, select a sample of exception transactions and determine the root cause.

Ensure that there is management visibility to measurement attainment, and that the management process includes root cause analysis and action plans to rectify any out of line situation. Assess the effectiveness of action plans taken.

OVERVIEW

AUDIT PROGRAM #50-00-00

CONTROL ASSESSMENT QUESTIONS – GENERAL

Key Control Question: 7. Solution Design

Objective:

Are solutions designed in accordance with customer requirements captured during opportunity management, properly reviewed and approved by management, and in compliance with IBM guidelines and instructions.

Risk/Exposure:

The design phase of a solution is crucial to the success of a project. A complete and realistic evaluation of the risks and costs (both internal and external, e.g., suppliers) associated with the proposal is extremely important, and a key input is the full understanding of customers' expectations. Also, a thorough evaluation and approval of all pricing elements and non-standard terms and conditions is necessary to prevent legal issues and safeguard IBM's profitability.

OVERVIEW

AUDIT PROGRAM #50-00-00

CONTROL ASSESSMENT QUESTIONS – GENERAL

Key Control Question: 7. Solution Design

Primary Test: Contract Design and Agreement (SD001.P)

Objective:

To ensure that contract terms can be met by IBM, provide certainty to both parties and protect IBM from risks. To that end, the contract should ensure that customer requirements were clearly and comprehensively defined and documented in the contract, and that the contract is consistent with all approvals and key assumptions in solution design.

Approach:

The contract should be reviewed for non-standard clauses. If such clauses are identified consideration should be given to the impact on the other CRM activities, such as revenue recognition, financial management, approval requirements.

Examples of clauses to look out for include:

- Unrestricted sweeper clauses which can be financially detrimental (a sweeper clause is any clause that commits IBM to unlimited, unquantified, or undefined services and/or liabilities. Indicators of sweeper clauses include ongoing and increasing cost overruns, increased scope, and services without associated revenue and missed service levels)
- Lack of a punitive termination clause
- Unrealistic SLAs or targets - consideration must be given to the type of service and industry (e.g., high levels of server availability may be expected where IBM support customer systems)
- SLAs which have a dependency on a third party outside IBM's control (e.g., end-to-end SLAs where IBM does not have responsibility for all of the service)
- Ambiguous contract language - review instances of ongoing and protracted negotiation (e.g., for contract changes)
- Retrospective benchmarking clauses
- Access to IBM's audit and investigation reports - also review instances where IBM is required to be involved in customer audit reviews, and impact on costs and actions required to address identified issues
- Minimum revenue guarantees. In particular, are there any terms that restrict the achievement of minimum revenue levels, impact IBM's ability to cover its fixed costs? Can customer "cherry pick" services and is that addressed in the pricing and risk associated with the contract?
- Terms that impact IBM's Intellectual Property rights over solutions

In addition, the contract should be reviewed to ensure that:

- The contract included a defined statement of work including measurable acceptance criteria. (where applicable). Where a high-level design is documented, review the timescales and actions required to agree upon a detailed solution design. Ensure the responsibilities for completion are clearly defined. Ensure that if design is not fully completed, then the ability to charge for additional work identified during 'full design' is included in the contract.
- When only a preliminary customer inventory was available, the contract included a clause allowing for financial adjustment when the final inventory is established. Where customer assumptions are provided, validate that these were from customer systems.
- For incremental business, the impact on the scope, deliverables, billing and service levels of the base contract has been clearly identified
- A review has been performed of the contract design to ensure that the solution design is accurately and consistently documented

OVERVIEW

AUDIT PROGRAM #50-00-00

CONTROL ASSESSMENT QUESTIONS – GENERAL

Key Control Question: 7. Solution Design

Primary Test: Contract Design and Agreement (SD001.P)

(Continued)

- IBM resources are available to meet the customer requirement. Where resource commitments are required from other lines of business (e.g., GBS resources to deliver an SO contract) what actions have been taken to confirm the availability of resources with the appropriate skills. Have DOU's been established that secure resource at the right skill level to deliver solutions.
- If IBM resources are not available, ensure that sub-contract resource is identified and contracted through IBM Procurement.
- Whether there are any onerous terms associated with customer disputes e.g. ability for the customer to withhold payments?

Contract approvals

- Was the credit status re-evaluated by IBM Global Finance before proposal was issued to the customer?
- Have all conditions in the approval of the contract (e.g., by Pricing, Legal, Accounting, Quality Assurance) been met?
- Are approvals ambiguous or implicit, e.g., by copy of an e-mail / attendance at a review meeting rather than explicitly?
- Check for any unapproved conditions inconsistent with the contract (e.g., side letters; written or verbal).
- Were the contracts signed and all approvals obtained before commencement of supply of service? If not, was there an approved letter of intent (LOI) or authorization to proceed (ATP) in place?
- Was there evidence that contract signatures had been back dated or the contract had been changed by the customer before signature?
- Have required opportunity learning reviews (formerly Win Loss reviews) have been conducted and documented according to the appropriate clip-level? Check that procedures were in use to disseminate lessons learned.

Data privacy considerations

- If personal data will be processed in another country, does the contract describe the data protection responsibilities, e.g., in Europe a separate European Union (EU) model clause is required before data is exported from the EU. The agreement to create these EU model clauses should be held in the main contract.

OVERVIEW

AUDIT PROGRAM #50-00-00

CONTROL ASSESSMENT QUESTIONS – GENERAL

Key Control Question: 7. Solution Design

Primary Test: Solution Design Mandatories (SD002.P)

Objective:

To ensure that the opportunity has been progressed using the mandatory IBM processes and procedures.

Approach:

Assess the complexity of the opportunity and determine the mandatory activities required based on the Business Transaction Type (BTT). For the selected opportunities verify the following:

- The BTT was calculated correctly, including adjustments for changes in the final stages of contract negotiation
- The pricing case is approved by delegated, authorized personnel. Where pricing approvals are required from multiple lines of business, ensure that approvals were based on a consistent understanding of the solution.
- All internal approvals were in place before proposed solution confirmed with customer
- The customer's credit worthiness has been assessed
- The customer was checked against US Export Regulation requirements
- A denied parties list check has been carried out
- Where required, C&N, accounting, and other organizations have reviewed the solution, and contract as required
- Terms and conditions were properly selected and approved
- Proposal and support plans were in place where required
- The customer requirements were clearly and comprehensively defined, and a detailed solution that addressed requirements was included within the contract and supporting statements of work
- A confidential disclosure agreement was assessed to ensure confidential elements of the contract were secured by both, IBM and the customer
- A preliminary customer inventory was available where required. (The contract should include a clause allowing for financial adjustment when the final inventory is established), and a plan in place to confirm the inventory.
- The solution was correctly priced (refer to test SD002.P for more details). Costs were compiled for all solution components. Adequate understanding of the complexity of transition and transformation was included in the pricing, and non-standard components were included in pricing, including e.g., trade-in, buy-back, demonstration equipment, trial-period-offering.
- Where OEM products are part of the solution, ensure that Product Safety Review Board (PSRB) approval of each product has been confirmed

NOTE: For IBM Consulting, Partners have delegation to conduct some the reviewer/approver activities, as they have the end-to-end responsibility.

OVERVIEW

AUDIT PROGRAM #50-00-00

CONTROL ASSESSMENT QUESTIONS – GENERAL

Key Control Question: 8. Solution Delivery

Objective:

The CM process includes primary testing on the contract proposal, customer acceptance, and fulfillment to the customer; agreement with subcontractors; billing and accounts receivable; and revenue recognition.

Risk/Exposure:

IBM has a long-standing commitment to maintain a correct and equitable business relationship with its customers. Any irregularity (or perceived irregularity) in the customer fulfillment process could damage the relationship with customers and expose IBM to complaints and loss of revenue.

The lack of controls over services contracts could lead to uncontracted services, inappropriate commitments, and customer dissatisfaction. Also, the failure to monitor the use of resources against the plan exposes IBM to billing inaccuracies, additional costs, and incorrect revenue recognition.

OVERVIEW

AUDIT PROGRAM #50-00-00

CONTROL ASSESSMENT QUESTIONS – GENERAL

Key Control Question: 8. Solution Delivery

Primary Test: Contract Proposal Acceptance and Fulfillment (DE001.P)

Objective:

Are contracts valid, in accordance with proposals, and have an authorized price release. Also, verify that work was not performed prior to contract signature, and that suppliers agreements have been obtained.

Verify that the contractual relationship between IBM and the customer has been accurately recorded and maintained during the contract period; that systems reflect the correct contractual status; that terms and conditions are valid, approved, and respected; that billable records have been generated on a timely and accurate basis.

In addition for services contracts, determine the effectiveness of management and operational controls to ensure that only valid and accurate service contracts, based upon customers' requirements, are released to customers.

Approach:

Conduct reviews with management in order to understand the contract management process for each type of contract and identify control weaknesses. For each contract sampled verify the following attributes:

- All contractual terms and conditions offered to the customer are in accordance with the proposal / order and are fully approved by IBM (nonstandard T&Cs been approved by Business Practices and/or Legal).

Proposal / contract includes only approved standard terms and conditions as defined by IBM's Contracts & Negotiations. Exceptions are approved as defined by Corporate Organization Letter (COL) 125L.

- Non-delegated terms and conditions, as defined in COL 125L, have not been offered in the proposal / contract.

Determine if other recent audits have assessed the effectiveness of revenue recognition that would have included the organization being audited. If so, then discuss with the audit manager what, if any, examination of revenue recognition should be performed as part of this engagement. If no recent reviews of revenue recognition have been performed, then determine if the organization has adequate controls over revenue recognition to mitigate the risk of issuing payments based on invalid attainment.

- Does the organization have a documented firm order and firm order exception policy.
 - Is there evidence that the policy is being followed?
 - Verify that the management system includes procedures to assess the incentive payment impact of cancellations, returns and revenue reversal transactions.
 - Review reports of revenue reversals, firm order exceptions, cancellations after shipment, uninstalled equipment reports, delinquent and deferred accounts receivable, etc. and verify that commissions were not paid for revenue that was reversed or not realized.
- If concerns with revenue recognition are identified, discuss with the audit manager if additional testing of revenue recognition should be performed. Should additional testing be required, use the revenue recognition tests: Revenue Recognition (RR001.P), Revenue and Cost Accruals (HS008.S) and Measurements (HS008.S).

OVERVIEW

AUDIT PROGRAM #50-00-00

CONTROL ASSESSMENT QUESTIONS – GENERAL

Key Control Question: 8. Solution Delivery

Primary Test: Contract Proposal Acceptance and Fulfillment (DE001.P)

(Continued)

NOTE: A Ts & Cs Deviations Contact List was created and distributed by the Manager of CHQ Pricing and Investments on 12/01/2000. The intent of this document is to educate and inform people involved in contracts with customers to not bypass the Contracts & Negotiations organization. This document lists intranet sites for standard contracts for all brands and geographies. It also includes a list which details the organization / position to contact for deviations, and references terms and conditions that cannot be changed (IBM Powers Reserved). This complete document is included in the Reference section of this audit program.

- A firm customer order / contract has been received (firm order = product/quantity/price/ delivery date/location have been identified).
- Orders based on Letters of Intent or IBM Initiated Orders have the required authorizations.
- Appropriate systems / project assurances have taken place.
- Does a process exist to ensure that the customer has been credit checked and that adequate controls are in place to ensure U.S export regulation compliance.
- The contract price is:
 - Based on pricing delegations, authorized offerings, and justified discounts (including I/VPA).
 - Sufficiently documented.
 - Properly approved.
 - Reflected / transferred into fulfillment systems accurately and timely.
- Equipment is delivered or services rendered after the contract signature or if not, is there approval to proceed in accordance with a defined authority to proceed process.
- System installation date is consistent with physical installation.
- All contract amendments are properly justified, approved, and documented before commencement.
- For services contacts verify:
 - A valid statement of work or type of service being provided is properly documented.
 - Charges are in accordance with planned resources.
 - Percentage of completion documentation is justified.
 - Actual services are recorded and monitored against the plan.

OVERVIEW

AUDIT PROGRAM #50-00-00

CONTROL ASSESSMENT QUESTIONS – GENERAL

Key Control Question: 8. Solution Delivery

Primary Test: Special Contracts (DE002.P)

Objective:

Is equipment on trial, on-loan or demonstration properly validated and controlled? Are buy-back and trade-in offerings administered in accordance with requirements?

Approach:

Review the local requirements for TPOs, loan and demonstration equipment, select a sample, and verify:

- If the decision is properly supported, reviewed, and approved by management as required.
- A valid contract is in place.
- If the contract was signed prior to the installation of the equipment.
- If the type of equipment, start date and duration are specified within the contract.
- Controls are implemented to ensure that equipment usage is in accordance with T&Cs (e.g., for demo, non-productive use).
- If the equipment is promptly returned to IBM, if not bought by the customer or that contract extensions are properly authorized. Also, if the equipment is timely/correctly billed, when purchased by the customer, during or at the end of the period.
- Any tax requirements are promptly fulfilled.

Also verify if there is a control in place to ensure that the same type of equipment is not already installed or offered to the customer under a similar offering.

Review local procedures for trade-in and buy-back offerings.

Obtain a list of equipment under trade-in or buy-back and verify that:

- The trade-in and buy-back are justified, fully approved and in accordance with the local process.
- An agreement was in place, specifying equipment, return date, and amount to be paid to the customer.
- The machine is collected on time and returned to IBM.
- The customer invoice reflects the terms of the offering.
- The payment to the customer account is authorized and processed only after the actual return of the machine to IBM and no invoice netting (Hardware purchase invoice netted with trade-in amount) has been performed.

OVERVIEW

AUDIT PROGRAM #50-00-00

CONTROL ASSESSMENT QUESTIONS – GENERAL

Key Control Question: 8. Solution Delivery

Primary Test: Deliverables (DE003.P)

Objective:

To determine if management checkpoints and controls were implemented for contract deliverables to ensure they were on schedule, within budgeted cost and in accordance with contract requirements.

A deliverable (according to PgMS) is defined as a physical (including electronic) item required to be provided to the Customer by IBM or to IBM by the Customer under the terms of a contract. Deliverables may include hardware, software, or reports. Deliverables do not include services.

Approach:

- Assess the complexity of the opportunity and determine the mandatory activities required according to the Business Transaction Type (BTT). Review the contract to understand the deliverables and request the universe of all deliverables.
- Were deliverables in the statement of work (SOW) clearly defined? Were deliverables agreed in accordance with contract timelines or delayed?
- Did approved deliverables meet the standards defined in the contract? Do deliverables contain omissions / scope reduction from the originally defined SoW, if so, what is the impact of the changed scope of the deliverable?
- Were customer acceptance criteria and completion criteria accurately defined in the contract?
- Did deliverables meet acceptance tests where required by the contract?
- Assess the root cause of instances where deliverables have not been met, is this due to solution design or delivery.
- Were any concessions, claims or settlements due to delayed or unclear deliverables?
- Was progress on completion of deliverables tracked, including risks relating to successful completion?
- Has an exit management plan been defined as a contract deliverable that details the responsibilities, and costs for each party in the event of termination of the contract? In the case of contracts being terminated, has the plan been followed and closure of the contract been adequately managed? Have all financial closing activities been completed on the contract, including reconciliation of the contract revenue and billing.

OVERVIEW

AUDIT PROGRAM #50-00-00

CONTROL ASSESSMENT QUESTIONS – GENERAL

Key Control Question: 8. Solution Delivery

Primary Test: Contract Change and Request for Services (DE004.P)

Objective:

Ensure that adequate, effective, and timely contract change management controls were in place. This should include service requests, in-scope and out-of-scope contract changes, and terms and conditions changes.

A contract change is typically a change to the base contract affecting terms and conditions, price, delivery. Requests for service are within the scope of the contract and may represent additional revenue or be counted as part of a committed revenue spend. Where requests for services are outside the scope of the base contract, a contract change will also be required. Contract changes and requests for services are equally subject to solution design and delivery processes. Review the requirement in the contract design and agreement process for contract changes and RFS, as these agreements are subject to the same mandatory requirements dependent on clip levels.

Approach:

Obtain the universe of contract changes and RFS during the audit period. Identify high risk samples based upon value, business transaction type (BTT), date signed (close to quarter end) and select a sample to determine if the request and change processes were followed.

- Were all contractual changes and RFS supported by solution design techniques, approvals and appropriate contractual documentation? (see also SD001 and SD002)?
- Review whether RFS impact service penalties, and that controls are in place to manage / minimize penalties.
- Have turnaround targets for contract changes and RFS been met? If not, are corrective action plans in place?
- Where third parties support IBM's turnaround targets, are back-to-back terms in place to enable IBM to meet its targets?
- Review the process to determine whether a request for service is chargeable or not. What controls are in place to assess whether an RFS was correctly treated, i.e., are concessions being hidden by counting RFS work as in-scope?
- Assess whether work started before the RFS was finalized and approved by both IBM and the customer. There should be a process in place to identify and track such bypasses / instances of work at risk. For instances where work at risk is an integral part of the process to manage RFS. Check for bypasses of this process to ensure no hours were worked without customer commitment and without additional billing where applicable. (see also SE009)
- Review a sample of deliverables from RFS and assess whether work performed met the requirements, or whether additional work was performed outside of the scope of the RFS. Review the change management process to manage scope changes to RFS and assess whether all changes were correctly identified, priced and charged accordingly.
- For contracts with significant RFS volumes, has a management system been implemented to monitor and track RFS for cost, and timescales? Where variances occur, are root causes or common issues identified and addressed in the solution design and delivery of future RFS?
- Verify that changes to delivery processes required to manage contract changes and RFS are incorporated into the management system. Confirm that monitoring of RFS is operating to identify operational delays and cost overruns. Assess the processes in place to monitor that RFS cost overruns are visible prior to limits on RFS being reached (e.g., monitoring to highlight when 80% of the RFS costs are spent).

OVERVIEW

AUDIT PROGRAM #50-00-00

CONTROL ASSESSMENT QUESTIONS – GENERAL

Key Control Question: 8. Solution Delivery

Primary Test: Contract Change and Request for Services (DE004.P)

(Continued)

- Confirm that baselines impacted by RFS are correctly priced and adjusted using the contract change process (e.g., reduced resource charges (RRCs) may be an inappropriate mechanism for adjusting charges following an RFS which decommissioned a large number of servers. This can be particularly significant on a contract which includes benchmarking clauses). Look for RFS which support significant expansion or contraction of the customer's business.
- Where appropriate, confirm that RFSs are rolled up into contract changes on a regular basis.

OVERVIEW

AUDIT PROGRAM #50-00-00

CONTROL ASSESSMENT QUESTIONS – GENERAL

Key Control Question: 8. Solution Delivery

Primary Test: Labor Claiming and Work at Risk (DE005.P)

Objective:

To ensure that labor claiming is accurate and in accordance with IBM and line of business guidelines for full labor recording, and controls in place to ensure the integrity of billing and measurements.

To ensure that work is not commenced prior to customer commitment or without following the required IBM work at risk processes. An assessment should be made of how the business monitors for unapproved work at risk, how liabilities are limited or contained with customers, and how violations are dealt with.

Approach:

Review labor claiming records and identify exception situations, including:

- Significant transfers between projects and contracts, indicating potential work at risk
- Net negative hours for employees on specific projects
- Excessive labor claiming (review average claiming by banding)
- Hours transferred between billable and non-billable activity codes including the transfer from vacation and education time to billable
- Significant gaps between when labor was claimed, and the date claimed for
- Codes where expenses have been incurred but no labor claimed? Are there any individuals with expenses and no hours claimed?
- Claiming by individuals on behalf of others, it may be possible for a project manager / administrator to claim on behalf of someone else, however excessive time claimed could indicate inappropriate claiming
- Time recorded against contracts which are re-opened during the audit period so that additional hours can be recorded. This could identify that revenue had been prematurely recognized against the original contract.
- Manipulation of troubled contracts ie when a contract becomes troubled, all spare resource is booked against it to make other contracts and utilization look better

Review reports detailing with project/RFS revenue and cost for situations that indicate issues in labor claiming. Identify projects with no costs, no revenue or excessive costs that may indicate:

- Hours recorded against expired or terminated contracts
- Billable hours not claimed against a billable claim code, with potential missed billing
- Hours worked against a project but not claimed or hours claimed but not worked

Review a sample of contract changes and requests for service (as per test SD004.P) to identify work at risk:

- Review the management system in place to identify work started before contract. Assess the adequacy of that process where instances of significant work at risk exist.
- Review all correspondence for the RFS/contract change to determine if there is any indication of work being carried out prior to contract signature
- For approved work at risk, check for required approvals prior to commencement of work, including communications with the customer to limit liability. Review whether work continued after approvals, cost limits had expired / been exceeded.
- Assess whether controls were in place to monitor expiry of work at risk approvals?
- Assess the impact of work at risk on revenue recognition without a contract
- Review where subcontractors have started work without a signed contract in place, or prior to IBM's contract with the end customer (note, subcontractors can work at their own risk, establish if IBM requested them to start work, and potential for procurement bypass)

OVERVIEW

AUDIT PROGRAM #50-00-00

CONTROL ASSESSMENT QUESTIONS – GENERAL

Key Control Question: 9. Financial Management / Revenue Recognition

Objective:

The general ledger process encompasses the posting of financial transactions from auxiliary or subsidiary ledgers to the general ledger accounts and the creation of accounting transactions based on internal ledger tables (e.g., periodization entries).

For purposes of internal and external reporting, operating decisions, and asset accountability, it is essential that these transactions are executed in conformity with generally accepted accounting principles (GAAP) and within a sound system of internal controls.

Risk/Exposure:

Inaccurate cost and revenue reporting could have a significant impact upon the integrity of the IBM financial statements.

Even if automated systems record cost and revenue in the general ledger from billing and inventory movements, it is still necessary to perform a detailed match between individual cost and revenue records, to ensure that the process is functioning correctly. Any aged, unmatched items might indicate a lack of processing integrity and/or associated administrative problems.

OVERVIEW

AUDIT PROGRAM #50-00-00

CONTROL ASSESSMENT QUESTIONS – GENERAL

Key Control Question: 9. Financial Management / Revenue Recognition

Primary Test: Financial Management (FM001.P)

Objective:

Was contract performance properly and accurately monitored, and results reported? Were there management controls to ensure that contract financials, including budgets/forecasts, are accurate, properly maintained and supported, and consistent with pricing case? Were there significant backlog adjustments that indicate other issues in financial management [note: signings and backlog is a separate audit program, and the overall process tested within a specific S&B audit]?

Approach:

Forecasting and reporting

- Review the process for accurate forecasting and tracking from pricing case to actuals. Are adjustments to the base pricing case (e.g., for additional resource charges (ARCs), reduced resource charges (RRCs), contract changes, and requests for service (RFSs)) made on a timely basis to enable a like-for-like comparison between pricing case and actuals to be maintained.
- Confirm that impacts of risks and issues are accurately reflected in the forecast (e.g., delays in transition and transformation (T&T) leading to future cost and gross profit (GP) impacts, missed service delivery requiring additional costs) through to the end of the contract.
- Ensure that effective interlocks between the various key drivers of cost and service levels on the contract, and the financial management processes are in place. Assess whether information passed regularly to the finance team is sufficient to enable changes in the forecast to be quantified.
- For instances where IBM has an arrangement for open book reporting / accounting, review the contract requirements to share information with the customer. Assess the controls in place to validate and review information shared with the customer.

Project control / portfolio analysis

- Is there a control process which highlights projects which do not report results within expected financial returns (pricing case or revised forecast)? Are all contracts included in such an analysis at individual contract level?
- Consider over- and underperformance of gross profit when compared with typical gross margins, or the pricing case, and whether root cause of issues has been identified and actions / route map put in place to manage risks.
- Has a periodic review of troubled projects been implemented? Are recovery dates for contracts defined, and met? Have recovery plans including deliverables, milestones and measurements been developed and met?

Other income and/or other charges

- Query the general ledger to verify whether other income or other charges were recorded and properly accounted for.
- Determine how the organization records other income and charges in the general ledger. For example, some organizations may record other income and/or other charges by department number, others by contract number.
- Assess the impact on GP reporting of correctly reporting charges above / below gross profit.
- Was other income and/or other charges recorded in the correct time period?
- Are there any instances where contract expenses are included in other charges leading to GP being overstated?

OVERVIEW

AUDIT PROGRAM #50-00-00

CONTROL ASSESSMENT QUESTIONS – GENERAL

Key Control Question: 9. Financial Management / Revenue Recognition

Primary Test: Financial Management (FM001.P)

(Continued)

Capital allocations

- Ensure deliverables included in the contract which require capital expenditure have been planned and requested in order to meet the contractual requirement.

Claims / claims avoidance

- Were any services / costs not charged to the customer in accordance with the contract? Were appropriate approvals in place for concessions?
- Were concessions made as part of a contract negotiation which should have been treated as a claim?
- Were commitments to provide a concession made to the customer prior to IBM approvals?
- Was root cause analysis of the issue conducted to minimize the risk of further lost revenue?

(FOR THE US ONLY) Extended customer assignments within in the employee's home country

- Review the process for tracking and monitoring the duration of employee assignments on the project.
- Assess whether the pricing of the contract took into consideration long-term assignments and the potential for additional costs associated with tax assistance.
- Ensure employee expenses were taxed from the point in time at which it was known their remote assignment would exceed the permitted duration.
- Validate that breaks in continuous service were managed in accordance with the guidelines and did not trigger additional income tax liability. Ensure that breaks in service were not being initiated and recorded with the explicit intent to re-set the allowed duration (e.g., US one year rule).

(FOR THE US ONLY) Primary tax homes

- Review the process for managing apartment approvals and long-term hotel stays. Validate that primary tax home guidance was provided to employees approved for such expenses.
- Ensure controls were in place to validate that employees who had apartment and long-term hotel expenses were in compliance with primary tax home guidelines.
- Perform appropriate testing to validate employee compliance with primary tax home guidelines.
- For instances in which employees were not compliant with primary tax home guidelines, had the reimbursement of remote living expenses been discontinued, and financial reporting corrected?
- Ensure inappropriate remote living expense reimbursements have not been billed to customers, resulting in a financial statement impact.

OVERVIEW

AUDIT PROGRAM #50-00-00

CONTROL ASSESSMENT QUESTIONS – GENERAL

Key Control Question: 9. Financial Management / Revenue Recognition

Primary Test: Revenue Recognition (FM002.P)

Objective:

To ensure that revenue recognition was in accordance with generally accepted accounting principles and IBM practices.

Note: The auditor should review in detail the terms and conditions of contracts selected in sampling to ensure that the revenue is recognized consistent with contractual commitments.

Approach:

The Initial Data Request requires a report of the revenue recognized by the business unit or project over the audit period. Reconcile the data provided with the reported results for the unit / project. When assessing the risks relating to accounting entries, analysis of automated entries versus those that are subject to change and/or have potential for manipulation should be assessed (e.g., certain software revenue recognition may be fixed on a transaction regardless of contract terms, geography), to ensure focus is placed on highest risk revenue in testing. Consideration in sample selection should be focused on fixed price rather than time and materials contract elements, on revenue subject to changes in volumes delivered rather than fixed charges.

When selecting transactions for review focus should be on the following:

- Entries processed at quarter ends and year-end
- High value entries (especially manual entries)
- Revenue recognized based on triggers or input from groups outside the accounting function (e.g., SO Project Office, project management team in cases of percentage of completion)
- Revenue adjustments processed at the Headquarter level
- Material balance sheet adjustments including cost deferrals, high value accruals - including transition and transformation deferrals
- Significant claims and timing of provisions

Ensure compliance with the relevant accounting instructions and guidelines. For the selected sample, verify that services revenue has been recorded when earned. IBM shall recognize revenue to depict the transfer of promised goods or services to customers in an amount that reflects the consideration to which IBM expects to be entitled in exchange for those goods or services. To achieve that principle, IBM shall apply the following steps:

- Step 1: Identify the contract with a customer
- Step 2: Identify the performance obligations in the contract
- Step 3: Determine the transaction price
- Step 4: Allocate the transaction price to the performance obligations in the contract
- Step 5: Recognize revenue when or as IBM satisfies a performance obligation

Key attributes to consider in the review of revenue recognition should include:

- Revenue is recognized in the correct accounting period, and that revenue and cost matching principles were adhered to
- Prior quarter reversals are supported and justified
- Management review / clip levels were adhered to, and adequate separation of duties exists for the processing of manual accounting entries transactions
- Have pass-through / cost recoveries been assessed for revenue recognition implications

OVERVIEW

AUDIT PROGRAM #50-00-00

CONTROL ASSESSMENT QUESTIONS – GENERAL

Key Control Question: 9. Financial Management / Revenue Recognition

Primary Test: Revenue Recognition (FM002.P)

(Continued)

- Consideration should be given to information that indicate issues with revenue recognition (e.g., downgrading of credit rating indicating collection issues)
- Manual entries: assess whether manual entries were required to correct other issues and validate which aspect of a business-as-usual process did not ensure correct revenue recognition. Where manual entries are the basis of transaction, review the adequacy of controls to ensure that they are correctly calculated, including a review of supporting documentation. Assess whether those transactions are processed on a timely basis with supporting backup, and where estimates are used, assess the validity of those estimates.
- Reversal of revenue: assess whether any conditions exist that require the reversal of revenue previously booked. Ensure controls are in place to monitor potential reversals.
- For instances where revenue is adjusted, verify the validity of related commission and incentive payments.
- For contracts that include transition and transformation (T&T) assess whether:
 - Deliverables constitute assets equal to the value of deferrals to the balance sheet. In cases where significant cost overruns have occurred, disputes are in place over the quality of deliverables, or the scope of T&T has significantly changed since approvals for T&T deferrals assess whether Accounting review has been performed and information made available to Accounting to enable an accurate assessment of the value of the asset to be performed.
 - T&T costs are separable from other charges to the customer, and management has reviewed that only work performed on T&T is logged as such.
 - Review the release of deferred T&T revenue and costs to ensure that writebacks are consistent with the period when the benefit of T&T is received.
- Assess the adequacy of controls to validate the accuracy, and timing of Additional Resource Charge (ARCs) and Reduced Resource Credit (RRCs) and their impact on revenue recognition.
- Where revenue is based on labor recording, assess whether subsequent reversals to records were made, and the potential for individuals other than those performing the work to manipulate labor recording.
- Where work at risk is an integral part of contract management, review controls in place to ensure revenue is only recognized on signing of a contract.
- For contracts with significant OEM content, assess whether revenue has been booked as gross or net. For revenue recorded as gross, assess whether the criteria for revenue recognition have been met. Assess whether such transactions have been assessed in accordance with clip levels by the contract team / F&P / Accounting as required. This aspect of testing is often judgmental by nature and should include validation of indicators that include: whether IBM was acting as an agent rather than the primary obliger; balance of core value-add services versus non-core value-add services; which party bears the risk of inventory; value add provided by third parties; contact between IBM's end customer and IBM's suppliers and the end customer perception of which party will address issues with IBM's service.
- For hardware shipments, review for reasonableness of dates (shipment dates, billing date, revenue recognition month, accounts receivable collection date, supplier selection dates, and payment dates) as indicators for abnormal transactions which require further analysis. For example, review: supplier selection versus vendor shipment date and shipment versus billing versus revenue recognition versus accounts receivable collection date.

OVERVIEW

AUDIT PROGRAM #50-00-00

CONTROL ASSESSMENT QUESTIONS – GENERAL

Key Control Question: 10. Document of Understanding (DOU)

Objective:

Is the contractual relationship (IBM/customer) correctly developed, validated, and maintained throughout the fulfillment process? Also, has IBM complied with proper business practice guidelines and concluded the contract in accordance with the terms and conditions. In addition, are services contracts properly established, effectively managed, and in accordance with customer expectations and IBM requirements?

Risk/Exposure:

IBM has a long-standing commitment to maintain a correct and equitable business relationship with its customers. Any irregularity (or perceived irregularity) in the customer fulfillment process could damage the relationship with customers and expose IBM to complaints and loss of revenue.

The lack of controls over services contracts could lead to un-contracted services, inappropriate commitments, and customer dissatisfaction. Also, the failure to monitor the use of resources against the plan exposes IBM to billing inaccuracies, additional costs, and incorrect revenue recognition.

OVERVIEW

AUDIT PROGRAM #50-00-00

CONTROL ASSESSMENT QUESTIONS – GENERAL

Key Control Question: 10. Document of Understanding (DOU)

Primary Test: Document of Understanding (DO001.P)

Objective:

To determine if line management has established processes and procedures to create and manage documents of understanding and service level agreements when the completion, accuracy, and timeliness of a process is dependent on the input or output of another organization.

Approach:

- Review the process documentation developed by the line organization that defines the management responsibilities for meeting organizational business objectives through relationships with other organizations within IBM.
- Identify key departmental processes requiring interdepartmental relationships and determine that DOUs have been established when the following criteria apply:
 - There is a high level of inter-departmental responsibility
 - The complexity level of the process is high, or
 - A critical dependency exists between functions.
- Develop a list of all DOUs that were in effect during the audit period and review the DOUs against the following criteria:
 - Were DOUs current? Were DOUs completed and signed during the transition period.
 - Did the agreement clearly define the roles, relationships, and responsibilities of the participating organizations?
 - Were the requirements complete, and the deliverables defined and measurable?
 - Had line management established a method for validating that services were being received or performed as agreed?
 - Had there been any changes (Interlock Change Documentation) in the process during the audit period? If so, were change control procedures established so that management could request changes and updates to the DOU? Verify that any adjustments to interlocks are substantiated and properly documented.

OVERVIEW

AUDIT PROGRAM #50-00-00

CONTROL ASSESSMENT QUESTIONS – GENERAL

Key Control Question: 11. Trade Compliance

Objective:

To confirm that IBM products, technology, and services to be exported, re-exported, or delivered were properly classified prior to export and the appropriate licenses were obtained.

Were operations adequately managed to verify compliance with the Export Regulation Office (ERO) United States Export Regulation Program (USERP) requirements, and corporate and local procedures governing export compliance requirements?

Risk/Exposure:

Failure to comply with IBM's export regulation requirements could result in delays in freight movement, fines and penalties, and the potential loss of IBM's export privilege. For example, export shipment transactions with or involving entities on the Denied Parties List may result in export regulation compliance incidents and damage to IBM's reputation.

OVERVIEW

AUDIT PROGRAM #50-00-00

CONTROL ASSESSMENT QUESTIONS – GENERAL

Key Control Question: 11. Trade Compliance

Primary Test: Integrated Product Development (TC001.P)

Note: This applies to all products, cryptographic, non-cryptographic, defense related, etc. This also includes software and technology introduced into a development organization's Online Collaboration Environments (OCE). OCEs includes team rooms, connections communities, Slack, databases, etc., plus external and internal cloud environment for international development project collaboration and discussion.

Objective:

To confirm that IBM products, technology and services to be exported, re-exported or delivered were properly classified prior to export and the appropriate licenses were obtained. Classification must be communicated by the controlling development and research organization to all other development and research organizations collaborating with development projects. This test includes verification of US export and legal requirements whenever technologies are communicated, exposed, released, or transferred to or in the presence of foreign persons working in countries in which they are not citizens or legal residents.

Approach:

- Were there documented processes for determining product/technology/services classifications for export transactions, including the release to foreign nationals in the US?
- Were export classifications correctly performed?
- Had all relevant development functions been identified?
- Have the development functions documented procedures to complete the appropriate classification documents prior to product announcement?
- Do development and research organization controls require export classification of OCEs based on the software and technology contents of those OCEs?
- Are access controls in place for the OCE based on the OCEs export classification and the nationalities of the individuals that have authorized access to the OCE?
- Do controls require periodic revalidation of the OCE classifications and associated access control lists?
- Does sample testing confirm OCE classifications have been obtained and access control lists are being managed consistent with the classification?
- Do operating unit controls require the controlling development location/organization to provide the export classifications of projects being transferred to or working in collaboration with other development organizations, IBM and external?
- Do IBM development organizations who are not the controlling organization have controls in place that require that project work not be accepted until the controlling development organization has communicated the relevant export classifications to them?

Review the procedures for identifying foreign persons who are employed at the audited location for determining any US export compliance requirements that apply to those person's IBM job assignments. These procedures must include all the following requirements:

- Identification of the nationality of all foreign persons that will be employed by IBM (IBM employees and contractors) before the employees or contractors' assignments begin.
- A review of all source code or technology that is required for a foreign person to perform their IBM job assignment.

OVERVIEW

AUDIT PROGRAM #50-00-00

CONTROL ASSESSMENT QUESTIONS – GENERAL

Key Control Question: 11. Trade Compliance

Primary Test: Integrated Product Development (TC001.P)

(Continued)

- A review of all source code or technology that a foreign person employed by IBM may have access to while performing their IBM job assignment. This includes (but is not limited to) access to output from or data residing on servers, team rooms, databases, electronic libraries, and any other on-line collaborative environment (e.g., wikis) that the foreign person will be granted access to while working for IBM.
- Emphasis needs to be placed on controls for foreign persons from any of the embargoed/terrorist countries (i.e., Cuba, Iran, North Korea, Sudan, and Syria).

Review that the IBM operating unit has implemented procedures to ensure site visits by foreign nationals are appropriately assessed, prior to the visit occurring, for any deemed export/re-export considerations that may apply. These evaluations should be based on the IBM host's knowledge of their visitors and the classification of the technology and/or source code which will be accessed during their visit.

OVERVIEW

AUDIT PROGRAM #50-00-00

CONTROL ASSESSMENT QUESTIONS – GENERAL

Key Control Question: 11. Trade Compliance

Primary Test: Supplier Selection (TC002.P)

Objective:

To determine if operations were adequately managed to prevent procurement transactions with parties on the IBM Denied Parties List (DPL). The execution owner responsible for this monitoring is Procurement.

Approach:

See Procurement audit program (44-00-00), Supplier Selection and Fair Value Analysis (SF001.P).

OVERVIEW

AUDIT PROGRAM #50-00-00

CONTROL ASSESSMENT QUESTIONS – GENERAL

Key Control Question: 11. Trade Compliance

Primary Test: Denied Party List Screening (TC003.P)

Note: These questions apply to IBM operations and processes that are executed by either GL or by LLP when those operations include DPL screening as a requirement within them.

Objective:

To determine if IBM export and re-export shipment operations are adequately managed to prevent shipments and deliveries to entities on the IBM Denied Parties List (DPL).

Approach:

Are there written procedures describing how DPL screening is completed that include the following provisions?

- The procedure requires that all export and re-export shipments be suspended when a DPL match is identified until/unless the match is resolved.
- Screeners have received education on DPL screening responsibilities and requirements and are able to explain what they are doing and why they are doing it.
- DPL screenings are documented with the date the screening was done and the identity of the person conducting the screening.
- The screenings are conducted in accordance with the provisions of USERP Section 4, Part 1.2.1 (DPL Screening Guidelines).
- The procedure describes the process for evaluating potential DPL matches, including communication of potential matches to relevant functions, the process for stopping or suspending affected export/re-export shipment operations, and escalation to the responsible operating unit ERE, ERC, or the ERO, as necessary.
- Controls or measurements are in place within the Global Logistics control tower organization that monitor Global Logistics supplier's use of the IBM Denied Parties List (DPL), ensuring consistency with IBM requirements and the supplier's responsibilities on behalf of IBM.

OVERVIEW

AUDIT PROGRAM #50-00-00

CONTROL ASSESSMENT QUESTIONS – GENERAL

Key Control Question: 11. Trade Compliance

Primary Test: Education and Awareness (TC004.P)

Objective:

Determine if IBM employees responsible for export internal control program related activities are aware of IBM's export regulation compliance with internal control requirements through ongoing training and education.

Approach:

Review the education requirements in Section 2, Part 2.5.1 of the United States Export Regulation Program (USERP) to verify the following:

- All IBM location organization employees that have been designated by the responsible operating unit's ERC as key compliance contacts have received export compliance education specific to their responsibilities within the past 12 months (The key organization contacts are listed in the Internal Control Program (ICP) document maintained by the responsible operating unit ERC).
- The key compliance contacts education participation within the audit period was documented.
- The education included the topics required in USERP Section 2, Part 2.5.

OVERVIEW

AUDIT PROGRAM #50-00-00

CONTROL ASSESSMENT QUESTIONS – GENERAL

Key Control Question: 11. Trade Compliance

Primary Test: Record Retention (TC005.P)

Objective:

To ensure records documenting compliance with the IBM export regulation compliance requirements produced by IBM business organizations are being retained in accordance with the requirements of USERP Section 2, Part 2.6.1.

Approach:

Select samples of records produced by IBM business organizations and verify compliance with IBM export regulation requirements to ensure documents are retained in an accessible manner.

OVERVIEW

AUDIT PROGRAM #50-00-00

CONTROL ASSESSMENT QUESTIONS – LABORATORIES

Key Control Question: 1. Trade Compliance - Exports Regulation

Objective:

This applies to all products, cryptographic, non-cryptographic, defense related, etc. This also includes software and technology introduced into a development organization, Online Collaboration Environments (OCE).

OCEs includes team rooms, connections communities, Slack, databases, etc. plus external and internal cloud environment for international development project collaboration and discussion.

OVERVIEW

AUDIT PROGRAM #50-00-00

CONTROL ASSESSMENT QUESTIONS – LABORATORIES

Key Control Question: 1. Trade Compliance - Exports Regulation

Primary Test: Trade Compliance - Exports Regulations (TC001.P)

Objective:

To confirm that IBM products, technology, and services to be exported, re-exported, or delivered were properly classified prior to export and the appropriate licenses were obtained. Classification must be communicated by the controlling development and research organization to all other development and research organizations collaborating with development projects. This test includes verification of US export and legal requirements whenever technologies are communicated, exposed, released or transferred to or in the presence of foreign persons working in countries in which they are not citizens or legal residents.

There are two main tests to be performed for Export Regulations for Laboratories, the classification and regulation for the products or projects being worked for non-US Labs and also the classification of the OCEs, the tools used for the developing across countries.

Approach:

- Select a sample of products/projects to validate the ERO classification and appropriate evaluation was done prior to the start of the work in the non-US country.
- Select a sample of the OCEs to validate their appropriate and timely export classification. Also, validate if there was a proper control over the OCEs inventory and accesses controls.
- Validate if mandatory training was completed by the required employees.

Additionally, review that the IBM operating unit has implemented procedures to ensure site visits by foreign nationals are appropriately assessed, prior to the visit occurring, for any deemed export/re-export considerations that may apply. These evaluations should be based on the IBM host's knowledge of their visitors and the classification of the technology and/or source code which will be accessed during their visit.

OVERVIEW

AUDIT PROGRAM #50-00-00

CONTROL ASSESSMENT QUESTIONS – LABORATORIES

Key Control Question: 2. Procurement

Objective:

Were Procurement process correctly applied for all the purchases? Are there adequate controls over the process for approving the commitment of IBM funds to external suppliers who are selected based on the criteria set forth in the Procurement Requirements and Practices booklet?

Risk/Exposure:

Failure to properly control the approval of commitments can create excess expenditures, legal problems, vendor relations exposures, and can lead to fraud.

OVERVIEW

AUDIT PROGRAM #50-00-00

CONTROL ASSESSMENT QUESTIONS – LABORATORIES

Key Control Question: 2. Procurement

Primary Test: Procurement (PR001.P)

Approach:

Since procurement owns most of the process, these tests are to ensure the requests and approvals required from the line team are being adequately reviewed. In addition, reviews of bypass reports should look to see if the auditable unit is listed to both see the root cause and action plans, along with determining if their process does not ensure use of the procurement guidelines. Select a sample of top vendors and purchase orders to confirm effective compliance with the established guidelines.

Overall Procurement focus

- Are all requisitions using the approved procurement processes? Review universe files of POs, ECRs, PO Exempts, and IOIs from audit period. Repeating requests for payment to the same supplier and/or from the same requestor could be a sample selection criterion. Verify that non-POs items did not require procurement involvement.
- Obtain a list of procurement bypasses reported during the audit period. Was the auditable unit on the procurement bypass report during the audit period?

If yes to bypass, are their action plans documented and implemented to avoid repeat bypasses? If any are repeat offenders, did the action reflect that?

OVERVIEW

AUDIT PROGRAM #50-00-00

CONTROL ASSESSMENT QUESTIONS – LABORATORIES

Key Control Question: 3. Product Development and Research Projects (when applicable)

Objective:

To determine whether controls were put in place to ensure there was an appropriate project management system, especially local project part and interaction of the local project with the overall Offering Management process, meeting project deliverables, and tracking and reporting local project control status.

OVERVIEW

AUDIT PROGRAM #50-00-00

CONTROL ASSESSMENT QUESTIONS – LABORATORIES

Key Control Question: 3. Product Development and Research Projects (when applicable)

Primary Test: Product Development & Research Projects (PD001.P)

Approach:

Select a sample of local projects that are part of the overall IPD process to determine from documentation, observation, and meetings with project staff.

Methodology/process used by product to execute design, code, build and test and against it, select a sample of projects where:

- The product releases that were done within the audit period
- In which product releases Lab was in charge of the product development
- In which product releases Lab was in charge of the product testing

For the selected product development projects, review:

- The evidence of the requested product release features by the Product Owner/Offering Manager
- Evidence of the development monitoring (design and coding) for the above product features
- Any change in the original features

For the selected Testing and Build, review based on the methodology/process used, that all planned tests were executed prior to the release.

If the Lab also had Level 3 support, from a list of all the problem analysis (PMR/tickets), select a sample to validate the timeliness of the action plan/steps taken to solve the issues and effective communication with Level 2 and/or Customer.

OVERVIEW

AUDIT PROGRAM #50-00-00

CONTROL ASSESSMENT QUESTIONS – LABORATORIES

Key Control Question: 4. Government Operations

Objective:

The governmental programs process within IBM encompasses advocating for government policies that support business growth, providing market support to assist internal clients to governments, and ensuring compliance with governmental trade regulations.

Risk/Exposure:

Failures when monitoring the lab's operations with Government involvement could result in legal/regulatory exposure, and fines or penalties (if applicable).

OVERVIEW

AUDIT PROGRAM #50-00-00

CONTROL ASSESSMENT QUESTIONS – LABORATORIES

Key Control Question: 4. Government Operations

Primary Test: Government Operations (GO001.P)

Approach:

There are Labs that are involved in Government grants and/or tax benefits for the nature of work in the organization/country. Sometimes it can be a benefit to the Lab itself or also for the IBM country. Either way, the involvement of Lab needs to be reviewed in this audit. There are specific audits for the tax/benefit calculation and execution, that should not be overlapped. However, the Lab internal process and the input from the Lab to the Tax organization should be reviewed.

Additionally, confirm if any gifts or amenities were provided to employees, officials of Government Owned Entities (GOEs) or to commercial parties in certain countries as listed in FIN 168 (CPICC). And, if so, if appropriate approvals were obtained (i.e., Compliance with Transportation, Entertainment, and Business Amenities (CTEBA) pre-approval).

OVERVIEW

AUDIT PROGRAM #50-00-00

CONTROL ASSESSMENT QUESTIONS – LABORATORIES

Key Control Question: 5. Financial Management

Objective:

To ensure that accurate financial performance is reported to management on a regular basis. To ensure that measurements are in place to give management visibility of the results of the operations during the period. Finally, ensure that costs are appropriately allocated and fully recovered.

Risk/Exposure:

Inadequate management review may result in financial issues going undetected, root cause analysis not being performed for missed, and timeliness of corrective actions not being taken, leading to potential financial misstatements for IBM.

OVERVIEW

AUDIT PROGRAM #50-00-00

CONTROL ASSESSMENT QUESTIONS – LABORATORIES

Key Control Question: 5. Financial Management

Primary Test: Intercompany Recovery Rates (FI001.P)

Objective:

To ensure that management controls are in place to guarantee the most accurate recovery rates.

Risk/Exposure:

Inadequate management review may result rates that do not cover costs and result in missed plans.

Approach:

For the cost recovery rates, verify:

- Operational parameters, cost trend, next year demand and estimated spends has been obtained timely and analyzed accurately.
- Rate inputs are reviewed by the local financial and worldwide management.
- Rate is approved by the required levels. (local and from the requesting organization)
- Billing is based on the published cost recovery rates for the samples selected to test for billing.
- All billings are post-approval of the rates.
- Rate changes during the year should be properly approved.
- Rate exceptions given to any specific/unique account(s) should be appropriately approved.
- Exchange rate agreements should be outlined in the documentation along with impacts.

OVERVIEW

AUDIT PROGRAM #50-00-00

CONTROL ASSESSMENT QUESTIONS – LABORATORIES

Key Control Question: 5. Financial Management

Primary Test: Internal Billing (FI002.P)

Objective:

To ensure internal billings are processed accurately and in a timely manner and that all costs are properly recovered in accordance with established interlocks and DOUs.

Risk/Exposure:

The absence of completeness controls increases the risk of omitted billings which could impact IBM's cash flow and the accuracy of the financial statements.

Approach:

Tailor the approach based on the environment:

To ensure complete understanding of all aspects of the billing process, consider flow-charting the complete billing process and documenting needed and existing control points. Test each of the different types of cost recovery methodologies: Direct Cost, Shared Infrastructure, Related Services, etc.

From a listing of ICA and DOUs or from Ledger extracts, select a sample and determine if all elements of the ICA or DOU have been billed per the terms. If ICA or DOU data cannot be obtained and Ledger extracts are used, request the associated ICA or DOU and all internal billings that have been generated. Focus on quarter-end, year-end activity, high-dollar transactions, and special contracts.

Review billing reconciliation controls and reports for managing ICAs and DOUs accomplishment (for example, how do the Finance Lab team monitor the remaining balances to be billed from an ICA compared to the actual billings so far?).

Determine if management had visibility to over limits billing, if root-cause analysis was performed, and if corrective actions were taken to ensure completeness of all billing transactions.

Verify if billing was accurate, timely and authorized. Ensure that billings were adequately supported with relevant details such as headcount, rate, and project information.

OVERVIEW

AUDIT PROGRAM #50-00-00

CONTROL ASSESSMENT QUESTIONS – LABORATORIES

Key Control Question: 5. Financial Management

Primary Test: Ledger Review (FI003.P)

Objective:

To verify that there is a management process to ensure that only properly authorized manual entries and accruals are posted to the Labs general ledger accounts.

Risk/Exposure:

- Ineffective journal entry control may enable employees to conceal irregular entries or clear reconciling items from account analysis by writing them off or otherwise disguising the real nature of the activity.
- Reconciliations, performed correctly and on time, are the primary control to identify any differences between the general ledger and the systems which feed it. In addition, the analysis of the accounts identifies if inappropriate or unauthorized transactions were recorded into the general ledger. Unresolved differences could lead to a misstatement of the company's financial position or diminish the capability to establish controls to prevent fraud situations.

Approach:

The review should be of any journal, accrual, or reconciliation that the audit client has direct requests or impacts on.

Journals

Select a sample of requested journal entries to determine:

- Was the request clear with appropriate documentation and line approvals prior to submission to finance / accounting for a journal entry to be done into Labs accounts?
- Does the journal amount agree with backup documentation and to the accounts that would be expected?

Accruals

Select a sample of accrual/provision entries to determine:

- Was the request clear with appropriate documentation and line approvals prior to submission to finance / accounting for a journal entry to be done?
- Determine if the calculation methodologies were reasonable and were consistent with IBM's accounting guidelines.
- Determine if accruals were reversed on time in the following accounting period and actual costs, or expenses were recorded as incurred.

OVERVIEW

AUDIT PROGRAM #50-00-00

CONTROL ASSESSMENT QUESTIONS – LABORATORIES

Key Control Question: 5. Financial Management

Primary Test: Over/Under Recovery Process (FI004.P)

Objective:

To ensure that over/under recovery adjustments arising out of billings at recovery rates are performed accurately, timely and properly approved.

Approach:

Test needs to be done according to the over/under process for the organization. However, the over/under residual treatment needs to be aligned with IBM finance guidelines or approved instructions.

Also, in general, select the permanent adjustment entries processed before year end or quarter end and check for the following:

- Review performed by the Local and WW Labs CFO for the over/under recovery to be adjusted and allocated to geo.
- Geo/WW involvement and acknowledgement.
- Billing adjusted by finance analyst against ICA.
- Reconcile the actual over/under allocation with the ledger entries. Analyze the variances.
- Impact of currency exchange rate changes from plan.

OVERVIEW

AUDIT PROGRAM #50-00-00

CONTROL ASSESSMENT QUESTIONS – LABORATORIES

Key Control Question: 5. Financial Management

Primary Test: Department Expenses (FI005.P)

Objective:

To verify that departments expenses are for a valid IBM business purpose, align with corporate instructions, unauthorized direct charging of expenses has not occurred, and there are no personal expenses that have been included in compensation.

Approach:

Select a sample of departmental expenses from those recorded on the ledger. A higher dollar amount parameter may be used based on risk.

Request the supporting documentation for these charges and test for the following attributes:

- Was the expense properly approved?
- Was the expense for a valid business purpose?
- Was the expense fully documented (i.e., a valid supplier invoice)?
- Was the expense reasonable?
- Was the expense charged to the proper account code? Or corrected allocated through the projects if common cost?
- Were depreciation charges proper registered and allocated through the projects?

OVERVIEW

AUDIT PROGRAM #50-00-00

CONTROL ASSESSMENT QUESTIONS – LABORATORIES

Key Control Question: 6. Asset Management

Objective:

Asset Management (AM) is the process for capturing, integrating, and maintaining technical and financial information about hardware and software assets from acquisition through to disposal.

Risk/Exposure:

Ineffective and insufficient monitoring on Lab's assets can lead to assets or information loss, or performance issues due to non-availability when needed. This could also result in incorrect asset and depreciation recording.

Does a process exist to cover all asset management activities i.e., approval, order, tracking, updates, changes, and disposal?

OVERVIEW

AUDIT PROGRAM #50-00-00

CONTROL ASSESSMENT QUESTIONS – LABORATORIES

Key Control Question: 6. Asset Management

Primary Test: Asset Management (AS001.P)

Approach:

First of all, it is important to keep in mind that two different processes will exist for this test. One and simpler for the CIO/IT owned assets and the capital assets (assets purchased and owned by the Lab). For the CIO given assets, there is not much to test unless their controls to make sure assets are secured (as they carry confidential information) and information/ownership is kept updated.

For capital assets

- Is there a documented process to cover all asset management activities? Capital approval for purchases: Are all capital expenditures appropriately planned and approved?
- For the Receipt of assets - Was the receipt of the asset handled efficiently? Consider:
 - Were assets signed for, verified in line with order, checked for damage?
 - What was the escalation process if discrepancies?
 - How were incorrect receipts resolved?
- Asset Tracking - How were assets tracked once received into IBM?
 - Were asset records updated in the relevant asset repositories with all relevant fields i.e., type, model, serial number, street name, location, owner, user. For the e-amt input, it is WW team responsibility, however, it is the asset owner responsibility to verify that.
- Asset Updates - When physical changes were made to assets e.g., change in physical location, was there an effective process in place to record the changes? When changes were made to the asset databases:
 - Had the changes been approved correctly?
 - How are unauthorized changes detected?
- Were reconciliations performed on a regular basis, were discrepancies highlighted, and had relevant actions taken place?
- Was physical tracking performed on a regular basis, were discrepancies highlighted and had relevant actions taken place?

Additionally, a physical reconciliation can be performed: book-to-floor (B2F) and floor-to book (F2B) validations.

It is important to make a mix of personal computers and the Lab servers. Important remind: Lab servers must be stored in a secure and controlled room.

Book-to-floor: From the assets universe list (typically from e-amt), select sample to physically review and make sure the asset is found, the correct owner is assigned, and correct location is indicated in the system.

Floor-to-book: During the walk review to find the assets of the B2F, select assets physically, take note of the machine type and serial number and then validate if they are in the systems with the correct information in.

OVERVIEW

AUDIT PROGRAM #50-00-00

CONTROL ASSESSMENT QUESTIONS – LABORATORIES

Key Control Question: 7. Access Management, Data Privacy, and Data Security

Objective:

To verify that a process is in place to safeguard data that is reviewed or stored as part of developing/researching. To ensure that access to the required systems is controlled in a timely manner, and to prevent unauthorized access to applications and information. Appropriate management approvals should be granted and documented according to business need. Ensure adherence to Information Technology Security Standards and Chapter 3: End user Acceptable Use Requirements, 3.1 General User Responsibilities.

Risk/Exposure:

Unauthorized persons may gain access to the application and its resources enabling them to get access to privileged and confidential IBM information which may result in IBM competitive data exposure.

OVERVIEW

AUDIT PROGRAM #50-00-00

CONTROL ASSESSMENT QUESTIONS – LABORATORIES

Key Control Question: 7. Access Management, Data Privacy, and Data Security

Primary Test: Access Management, Data Privacy, and Data Security (AD001.P)

Approach:

Review list of applications and databases used in the developing, testing, support, researching activities and test for them the data privacy/security as well as the accesses controls.

Additional question: Were all necessary ASCA certifications in place for IBM applications, databases, and spreadsheets used as a trusted source of information? (It may not be always applicable)

Access Control

- Review the access controls lists to applications and systems to validate that users have an appropriate business rationale.
- Review access lists to establish business needs and verify that periodic continued business needs were performed and complete.
- Verify that management controls and authorization of all access to the application and data can be demonstrated with management awareness and removal of such access is processed when there is no longer a business justification.
- For systems used for confidential developing and researching, were controls in place to guarantee physical and logical security?
- Most likely, the Labs systems network will be protected by a firewall, that's how they can guarantee the systems are isolated, which minimize risks to the development/research systems. For that, it is necessary to validate the access list to this firewall and make sure only Lab employees with business should have access to this firewall.

Data Privacy and Security

- Validate that there are controls to certify that IBM is sufficiently protecting confidential information.
- Review documentation to ensure proper classification of information. For this, review possible open access repositories.
- Review the approved IT security guidelines in place for the organization (indicate if ITSS is in place). The reason to request it is that ITSS is open and summarized to let the organizations implement their own specifics controls. Also, there are organizations that have SSCE/CISO approval to keep using ITCS104 until completely adapt to ITSS or create your own process.
- Request the IP range(s) reserved for and/or available to the Lab. From this, the BIT team can run different tests to check their compliance with the IPs documentation/registration, validate if they are behind firewall (this is important for Labs that handle isolated systems), validate access (if it is default IDs, if it is open, possibly old (vulnerable) software in use, etc.).

Test: Privacy

Objective:

Privacy laws impose requirements on how IBM and its Clients process Personal Information (PI). The Global Privacy Control Assessment Questions are composed with two key areas of the business to help address compliance with these various high-level laws.

OVERVIEW

AUDIT PROGRAM #50-00-00

CONTROL ASSESSMENT QUESTIONS – LABORATORIES

Key Control Question: 7. Access Management, Data Privacy, and Data Security

Primary Test: Access Management, Data Privacy, and Data Security (AD001.P)

(Continued)

- **IBM as a Controller** – The Enterprise Privacy Baseline – Controller establishes the high-level requirements that IBM must meet when acting as a Controller of Personal Information (PI). That is, PI that IBM collects and processes for its own purposes, such as Business Contact Information that IBM holds on its existing or potential customers or suppliers.
- **IBM as a Processor** – The Enterprise Privacy Baseline – Processor establishes the principles and requirements that IBM must meet when acting as a Processor of Client Personal Information (PI) and applies to all products, offerings, and services (including their components) that IBM provides to Clients, regardless of whether IBM develops or re-brands them, or provides them for a fee or on a beta, trial, or no-charge basis.

Approach:

Review the Data Privacy responses provided from the Initial Data Request. Determine if IBM is Controller or Processor of PI/SPI data in the process.

Testing:

IBM as Controller

If IBM is Controller, request a risk-based sample of Global Privacy Assessments for the processes and/or assets. Complete the testing from the following link: <https://ibm.ent.box.com/file/1198251968388>

IBM as Processor

If IBM is Processor, select a sample of products/offerings/services provided for the in-scope activities. Complete the testing from the following link: <https://ibm.ent.box.com/file/1198263127550>

IBM as both Controller and Processor

Test either IBM as Controller or Processor, do not test both. Consider the volume and sensitivity of the controller and processor data and select the higher risk.

OVERVIEW

AUDIT PROGRAM #50-00-00

CONTROL ASSESSMENT QUESTIONS – SMALL COUNTRIES

Key Control Question: 1. Ecosystem Management

Objective:

To determine if an effective process for establishing Ecosystem relationships had been defined, documented, and followed. To determine also if the business results of Ecosystem relationships were monitored so that informed payment/renewal/continuation/termination decisions could be made.

To determine if the process for managing Ecosystem contracts had been defined, documented, and followed, with emphasis on the following questions: Were properly approved contracts in place to support all business partner (BP) relationships? For BPs, were deviations to standard terms and conditions, if any, authorized through a disciplined Change Management or Special Bid process to ensure both the protection of IBM assets and the equitable treatment of BPs? For BPs with nonstandard agreements, were changes to the contract, supplement, or business partner development plan approved by the Partner Initiative Council (PIC) or equivalent? For BPs were the most current worldwide modular Ecosystem Agreement documents used (appropriately modified by the country within the boundaries of its delegated authority)? Were there unapproved commitments made to BPs that altered contracts without proper approvals ("side deals")?

To determine if process controls had been defined, documented, and followed for ensuring that disbursements to Ecosystems were valid, accurate, authorized and paid in a timely manner. To also determine if the terms and conditions of any marketing incentive plans or programs had been documented and approved by authorized management. (Depending upon the ATL's intended scope, the Corporate Audit Program for Commissions may be used to review sales incentive payments to IBM sales personnel.)

To determine if the process had been defined, documented, and followed for ensuring that assets shipped to Ecosystems were accurately tracked and recorded, including those which eventually become authorized returns which result in billing credits to the Partner.

Risk/Exposure:

A defined and documented review of potential Ecosystems is essential to determine if the relationship is a good strategic business decision. Failure to execute a consistent BP selection and renewal process could result in the unintended ("automatic") renewal of a BP relationship that is not in IBM's best interest to continue, resulting in Partner relationships that do not achieve business objectives, expose IBM to claims of inequitable treatment of candidates and other Ecosystems, as well as issues and violation of regulations and legislation such as anti-competitive legislation like the Robinson Patman Act (US), jeopardizing IBM assets, or damage to IBM's image.

Missing, outdated, or improperly approved contractual documents increase the risk of inconsistent treatment of BPs and expose IBM to allegations of unfair business practices; increase the legal risk of BPs with nonstandard agreements, and also makes it difficult to enforce critical terms and conditions of the relationships and could therefore lead to inefficient use or loss of assets (including losses associated with copyright, licensing, or intellectual property clauses). Customer satisfaction exposures, impacting overall BP marketing strategies, may also result from a failure to secure, protect, and enforce key provisions in the contractual documentation. In addition, inappropriate long-term trial, loan or demonstration contracts could infringe upon local geographic accounting or taxation rules.

Risks involved with BPs with nonstandard agreements may contain violations of regulations or legislative requirements such as the anti-competitive laws in the Robinson-Patman Act (in the US) and accounting regulations involving revenue reversal vs expense spending.

OVERVIEW

AUDIT PROGRAM #50-00-00

CONTROL ASSESSMENT QUESTIONS – SMALL COUNTRIES

Key Control Question: 1. Ecosystem Management

(Continued)

Failure to monitor and reconcile products shipped to Partners may result in the undetected loss of assets and/or delays in installation and billing, resulting in negative impacts to expense, revenue, and customer satisfaction.

Inaccurate or delayed processing of end user installation dates may result in improper warranty information. This could result in increased maintenance expense, decreased maintenance revenue, and customer dissatisfaction.

Inadequate monitoring of returns may result in lost assets, as well as the processing of billing credits to which the Ecosystem may not have been contractually entitled.

Failure to effectively control disbursements might allow unauthorized or undetected payments which could result in financial loss to IBM. Failure to establish and enforce the terms and conditions of marketing incentive programs could result in claims of inequitable treatment of Ecosystems, which might result in additional cost to IBM, legal issues, negatively impact Ecosystem satisfaction and could impact revenue recognition.

OVERVIEW

AUDIT PROGRAM #50-00-00

CONTROL ASSESSMENT QUESTIONS – SMALL COUNTRIES

Key Control Question: 1. Ecosystem Management

Primary Test: Ecosystem Selection, Review, and Terminations (BP001.P)

Objective:

Ongoing Review of BP Relationship

To determine if the process had been defined, documented, and followed for ensuring an appropriate level of monitoring and management of Ecosystem performance following the approval of the candidate application and signing of the relevant contractual documents. Specifically, was there a plan for reviewing the business results of Partner relationships? Based on such reviews, were relationships ever renegotiated, terminated, or otherwise not renewed?

Global Ecosystem revalidation processes were amended in 2011, effective in 2012. These give clear guidelines on the revised approach to partner revalidation, and process steps and key documentation that should be retained during the process. You should ensure that this process is implemented in the geography that you are auditing. Ecosystem advisory instruction 2011-04 applies.

Ensure that at a minimum, annual reviews of each BP's performance are conducted to determine if the BP should be renewed or terminated and that appropriate management review and approval is obtained, including exceptions. Depending upon the type of BP the following should be considered when renewing the relationships: performance against revenue objectives, A/R collection trends, Lead closure, Customer Satisfaction, Special Bid usage, and Contract Compliance.

Terminations

To determine if the process was being followed and that risks were being managed at an acceptable level. This is accomplished by determining if the process had been defined, documented, and followed to ensure that decisions to terminate or otherwise not renew Ecosystem relationships were made by authorized personnel following review of appropriate information. Also determine if further actions were necessary and taken to protect IBM and end-user interests.

Terminations - To ensure a) the termination of a BP is handled properly including the involvement of all affected functions within IBM (including Legal) b) in the termination decision, there is an independent review of the results of the BP's performance reviews (if applicable), c) there's timely notification to the BP of the termination, d) recovery of any IBM assets held by the BP including the resolution of any outstanding AR prior to termination, e) deactivation of the BP from any systems, databases, or access to IBM facilities, resulting in a proper and timely closeout of the BP relationship.

Approach:

Ongoing Review of BP Relationship

Request the criteria for acceptable performance for each Ecosystem type relationship. Understand such factors as minimum annual attainment, performance targets, sales attainment, contract compliance, accounts receivable status, customer satisfaction, and complaint resolution.

- Determine if the process documentation for the review and renewal process incorporates these or comparable factors.
- Review measurement package and the compliance testing performed, including sample selection methodology, number of transactions tested, testing results, and findings and related actions plans. Consider the results of the compliance testing during sample selection for the audit. Evaluate whether management's testing covers adequate risk in the process and local business environment.

OVERVIEW

AUDIT PROGRAM #50-00-00

CONTROL ASSESSMENT QUESTIONS – SMALL COUNTRIES

Key Control Question: 1. Ecosystem Management

Primary Test: Ecosystem Selection, Review & Terminations (BP001.P)

(Continued)

- Determine if the process documentation addresses the frequency of Partner performance reviews as it relates to decisions to renew or terminate the different types of Partners. For Partners with Minimum Annual Attainment targets (or similar quantifiable objectives), an annual review should occur. This is extremely important if discount percentages for the BP are based on revenue expectations.
- Confirm that the organization is complying with related business partner advisory instructions in relation to renewal such as Global Ecosystem Management Instruction 2011-04.
- For nonstandard type agreements, request the unique measurement requirements as stated in the contract. Understand the requirements and the required validation of the measurements.
- Failure to monitor BP performance and/or BP contract expiration dates could result in the unintended ("automatic") renewal of a BP relationship that is not in IBM's best interest to continue, resulting in Partner relationships that do not achieve business objectives, or damage IBM's image.
 - Review a risk-based sample of the Ecosystem Agreements without Minimum Annual Attainment objectives that had expiration dates in the previous quarter.
 - Review a risk-based sample of the Ecosystem Agreements with Minimum Annual Attainment objectives that had contract anniversary dates in the previous quarter.
- Test the selected samples against the monitoring principles in the process documentation. Determine what percentage, if any, were out of compliance with the following:
 - Were annual reviews of active Partners with Minimum Annual Attainment objectives performed? Did decisions to renew / terminate relationships give appropriate weight to these performance reviews? Were they supported by documented approvals from personnel properly authorized to give such approvals?
- For all BP renewals/termination, were the BP objectives met, such as revenue or skills? Was meeting these objectives a determination of BP renewal/termination?
- Was the person who approved accurately shown on the SOD assessment and were there no conflicts?
- Were quarterly reviews of other types of expiring contracts performed? (This would apply to relationships not covered by the standard BPA agreement. Generally, all agreements with BPs must either be standard or follow the custom initiative process. BPA agreements have an evergreen clause and do not expire unless overt action is taken.) Did decisions to renew or terminate relationships give appropriate weight to these reviews? Were they supported by documented approvals from personnel properly authorized to give such approvals?
- If BP did not meet established renewal criteria and a decision to retain the BP was made, was this exception approved?
- Are violations tracked and used to evaluate BP performance during renewal time?

OVERVIEW

AUDIT PROGRAM #50-00-00

CONTROL ASSESSMENT QUESTIONS – SMALL COUNTRIES

Key Control Question: 1. Ecosystem Management

Primary Test: Ecosystem Selection, Review & Terminations (BP001.P)

(Continued)

Terminations

Request the criteria for deciding to terminate Ecosystem Agreements and the procedures to be followed in order to administer the terminations fully.

- Review measurement package and the compliance testing performed, including sample selection methodology, number of transactions tested, testing results, and findings and related actions plans. Consider the results of the compliance testing during sample selection for the audit. Evaluate whether management's testing is adequate to cover risk in the process and local business environment.
- Review a risk-based sample of the Ecosystem Agreements which were allowed to expire or were otherwise terminated during the previous quarter. Determine what percentage, if any, were out of compliance with the following standards:
 - Was the Partner officially notified that the relationship was being terminated (if the termination was not initiated by the BP)?
- If fee payments or marketing incentives were applicable, were accounts receivable status verified prior to issuing payments or marketing incentives?
- Were checks made and actions taken for end-user customer business pending with the terminated Partner? (For example: new orders to be entered, existing backlog to be managed, recent shipments to install, outstanding opportunities, etc.)
- Was there evidence that A/R was notified of the termination notice and that collection activity was coordinated in the termination process?
- Were documented "wind-down" procedures followed to resolve all pending business transactions with the terminated Partner (including order cancellations and/or shipments; billing and/or accounts receivable)?
- Were open inventory issues (loaned equipment, demo equipment, outstanding RPMES parts returns) reviewed and reconciled)?
- Were facility access privileges (including badges) reviewed and, if granted, revoked?
- Were system/application access privileges reviewed and, if granted, revoked?
- Were database administrators notified to remove the BP (e.g., from PartnerRewards, PartnerInfo, the BP Database, etc.)?
- Was the person who approved, accurately shown on the SOD assessment and were there no conflicts?

OVERVIEW

AUDIT PROGRAM #50-00-00

CONTROL ASSESSMENT QUESTIONS – SMALL COUNTRIES

Key Control Question: 1. Ecosystem Management

Primary Test: Special Bids (BP002.P)

Objective:

To determine if process controls for the review and approval of Special Bid requests had been defined, documented, and followed, with emphasis on the compliance of pricing decisions to authorized functional delegations and the equitable treatment of partners involved in a bid. Also, to determine whether the ecosystem accurately represented both the route to market and end user price requirements in the special bid and then complied with the terms of the special bid by ensuring that products were delivered to the identified end-user at correct time and at the correct price.

Approach:

Determine if the process was being followed and that risks were being managed at an acceptable level. Request the documented Special Bid process as defined by the relevant country's pricing organization, including the delegation documentation which defines authorizations and approval clip levels. The approach should consider if the special bid has adequate supporting documentation, proper approvals, and that orders under the Special Bid Offering (SBO) were fulfilled as approved. For the validation of compliance by Ecosystems with special bid terms, this test should be carried out in conjunction with CA004.P

Review measurement package and the compliance testing performed, including sample selection methodology, number of transactions tested, testing results, and findings and related actions plans. Consider the results of the compliance testing during sample selection for the audit. Evaluate whether management's testing covers adequate risk in the process and local business environment.

Select samples of special bids under which shipments were made. Sample selection should focus on those transactions which exhibit red-flag indicators for risk of potential manipulation of the special bid process. Red-flag indicators include but are not limited to SBO transactions with shipped but uninstalled machines; quarter-end SBO creation, completion, and shipment; and special bids with previously investigated BPs. (Please see the IA Audit Preparation repository for a listing of red-flag indicators, information necessary for red-flag data mining, and sources of that information.)

Review the following attributes:

- Was the customer requirement (competitive need) for special terms or pricing justified and validated? The SBO should be submitted by the BP and include the end user and anticipated end user price for certain products (see advisory for product exclusions 05-007.) http://w3-03.ibm.com/sales/partners/bpcontrols/advisory_index.html

(The reason for requesting the end user price is to ensure that pricing has valid information to make a pricing decision. End user price is also required to help external compliance validate through BP post audits that the price was required to make the sale. Also, in some countries, SWG may deal directly with the end user during the SBO in establishing a price, then allow the end user to buy from a BP as part of a packaged solution. In this case we give the normal discount off the SBO price to the BP. In the SWG scenario, the risk of excess discount is minimized by dealing directly with the end user. Therefore, the end user price does not need to verify where we establish the SBO prices with the end user.)

- Were all approved prices within the limits authorized by documented delegations and if not, were additional approvals documented?

OVERVIEW

AUDIT PROGRAM #50-00-00

CONTROL ASSESSMENT QUESTIONS – SMALL COUNTRIES

Key Control Question: 1. Ecosystem Management

Primary Test: Special Bids (BP002.P)

(Continued)

- Were validity periods (expiration dates) for approved bids honored? Were bids, if any, executed beyond these periods supported by additional authorized approvals?
- Was the end user and price on the special bid the same end user who received the price? This can be verified by reviewing the order data.
- Did the bid price approved equal the price communicated and billed to the Partner? (Be alert of situations where BP is given a special bid but then is given an even deeper discount (repair) for same or different end user than initial bid. Ensure the bids being reviewed are the final bids.)
- Is each BP's participation in the SBO route-to-market justified? Is each BP providing additional value to the route-to-market? (Extraneous BPs could be used to pad BP margins.)
- When two or more BPs are bidding for the same business ensure that all BPs were given same discount by IBM if they can demonstrate the same level of contribution to the sale. It is up to BP to determine the price they bid. Please note multiple tiers may be involved, and this should be noted on the special bid request.
- Was a process in place to ensure that the special bid quantity approved was equal to the quantity ordered? A BP may consistently request a high volume to get a deep discount and then order lesser product. Also, a BP may get a deep discount approved and attempt to order more quantity than approved. A process should be evident to detect the first situation through data mining, and a process should be in place to prevent (or quickly detect) the BP from ordering additional product. (It should be noted that pricing does not use quantity in establishing discount rate for certain products. Check with pricing to determine how quantities impact discount rates.) Please review how discounts are applied to bottom line bids when the products are not shipped or invoiced together.
- If other than price was modified on the special bid, i.e., terms and conditions of the BP contract altered, were these changes properly approved? (This should be in line with local country legal approved signatory delegations).
- Was the globally approved standard SBO document used?
- Was there evidence of prohibited side deals (unauthorized alterations to the terms and conditions of accepted contracts)? (Evidence is sometimes found in inappropriate AR write-offs, requested disbursements outside of contractual terms, additional discounts, extended payment or warranty terms or extended returns provisions. If these actions occur, discuss with management if investigation or Legal action is necessary.)
- If contract terms and conditions were modified for a single Ecosystem for a specific customer transaction, were such changes approved via the local Special Bid or Transaction Agreement process? Are there special approvals for this? Specifically, by WW BP, C&N, Legal? There are common documents and the approval requirements which are noted on the website referenced in the bullet above.

OVERVIEW

AUDIT PROGRAM #50-00-00

CONTROL ASSESSMENT QUESTIONS – SMALL COUNTRIES

Key Control Question: 1. Ecosystem Management

Primary Test: Special Bids (BP002.P)

(Continued)

- Please note that a process may be in place by the organization to accommodate end user changes. For example, Software Group (SWG) allows end users to transfer licenses to other end users, including special bid transactions. In addition, Systems and Technology Group (STG) allows end user renaming. If the organization utilizes such transfers, ensure a process is in place and adhered to for how these transfers take place and how it is validated that the old end user no longer has accesses to the software or hardware.

END USER VERIFICATION

Where the risk indicates it is appropriate select a risk-based sample of special bids and obtain information through the Business Partner Compliance team to validate that special bid terms and conditions were observed.

The following areas should be reviewed:

- PO issuance date (PO from ecosystem)
- Date product shipped to the BP (delivery documentation validation)
- Date the product was shipped to end-user
- BP reported end-user on sales activity report should match the special bid end-user
- The price to the end user was in line with the approved maximum end user price in the bid release (This will necessitate reviewing the end user contract between the partner and customer)
- Ensure that any documentation provided by the partner in the firm transaction management process is supported (e.g., a firm end user order was in place at the time stated by the partner)
- Validate that the route to market was as approved in the special bid (were different or more partners involved in the bid)
- Outcome of BPAC reviews

In selecting high-risk audits, the following additional tests may be considered:

- Obtain a list of SBOs for which the end user transaction was financed by IBM Global Financing (IGF). Confirm receipt of first installment to the end user. Determine whether the financed amount matches the EU price requirement reported by the BP. If the financed amount is greater than the required EU price, then investigate whether the BP charged a higher price to the EU, therefore misrepresenting EU requirements on the special bid application and causing IBM to grant a deeper discount than necessary.
- To determine if BPs were treated equitably in open tender bidding situations requiring letters of authorization (LoAs). Selective granting of LoAs or inequitable offering of prices could expose IBM to BP dissatisfaction or complaints of discrimination. In some countries, end users require letters of authorization (LoAs) for participation in open tenders. LoAs are letters from IBM to the end user which grant authority to a certain BP to sell IBM products. For each open tender SBO selected for testing, request all LoAs issued. Test whether LoAs were issued to all BPs listed in the special bid factsheet as open tender participants and vice versa. Investigate any discrepancies. Request evidence of special bid prices offered to each open tender participant and verify that all BPs were offered the same price.

OVERVIEW

AUDIT PROGRAM #50-00-00

CONTROL ASSESSMENT QUESTIONS – SMALL COUNTRIES

Key Control Question: 1. Ecosystem Management

Primary Test: Transaction Agreements (BP003.P)

Objective:

To determine if Transaction Agreements (TAs) were used inappropriately to circumvent the normal Ecosystem Selection and/or contracting process and to determine if appropriate records were in place to effectively monitor and control TA usage.

Global business partner vetting requirements for relationships in a transaction agreement with a company that is not an approved ecosystem were amended in 2011, effective in 2012. These give clear guidelines on the approach to vetting these partners. You should ensure that this process is implemented in the geography that you are auditing. Ecosystem advisory instruction 2011-05 applies.

Approach:

Since Transaction Agreements are stand-alone documents designed for engaging a specific firm for a specific transaction, determine if their use has been restricted to firms or individuals not wishing to become full-fledged Ecosystems or Ecosystems outside normal agreements. Request process documentation for preventing unauthorized granting of multiple TAs to the same firm or individual.

If either brands or sectors are allowed to enter into transaction agreement relationships without sufficient monitoring, they can continue to reuse this relationship and set up a BP type of relationship outside of channels. This can negatively impact IBM's equitable treatment of BPs and could lead to allegations of unfair treatment (compliance with laws, safeguard assets).

Review measurement package and the compliance testing performed, including sample selection methodology, number of transactions tested, testing results, and findings and related actions plans. Consider the results of the compliance testing during sample selection for the audit. Evaluate whether management's testing covers adequate risk in the process and local business environment.

Request a report, log, or other file comprising a record of all TAs authorized within the previous twelve months. In addition, request a listing from the Fulfillment organization of all orders shipped under Transaction Agreements within a specified time frame. Review a risk-based sample of the firm or individual names identified from these requests. If the same firm or individual name appears for two or more separate Transaction Agreements, it must be included in the sample. Determine what percentage, if any, of the samples were out of compliance with the following:

- Was each shipment supported by properly approved TA documents? Did the TA contain the end user name?
- If a sample is from a business entity with more than one Transaction Agreement, was that information documented and taken into consideration by an authorized approver before the additional TAs were approved?
- Was the business entity on the TA properly vetted if not an existing BP, i.e., DPL check, export checks?
- If the TA includes a price, was the price properly approved per transaction pricing delegated approval grids.

OVERVIEW

AUDIT PROGRAM #50-00-00

CONTROL ASSESSMENT QUESTIONS – SMALL COUNTRIES

Key Control Question: 1. Ecosystem Management

Primary Test: Transaction Agreements (BP003.P)

(Continued)

- Was work transacted against this contract performed only after contract acceptance? (A test can be constructed to identify all shipments, payments, or billings prior to the contract acceptance date.)
- Were there any side deals altering TA terms and conditions?

OVERVIEW

AUDIT PROGRAM #50-00-00

CONTROL ASSESSMENT QUESTIONS – SMALL COUNTRIES

Key Control Question: 1. Ecosystem Management

Primary Test: BP Compliance Reviews (BP004.P)

Objective:

To determine that compliance audits of value-added enhancement and special bid transactions are being completed by the Ecosystem Compliance organization as required considering the current business environment and direction. Further, to ensure that all restitution owed to IBM by the ecosystem as a result of the compliance audit is collected by the BP line organization and appropriate actions are followed up with partners in breach of terms and conditions.

Approach:

Determine what type of reviews are being performed in the compliance audits for the channel or channels being audited. Request the results of these reviews and determine if the reviews were effective and appropriate action plans were put in place. In some cases, this may include reviews performed by third party auditors.

Validate that sample selection and coverage is in line with global guidance provided for work of the Ecosystem Compliance team and that all key risks have been considered in selection of the partners to be audited.

Review measurement package and the compliance testing performed, including sample selection methodology, number of transactions tested, testing results, and findings and related actions plans. Consider the results of the compliance testing during sample selection for the audit. Evaluate whether management's testing covers adequate risk in the process and local business environment.

The following is an example of the type of reviews that could be conducted. However, these types of reviews may not be applicable to all situations.

Special Bids

- Was the price communicated and billed to the end user equal to the price the Ecosystem submitted in the special bid request to win IBM approval?
- If there was a special bid violation, was the transaction evaluated by the IBM Ecosystem Compliance Review Board?
- For any infraction, was the action taken in line with the minimum actions required in the 'Minimum Actions Requirements for Ecosystem Infractions' maintained in the BP controls website in the instructions and advisories section. Any actions taken which are less than though minimum should have received the appropriate exception approval.
- If the IBM Ecosystem Compliance Review Board concludes that restitution was required, was the amount collected equal to the planned amount? If restitution was not collected, was the nonpayment properly approved, action taken against the BP (such as being placed on a probation period) or the BP contract terminated where legally permitted? This is done at both the Geo and Country level.

Value Added Enhancement (VAE)

- If there was a VAE violation, was the documentation evaluated by the IBM IBM Ecosystem Compliance Review Board?
- Compliance Review Board to determine if restitution is required? This is performed at a Geo level.
- If restitution was not collected, was the nonpayment properly approved, action taken against the BP (such as being placed on a probation period) or the BP contract terminated where legally permitted? This is performed at a Geo Level.

OVERVIEW

AUDIT PROGRAM #50-00-00

CONTROL ASSESSMENT QUESTIONS – SMALL COUNTRIES

Key Control Question: 1. Ecosystem Management

Primary Test: BP Compliance Reviews (BP004.P)

(Continued)

- Review the log of non-compliance by the ecosystem (i.e., higher end user price than what was included in SBO). Reconcile log against the recovery made and validate that restitution was not made to any items not identified on the log. This is performed at a Geo Level.
- For high-risk organizations, verify if management is taken action to ensure BP is complying with firm order management policies. For example, management could implement customer care call process whereby the end user is called to verify the products and customer satisfaction, or on-site visits to the BP could also take place. If such a process is in place, validate if management action is taken on potential fraudulent transaction in the review and that processes are connected to Ecosystem Compliance Team or to Investigations.

OVERVIEW

AUDIT PROGRAM #50-00-00

CONTROL ASSESSMENT QUESTIONS – SMALL COUNTRIES

Key Control Question: 1. Ecosystem Management

Primary Test: Inventory Management (BP005.P)

Objective:

To determine if the level of inventory maintained by the Ecosystem is reasonably accurate, analyzed, reported, and accounting entries are made when required.

Approach:

BP Inventory Levels

Periodic reporting and analysis of BP inventory levels are required. This information is supplied directly by the BP through inventory reports. Where a formal sales-out reporting process is established, sales in and sales out data can be used to confirm the reported inventory. This information is used to manage the channels, i.e., determine if additional incentives may be required, and also allows finance and accounting to determine the appropriate amount of revenue provisions. This information is collected at a country level and aggregated and reported by geography to worldwide where provision analysis is performed, and the appropriate accounting entries are made.

On a periodic basis, inventory levels for certain Ecosystems are assessed. Ecosystems (distributors) are required to submit their inventory levels to an analyst to determine if the six-week level of inventory is being exceeded and determine if revenue needs to be reversed based on exceeding a predetermined inventory level (weeks of supply). Note: Provisions are only taken on a quarterly basis and significant impact will be at quarter-end since that is when key management decisions and financial impact would occur.

Sales from IBM into the distributor's inventory are known as "sell-in." Sales from the distributor's inventory out to the second tier BP are known as "sell-out."

Review measurement package and the compliance testing performed, including sample selection methodology, number of transactions tested, testing results, and findings and related actions plans. Consider the results of the compliance testing during sample selection for the audit. Evaluate whether management's testing covers adequate risk in the process and local business environment.

Request the results of the inventory level reviews during the audit period. Understand how the six-week inventory level is calculated. Determine what percentage, if any, were out of compliance with the following:

- Were inventory quantities for Ecosystems collected as required? Were actions taken when Ecosystem inventory quantities were not taken?
- Was the BP information sent directly to the administrator preparing the report? (The information should not be passed through the Client Relationship Ecosystem sales Representative where they may have the ability to alter the data.)
- Did the beginning inventory match last month's ending inventory?
- Were growth assumptions for next quarter sell-out reasonable and within approved guidelines? Were growth rates outside of guidelines granted exception approval? Were estimated sell-out growth rates reasonably similar to actual quarter-to-quarter sell outgrowth?
- Was the six-week inventory level correctly calculated?
- If the inventory level exceeded the six-week level, were the results reviewed by accounting?

OVERVIEW

AUDIT PROGRAM #50-00-00

CONTROL ASSESSMENT QUESTIONS – SMALL COUNTRIES

Key Control Question: 1. Ecosystem Management

Primary Test: Inventory Management (BP005.P)

(Continued)

- Was revenue reversed by accounting when appropriate based on the results of the inventory level review? Note: BP inventory held for more than a predetermined level (generally six weeks, but the target can be modified by brand by country) must be analyzed and accounting provision and commission adjustment taken if necessary. Was there a stop order for any inventory going to a customer who has exceeded the six weeks?

Note: This reporting process only applies to certain hardware products and for Distributors. Second tier resellers are allowed to store inventory. If a second-tier reseller does carry inventory, IBM does not track that inventory since IBM does not sell directly to second tier resellers.

In select high-risk audits, the following test may be considered:

Objective: To identify whether BPs with dual identities as both a distributor and a solution provider (SP) bypassed weeks-of-supply requirements. The risk is improper revenue recognition for shipments to BPs who have already surpassed their inventory weeks-of-supply limitation.

Note: In some cases, one company may have two different ecosystem agreements (BPA) with IBM. One BPA may grant an identity as a distributor while the other grants an identity as an SP.

Approach: Obtain a listing of shipments, including the ship-to BP's identity as a distributor or a solution provider. Reference the inventory weeks-of-supply reports and take note of distributors who met or almost met the weeks-of-supply limitation. Determine whether those distributors also have identities as SPs. Check whether shipments under the SP identity increased significantly during the time that weeks-of-supply limitation was met. If any such cases are identified, request supporting information.

OVERVIEW

AUDIT PROGRAM #50-00-00

CONTROL ASSESSMENT QUESTIONS – SMALL COUNTRIES

Key Control Question: 1. Ecosystem Management

Primary Test: Disbursements (BP006.P)

Objective:

To determine if management had oversight and visibility to determine if the process was being followed and that risks were being managed at an acceptable level. This is accomplished by determining if the process for timely and accurate payment of valid, authorized complementary fees had been defined, documented, and followed.

The process includes the approval of contracts and programs as well as the execution of the disbursement process. (Disbursements include both credit notes and payments.) All programs and contracts that result in BP disbursements are reviewed and approved prior to announcement, for equitability, funding, legality, and ability to be efficiently administered (planning and approval). Prior to making a disbursement, the eligibility of the BP, the accuracy of the data used to confirm performance against terms and conditions, and the attainment against objectives must be independently validated. The disbursement must then be properly approved, reconciled and post audit analysis performed for duplicate payments.

Approach:

Fee payments are made to complementary Ecosystems as compensation for their assistance in the completion of a sale to one of IBM's end-user customers. The amount of the fee is usually a function of the value of the sale.

Request a copy of the process documentation from the audit client. The process documentation and process execution should ensure adequate separation of duties. Understand the methodology for calculating and approving the fee to be paid, and what activities must be performed by the Partner in order to earn the fee. If a vendor has been engaged to support any or all of the process, the documentation should include any DOUs or SLAs that describe IBM's requirements and expectations. (For significant outsourced operations, use outsourcing management test CM001P.)

Systems which generate fee payments are subject to ASCA certification, so the auditor should request documentation of the ASCA status of any such applications.

Review measurement package and the compliance testing performed, including sample selection methodology, number of transactions tested, testing results, and findings and related actions plans. Consider the results of the compliance testing during sample selection for the audit. Evaluate whether management's testing covers adequate risk in the process and local business environment.

Review a risk-based sample of complementary fee payments made to Ecosystems in the previous quarter. The sample should focus on high value fees and Ecosystems with multiple transactions. Determine what percentage, if any, were out of compliance with the following:

- Were the reasons for payments valid according to the terms and conditions and performance requirements of the relevant contract?
- Was it validated that work for which all fees were paid was properly performed? (Note: Where such validations rely upon Partner-supplied data, determine what "reasonableness tests" the audit client uses. For example, does Partner-supplied data reflect higher quantities sold/installed than IBM records for that Partner would seem to support? Do serial numbers supplied by the Partner appear to have been sold to another Partner or end-user)?

OVERVIEW

AUDIT PROGRAM #50-00-00

CONTROL ASSESSMENT QUESTIONS – SMALL COUNTRIES

Key Control Question: 1. Ecosystem Management

Primary Test: Disbursements (BP006.P)

(Continued)

- Was the work required to be performed completed and validate prior to the disbursement.
- Were payments approved in accordance with Corporate Instruction, Finance 101 including adequate separation of duties (approval generally by a manager)?
- Was the accounting for the disbursement valid, i.e., was the accounting into either revenue, expense, or cost supported by accounting guidance?
- Were actual fees paid reconciled against fees claimed, calculated, and approved?
- Determine if the period expenses/revenue reversal matched the same period as the corresponding revenue. If not, was an accrual made if required? (Depending on the criteria set by accounting, accruals under a certain dollar amount are not required.).
- Were procedures in place to identify duplicate submissions, payments, or credits to the same BP for the same activity? (Note: If back-up submitted includes references to specific products, is there a reasonableness test performed to ensure that the same serials or quantities have not been referenced more than once?)

OVERVIEW

AUDIT PROGRAM #50-00-00

CONTROL ASSESSMENT QUESTIONS – SMALL COUNTRIES

Key Control Question: 2. Pension Benefit Management

Objective:

To determine whether pension benefit management was properly handled, performing accurate calculations, and implementing proper controls for cash and bank activities.

Risk/Exposure:

Incorrect calculation, generating over/under payments.

Insufficient controls over cash disbursement.

Lack of controls over the fees paid for contract administration.

OVERVIEW

AUDIT PROGRAM #50-00-00

CONTROL ASSESSMENT QUESTIONS – SMALL COUNTRIES

Key Control Question: 2. Pension Benefit Management

Primary Test: Payments to Recipients (PB001.P)

Objective:

To verify that all participants and recipients entitled to participation in Pension Management funds are receiving proper valuation for their entitlements and proper payout of benefits.

Approach:

Identify all types of eligible recipients who are authorized to receive payments (e.g., IBM pensioners, IBM employees on medical disability, surviving spouses, widows, orphans, etc.).

Obtain a listing of all current recipients for the last three-month time period. Select a sample of recipients, including each type of recipient in the sample, and test for the following:

1. All current benefit recipients are valid current or former IBM employees and entitled to payments. If a surviving spouse, confirm valid spousal relationship (e.g., not divorced) and entitlement to payment. This may include checking terms/conditions associated with re-married status. For orphans' pensions, this may include proof of relationship. For pensioners who have moved out of the country, there may be requirements to provide a "proof of life" at specific intervals for the payments to continue.
2. Are payment amounts correct? Check salary history against payment terms and conditions based on retirement date and applicable retirement program in effect on that date.
3. Have cost of living adjustments been correctly reflected in the pension system?
4. Are payments being made timely?
5. Do duplicate or nonexistent social security records (or equivalent) exist? How often are records tested for incorrect or fraudulent records? This can be checked using the HR system, pension system, or census data, if applicable.
6. What steps does the fund take to ensure recipients are still eligible? What documentation is required from the payment recipients by the plan or per local law to prove eligibility?

Select a sample of payees and compare the HR record data to the data provided to the actuary to ensure the assumptions match and the payment properly calculated based on those assumptions.

OVERVIEW

AUDIT PROGRAM #50-00-00

CONTROL ASSESSMENT QUESTIONS – SMALL COUNTRIES

Key Control Question: 2. Pension Benefit Management

Primary Test: Fees and Contract Administration (PB002.P)

Objective:

Validate if contracts for vendors, including banks, were properly negotiated, selected, accounted for, and monitored.

Approach:

Confirm that procedures governing procurement activities exist. If a procurement delegation is in place, ensure the department adheres to the blue book guidelines. If a delegation does not exist, ensure that procurement is involved in the contract process. Request and review any SAS70 that are provided by vendors.

1. Were contracts approved by the Procurement organization, or, if purchasing responsibilities have been delegated, are controls in place at the delegated location? Is this delegation in writing and current (within the last twelve months)?
2. Was there a reasonable basis for vendor selection? What controls are in place to ensure competent vendors are selected for high skill areas. If exceptional (single or sole) sourcing of a contract is used, is there a valid business justification with adequate management review and approval? Are these vendors re-evaluated annually?
3. Are signed contracts on file and available for review?
4. Were any payments made to the vendor prior to the final contract?
5. Was a Legal review of the contract performed?
6. Do contracts include all necessary clauses to protect both IBM and its current and former employees?
7. For larger contracts, do audit clauses exist that allow further review of contracted processes?
8. For larger contracts (assets over \$100M), do contracts require that the vendors provide a SAS70. If a SAS70 is contractually required review the following:
 - a. Was an assessment of the SAS70 performed?
 - b. Were there any material control weakness reported in the vendor's process?
 - c. Was an assessment of the user considerations performed? (i.e., actions required by IBM in order to ensure contract services)

OVERVIEW

AUDIT PROGRAM #50-00-00

CONTROL ASSESSMENT QUESTIONS – SMALL COUNTRIES

Key Control Question: 3. Management of Disbursements - 3rd Party Expense/CTEBA

Objective:

To ensure that CTEBA pre-approval is obtained before offering business amenities or gifts that exceed the applicable clip level, to an External Entity that is an official employee, or representative of a Government Owned Entity (GOE), or an employee or representative of a Commercial Party in Certain Countries (CPICCs). CTEBA applies to the provision of the business amenities defined in FIN168, offered to officials, employees, or representatives of a GOE, or employees or representative of a CPICC.

To ensure that payments and reimbursements for any Third-Party expenses are incurred reasonable, properly authorized, supported, receipt of goods or service verified, and in compliance with IBM policies and procedures.

Risk/Exposure:

Bypasses of CTEBA process coupled with insufficient controls over payments and reimbursements could lead to non-compliance with FCPA and other regulations governing fraud and bribery. This could lead to financial loss and severe damage to IBM's reputation and image.

Note: Management of Disbursements - 3rd Party Expense/CTEBA audit could have the potential to overlap considerably with the Travel and Expense audit program (18-15-00). It is important that we do not overlap into the depth of testing that is contained in the Travel and Expense audit program or Marketing and Communications audit program (50-20-00). Audit's focus in these reviews needs to be on the role of the management team in ensuring that expenses (GOE and/or CPICC) being submitted are in line with company, and country policies and that there are controls in line to prevent fraud.

OVERVIEW

AUDIT PROGRAM #50-00-00

CONTROL ASSESSMENT QUESTIONS – SMALL COUNTRIES

Key Control Question: 3. Management of Disbursements - 3rd Party Expense/CTEBA

Primary Test: Payments and Reimbursements (MC001.P)

Objective:

The objective of this test is to ensure that employee expenses claimed for third-party meals, entertainment, and business amenities, were reviewed and approved by management with proper supporting documentation. This review by management should encompass all expenses, including exceptions to WW and local policies and guidelines.

Approach:

Use reports of all expenses, including reports or listings of potential exceptions to guidelines, to select for review. Pay particular attention to instances where there may be outliers. For example:

1. An inordinately large numbers of expense accounts by one person
2. High total expense amounts by one person
3. Numerous exceptions allowed by the same manager
4. Exceptions without any apparent business justification.

Assess the following, focusing on process and guideline adherence:

- Management demonstrated an understanding of 3rd party expense reimbursement policy and their role in the process by reviewing and approving expenses according to guidelines, as required
- Exceptions were reviewed and approved by management
- There was clear business justification for the exceptions
- There were determined and reasonable support for expenditure
- That in the case of repeated exceptions by the same employee, management was aware and took action, as appropriate
- Proper internal IBM organizational pre-approvals (e.g., corporate community relations, expense restrictions)
- In countries without local guidelines (legal, works council agreements, etc.) that do not restrict use of the IBM corporate card to business only, was the corporate charge card used for only business expenses?
- Management reviewed for appropriate categorization of expenses and accurate completion of required information

Types of expenses that managers should review on an expense account are:

- Was the hotel in the IBM hotel guide, was it booked as a group hotel through procurement, or was it a client-directed hotel?
- Are business meals documented, approved and within guidelines?
- Was the class of airfare in policy according to established procedures?
- Were IBM cell phone charges in accordance with guidelines?
- Was the corporate charge card used for only business expenses?
- Was the corporate card used for airfare, car rentals, and hotels?
- Were there any spousal expenses and did they adhere to guidelines? Note that IBM spouse expenses are taxable and must be appropriately reported. Customer spouses are treated as customers, and they have to be listed on the attendee list with justification in CONCUR.
- Was evidence retained to demonstrate that goods and services were received?

OVERVIEW

AUDIT PROGRAM #50-00-00

CONTROL ASSESSMENT QUESTIONS – SMALL COUNTRIES

Key Control Question: 3. Management of Disbursements - 3rd Party Expense/CTEBA

Primary Test: CTEBA Use and Monitoring of CEPAT Tool (MC002.P)

Objective:

To ensure that all interactions offering business amenities above the country specific clip levels involving individuals from GOEs or in CPICCs have gone through the CEPAT tool or Other Events Tools (OET), obtaining approval prior to the interactions/events with the external party, with a completed documented Post Interaction/Event Review.

Approach:

From a Universe of Transactions (Reports are being developed to pull 100% of anything identified as third-party expense, group expense and miscellaneous expense).

- Determine if the engagement includes an individual from a GOE or from/in a CPICC country
- If the answer is no, proceed to the section labeled "Commercial Accounts"
- If the answer is yes, proceed to the section labeled "GOE and CPICC"

Commercial Accounts

- Focus is on Compliance with FIN/LEG 168
- Meals and Transportation - IBM preference is to have the third party pay for their own. However, if there is a rationale for IBM to pay for the meals and transportation (should be documented), then policy is that the IBM travel policy guidelines should be followed.
- Accommodation - defined by IBM travel policy and all exceptions are handled through the expense reimbursement policy.
- Entertainment - reasonable is defined as no more than \$200/person, and this is specific to the cost of attending the event and not any additional meals or other amenity. Exceptions require the prior approval of the applicable CFO.
- Gifts - Nominal is defined as \$50 or less. This includes the cost of engraving, packaging, insurance, and mailing. Exceptions requires prior approval of the applicable CFO. Audit team to focus on explanation for the exception and documentation provided to support the additional expense and/or exceptions.

GOE and CPICC: Follow CTEBA Guidelines

- The audit team will select their samples from the CONCUR universe used for the engagement. Audit should not select CONCUR samples that have gone through the CTEBA Compliance Management system which includes monthly control point testing, Independent Verification Reconciliation (IVR) or Bypass Detection Process.
- Focus is on Compliance with CTEBA Process/Tool – This includes analysis to determine if the expense exceeds the country clip level that has been set by the Trust and Compliance team. If the expense does not exceed the clip level, then it is not required to go through the CTEBA tool. However, all FIN/LEG 168 guidelines still apply.

OVERVIEW

AUDIT PROGRAM #50-00-00

CONTROL ASSESSMENT QUESTIONS – SUBSIDIARIES AND JOINT VENTURES

Key Control Question: 1. Cost and Rate Management

Objective:

Are there adequate controls over the process for approving the commitment of IBM funds to external suppliers who are selected based on the criteria set forth in the Procurement Requirements and Practices booklet?

Risk/Exposure:

All commitments of IBM funds to external suppliers must receive a minimum of two independent approvals: (1) requestor approval authorizing the release of IBM funds, and (2) procurement approval authorizing the source selection, price, and terms and conditions. All commitments of IBM funds must be approved by an official procurement organization that has received an authorized delegation of procurement authority from the IBM Chief Procurement Officer.

Failure to properly control the approval of commitments can create excess expenditures, legal problems, vendor relations exposures, and can lead to fraud.

Failure of suppliers to meet established performance targets decreases IBM's ability to provide high quality, low cost products and services to our customers.

OVERVIEW

AUDIT PROGRAM #50-00-00

CONTROL ASSESSMENT QUESTIONS – SUBSIDIARIES AND JOINT VENTURES

Key Control Question: 1. Cost and Rate Management

Primary Test: Product Costing (PC001.P)

Objective:

To ensure the inventory values are consistent with the costing methodology and all elements of cost (e.g., materials, value add, process scrap) are included in the cost system input. To ensure that all products have been assigned a unit cost and that products without costs are investigated and adjusted in a timely manner. To determine if costs are updated in the current period and to ensure exceptions, variances, and system input errors are controlled and resolved with management visibility.

Approach:

Test the fundamental costing technique by selecting samples of shipped product included in the plant's cost of goods sold account.

Review the costing methodology used for Cost of Material (COM), Material Value Add (MVA) and Cost Variance (CV) if the basis is appropriate, adequate, consistently applied, and in accordance with IBM standards. Additionally, assess the adequacy of management system to review and reconcile cost variances and resolution of identified issues.

Assess the adequacy and timeliness of product revaluation, and if update methodology was consistently applied. This includes revaluation of Cost of Material, Manufacturing Value Add, and Cost Variance.

Review the cost construction of the output by decomposing the various elements and tracing their values to upstream sources. In conjunction with the testing of bill of material (BOM) values, the overhead application rate should also be reviewed.

Verify that all part numbers have been assigned a unit cost. If there are part numbers without a cost, understand the reasons and actions taken to resolve exceptions.

Ensure that all exception transaction reports are reviewed and approved by management. Test a sample of the high value exception transactions.

Review forced closure of exceptions to ensure proper disposition. Ensure the ability to change costs within the system is adequately restricted. Test a sample to ensure the adjustments are valid and properly disposition.

Compare part numbers' bills of materials released by engineering and loaded in the logistic and / or cost system with physical parts and features used during the production cycle to ensure that product cost is accurate. Test that the final BOM is an aggregation of components at standard values.

OVERVIEW

AUDIT PROGRAM #50-00-00

CONTROL ASSESSMENT QUESTIONS – SUBSIDIARIES AND JOINT VENTURES

Key Control Question: 2. Integration Compliance

Objective:

To verify the existence of an integration plan for acquired entities and non-integrated subsidiaries, that include core support processes, and any proposed change to the accepted Transfer of Employment (ToE) and Transfer of Business (ToB) plan of record is documented and appropriately approved in accordance with the extension process outlined in Corporate Instruction FIN 122. The scope does not include less than wholly owned non-integrated entities (e.g., joint ventures, alternate structures, etc.).

Risk/Exposure:

The continued stand-alone operation of acquired entities and other wholly owned subsidiaries of IBM that are not integrated into IBM's global processes may impose increased financial, legal, and reputational risks to the IBM Enterprise.

OVERVIEW

AUDIT PROGRAM #50-00-00

CONTROL ASSESSMENT QUESTIONS – SUBSIDIARIES AND JOINT VENTURES

Key Control Question: 2. Integration Compliance

Primary Test: Integration Compliance (IC001.P)

Objective:

To verify the existence of an integration plan for acquired entities and non-integrated subsidiaries, that include core support processes, and any proposed change to the accepted Transfer of Employment (ToE) and Transfer of Business (ToB) plan of record is documented and appropriately approved in accordance with the extension process outlined in Corporate Instruction FIN 122. The scope does not include less than wholly owned non-integrated entities (e.g., joint ventures, alternate structures, etc.).

Approach:

Review the plan of record (integration plan) for the acquired entity and non-integrated subsidiary and verify compliance with FIN 122.

Did the acquisition achieve all Transfer of Employment or “ToE” and the Transfer of Business or “ToB” requirements within 6 months of close per FIN 122?

- a. If so, validate the approval to the declaration of TOB for the entity, if declared after November 2024.
- b. If not, is there a valid documented extension approved as required per FIN 122? If it is within the extension period, no further testing would be applicable if an extension was approved, and/or the ToB/ToE is not yet due.
- c. If there is an approved exception to the ToE or ToB criteria in place, was it approved as required per FIN 122?

For process audit programs, the following approach should be applied:

- a. Are there any NISs executing operational processes that are not integrated into IBM's global processes? (yes or no; if yes, provide the universe)
- b. If yes to a, provide the integration plan as applicable and status for the applicable process tasks associated with the selected NIS samples.
- c. Demonstrate how the processes are controlled and aligned with the Transfer of Control timeline per FIN 122 for wholly owned NISs.

Test:

Review the integration procedures for Acquired Entities and Non-Integrated Subsidiaries to verify a plan and valid approvals exists, when required.

OVERVIEW

AUDIT PROGRAM #50-00-00

CONTROL ASSESSMENT QUESTIONS – SUBSIDIARIES AND JOINT VENTURES

Key Control Question: 2. Integration Compliance

Primary Test: Integration Compliance (IC001.P)

(Continued)

Key Reference Information and Terms:

- **Corporate Instruction FIN 122:**
<https://w3.ibm.com/ibm/corporate-documents/fin/fin-122>
 - **Transfer of Controls** – ToC refers to IBM Global Process Owners assuming the decision rights, responsibility, and accountability for their processes across the Acquired Entities and NIS at acquisition close or the date of creation of the wholly owned subsidiary.
 - **Transfer of Employment** - ToE refers to the transfer of the employment relationship between the Acquired Entity and its employees under the Acquired Entities' or NIS' heritage employment terms to the appropriate IBM entit(ies) under IBM employment terms and conditions, in compliance with all local legal and regulatory requirements.
 - **Transfer of Business** - ToB refers to the assignment and transfer of all the Acquired Entities' or NIS' assets, businesses, and operations to the appropriate IBM entit(ies), in compliance with all local legal and regulatory requirements.

OVERVIEW

AUDIT PROGRAM #50-00-00

CONTROL ASSESSMENT QUESTIONS –
OTHER UNIQUE PROCESSES THAT COULD ARISE IN AN OVERVIEW REVIEW

Key Control Question: 1. Site Security

Objective:

The objective of this audit program is to determine, in conjunction with the IBM Security Requirements Manual (SECMAN), that there is a management system to implement the defined scope and cover the following:

- Procedures have been implemented to ensure a secure business environment for IBM employees and other people working in IBM facilities.
- There are effective management actions to protect proprietary information and assets from unauthorized disclosure, modification, or misappropriation.

Risk/Exposure:

Insufficient access controls could expose IBMs perimeter, facilities, and parking facilities so that the facility is insecure for employees and visitors and their property.

Lack of adequate controls over specifically defined space could result in a loss of intellectual and physical assets or create an insecure work environment for personnel.

If the process for badge controls is ineffective the physical access control program may be ineffective.

Lack of adequate controls over locks and keys could result in an insecure business environment for employee property, loss of IBM proprietary information, and loss of IBM physical assets.

OVERVIEW

AUDIT PROGRAM #50-00-00

CONTROL ASSESSMENT QUESTIONS –

OTHER UNIQUE PROCESSES THAT COULD ARISE IN AN OVERVIEW REVIEW

Key Control Question: 1. Site Security

Primary Test: Access Controls and Badge (SS001.P)

Objective:

To determine whether the processes and technology in support of physical access are operating effectively.

Approach:

Review the latest version of the security manual related to access controls and badge designs (section PS05).

1. Determine if CAS or one-time use badges are issued per requirements, for example:
 - a. Documentation of management authorization for non-IBM personnel was obtained prior the badge being issued.
 - b. Proof of identity was obtained prior to a badge being issued to non-IBM personnel.
 - c. Temporary, contractor badges (yellow) are authorized by an IBM manager, purchasing buyer, IBM coordinator, or authorized pre-designated contract company supervisor. Visitor identity (those requiring escort and issued red badges) must be validated by a government ID or the person authorizing the visit.
 - d. Badges are in compliance with the security manual design requirements (for example, sealed, white photo background with a postage guaranteed post office box return address on the reverse).
2. Validate that all badges have an expiration date in the CAS database.
 - a. Determine whether badges which are not returned on the due date (for example, temporary or visitor badges) are deactivated.
 - b. Determine whether badges reported as lost have immediate action taken to place the badge in lost status and whether the profiles are kept in the CAS database for six months.
3. Validate that all hardware, badge stock, and other components of the CAS badge process are secured when not in use.
4. Validate that user IDs are assigned to all CAS operating personnel in compliance with the IT Security Standard and authorization reviews are performed every six months.
5. Verify that an effective process is in place to remove employee access in a timely manner:
 - a. Category manager reports are distributed to category managers every 90-95 days.
 - b. Every 30 days IBM Security must match CAS database to the HR database. (Note: If separations are being performed by the Enterprise Director (ED) Trigger automated process, the 30-day match is not required.
6. Process must be in place to deactivate lost badges within 24 hours.

OVERVIEW

AUDIT PROGRAM #50-00-00

CONTROL ASSESSMENT QUESTIONS –

OTHER UNIQUE PROCESSES THAT COULD ARISE IN AN OVERVIEW REVIEW

Key Control Question: 1. Site Security

Primary Test: Interior Access Controls (SS002.P)

Objective:

To determine whether appropriate access controls are in place within the audited facilities.

Approach:

Review the latest version of the security manual related to building perimeters and interior security (section PS02). Test for specific controls related to the various types of designated space.

- Perimeter doors
 - Windows and exterior glass walls
 - IBM internal space
 - Restricted space
 - IBM internal shared space
 - Tenant space
 - Loading docks
 - Lobbies
1. Verify that all perimeter doors designed as entrances are constructed of heavy-duty material and are alarmed or monitored. Verify that all emergency exit doors are constructed of heavy-duty material and are alarmed. Determine if the door jambs, hinges, locks are designed to resist forced entry.
 2. Validate that windows on the ground floor cannot be opened more than 10 inches (25 cm). If the location is rated at a high or extreme risk of terrorism, validate that ASF has been installed adjacent to vulnerable areas.
 3. Verify that all general use areas such as lobbies, elevators, and loading docks have a system to control access into IBM interior space.
 4. Validate that there are inconspicuous panic alarm devices in staffed lobbies which are monitored by Security or other constantly staffed workstation. Validate that staffed loading docks are equipped with panic alarm devices which are monitored by Security or other constantly staffed workstation. Verify there is a documented response procedure, and the alarm devices are tested as required. In unstaffed lobbies and loading docks that are controlled by remote access doors, verify there are monitoring devices to allow identification of an individual prior to allowing access to the building.
 5. Validate that security infrastructure (for example, for doors, emergency exits, panic buttons, CCTV, etc.) are tested to ensure they are operational and that the results are documented within the required timeframe. Determine if corrective actions were taken and any deficiencies were documented.
 6. Determine if the interior space is isolated from the public space (such as lobbies and public restrooms) with slab-to-slab construction techniques.
 7. Determine if the restricted space has a supervised control access system with an audit trail and that the audit trail is reviewed by management every 90-95 days. If cipher locks with audit function are used, validate that the combinations are changed every 90-95 days (or when employees change assignments).

OVERVIEW

AUDIT PROGRAM #50-00-00

CONTROL ASSESSMENT QUESTIONS –

OTHER UNIQUE PROCESSES THAT COULD ARISE IN AN OVERVIEW REVIEW

Key Control Question: 1. Site Security

Primary Test: Interior Access Controls (SS002.P)

(Continued)

8. Validate that no unauthorized individuals have access to IBM terminals and printers. Determine if the contracts with tenants prohibit such access.
9. In locations where banking facilities (such as automated teller machines) exist, validate that there is a process for third party monitoring for response to robberies and burglaries.
10. When IBM shares space with non-IBM functions, IBM employee offices and proprietary information must be secured when unattended.

OVERVIEW

AUDIT PROGRAM #50-00-00

CONTROL ASSESSMENT QUESTIONS –

OTHER UNIQUE PROCESSES THAT COULD ARISE IN AN OVERVIEW REVIEW

Key Control Question: 1. Site Security

Primary Test: Exterior Access Management (SS003.P)

Objective:

To determine whether sufficient controls are in place at this IBM facility to deter and detect unauthorized access to:

- External Utility Areas
- Parking Facilities
- Building Entrances

Approach:

Review the latest version of the security manual related to exterior security (section PS01).

1. Verify that Facilities management has posted signs indicating property boundaries and entry restrictions.
2. Validate that critical utilities have been identified, documented, and revalidated within the last 12 months. Determine if the required controls are implemented.
3. Verify that the minimum lighting requirements have been met.
4. Verify that access from the parking structure is limited and secure. Determine if the area is well-lit with concealment areas minimized.
5. If IBM controlled, determine if access to the parking structure is restricted to vehicles or drivers that are authorized.
6. If IBM controlled, verify that there are physical deterrents (such as barriers or landscape techniques) which impede vehicular access to lobbies or other glassed areas of buildings, where there is a concentration of people. These requirements are baseline for new construction after June 1, 2003, and optional prior to that date.
7. Verify that building access points below the third floor (grills, grates, manhole covers, utility tunnels, sky lights, and roof vents, etc.) are secured to prevent entry into the building or damage to critical utilities, unless prohibited by local ordinances, codes, laws or regulations. If local ordinances, codes, laws, or regulations prohibit security these access points, verify that alarms have been installed to detect unauthorized access.
8. Verify that there is a clear line of sight maintained around the perimeter of the building.
9. All renovation and construction of IBM Security control centers must be reviewed and approved by the Director of Innovation and Technology, Corporate Security (Section PS06).

OVERVIEW

AUDIT PROGRAM #50-00-00

CONTROL ASSESSMENT QUESTIONS –
OTHER UNIQUE PROCESSES THAT COULD ARISE IN AN OVERVIEW REVIEW

Key Control Question: 2. Disaster Recovery and Business Continuity

Objective:

To determine if process owners developed, reviewed, and tested business continuity plans (BCP) / disaster recovery plans (DRP) so that in the event of natural or man-made disasters, pre-defined plans can be executed to maintain business operations.

Were disaster recovery or business continuity commitments documented to ensure that services being provided on behalf of the customer were recoverable in case of disruption? Was there a disaster back-up and recovery plan for the computing and operating environments? Has the plan been agreed to by both parties? Has the plan been tested as required or at least once every two years? Did the plan identify and include all Global Resourcing locations?

Risk/Exposure:

If IBM was unable to recover processing or operating capabilities following disruption due to accident, disaster, or other emergency, obligations to customers may not be met. This could expose the company to financial and legal ramifications and customer satisfaction issues. Many business processes have been centralized, and often operations are conducted in locations, which may be susceptible to business disruption. As a result, it is important that business and process owners have developed plans to maintain continuity of business operations.

OVERVIEW

AUDIT PROGRAM #50-00-00

CONTROL ASSESSMENT QUESTIONS –

OTHER UNIQUE PROCESSES THAT COULD ARISE IN AN OVERVIEW REVIEW

Key Control Question: 2. Disaster Recovery and Business Continuity

Primary Test: Disaster Recovery and Business Continuity (DR001.P)

Objective:

To determine if process owners have developed, reviewed, and tested business continuity plans (BCP) or disaster recovery plans (DRP) so that in the event of natural or man-made disasters, pre-defined plans can be executed to maintain business operations.

Approach:

Please note that the terminology business continuity plan (BCP) is being used for simplicity. Depending on the customer or contract, either BCP or DRP (disaster recovery plan) will be used.

Currently there is no single corporate instruction detailing business continuity plan (BCP) requirements for processes. In addition, different processes will have their own unique risk profiles regarding the probability and impact of an interruption to business operations. For example, the probability and impact of a business interruption for a process which has been centralized for multiple countries in a location with less-developed infrastructure is greater than that of a process supporting only a single country in location with robust infrastructure. As such, significant auditor judgment will be required to determine how important BCP is for a particular process, as well as to determine the reasonableness of any plans that have been designed by the process owners.

In the initial data request, seek information from the process owner regarding what plans have been implemented to ensure business continuity in the event of a natural or man-made disaster. Review that non-I/T process elements have been adequately considered in the BCP. All plans should include locations that include offshore, on shore, and near shore services. Following is a list of items to consider for review:

1. Verify if any level of requirements for continuity of service was established. Was there a defined timeframe to resume operations in case of major disruptions?
2. Verify whether the process owner identified critical skills and resources supporting the process, including the location of these resources. This could include suppliers and non-IBM locations.
3. Was a critical skills human resources (HR) list established with an identified means to contact these skills in the event of a significant business interruption (such as phone numbers and/or email addresses)? Were these lists accessible independently from the availability of IT systems?
4. Were dependencies on other IBM organizations identified (e.g., Global Well Being, Human Resources, Communications, Facilities)?
5. Review and evaluate the thoroughness of the BCP content. Part of this evaluation should include an inquiry with the organization regarding what is needed to continue operations in the event of a business continuity disruption. Here are some potential items to review for inclusion in the BCP.

If the process is executed at a primary location, were plans put in place for backup infrastructure if the infrastructure at the primary location is inaccessible? Items for backup infrastructure include:

- a. Space and power systems
- b. Personal workstations and necessary software, and LAN points
- c. Servers
- d. Phones
- e. Are there other items that the auditor can identify?

OVERVIEW

AUDIT PROGRAM #50-00-00

CONTROL ASSESSMENT QUESTIONS –

OTHER UNIQUE PROCESSES THAT COULD ARISE IN AN OVERVIEW REVIEW

Key Control Question: 2. Disaster Recovery and Business Continuity

Primary Test: Disaster Recovery and Business Continuity (DR001.P)

(Continued)

6. Were there documents of understanding in place with potential suppliers of the backup infrastructure, to reduce the risk that this infrastructure might not be available in the event of a business disruption?
7. Review that BCP included an established communication plan for when BCP was initiated. Organizational call lists should be established such that when initiating a BCP, communication can flow from top level management all the way down throughout the entire organization (including external suppliers).
8. Did the plan have any provision for alternative means of communication in case of disruptions to phone or email services?
9. Most countries and major site locations also have established site crisis management teams (CMTs). Did the process owner review or synchronize their BCP with the appropriate CMT(s)?
10. Verify whether BCP was reviewed and understood by individuals identified in the critical skills HR list. Also, review that BCP was communicated to all affected employees.
11. Verify if formal agreement was obtained from the client regarding BCP and when this was to be implemented.
12. Review how the BCP was tested. Usually stress testing of systems is performed but at times a paper walk through test may be performed. Was there any validation that service requirements and backup infrastructure could be met? Were processes, key people, or environmental factors changes aligned with the ones included in BCP? Were BCP results documented? Was a root cause analysis performed to document results when the test brought up unexpected results? Was an action plan put in place to ensure the mitigation of deviations?

OVERVIEW

AUDIT PROGRAM #50-00-00

CONTROL ASSESSMENT QUESTIONS –
OTHER UNIQUE PROCESSES THAT COULD ARISE IN AN OVERVIEW REVIEW

Key Control Question: 3. Parts Logistics

Objective:

Included in the process are administrative procedures which ensure protection of assets and efficient customer service and financial procedures to account for the accurate statement of inventories.

Risk/Exposure:

Insufficient controls in place IBM could result in business discontinuity, customer dissatisfaction, and suppliers' disputes.

OVERVIEW

AUDIT PROGRAM #50-00-00

CONTROL ASSESSMENT QUESTIONS –

OTHER UNIQUE PROCESSES THAT COULD ARISE IN AN OVERVIEW REVIEW

Key Control Question: 3. Parts Logistics

Primary Test: Supply Order Management (PL001.P)

Objective:

To determine based on the planning process if orders for parts are properly placed and managed. In addition, were there adequate controls and reviews for identifying, processing, and resolving excess, surplus and scrap inventory along with timely implementation of engineering changes.

Approach:

Process Risk

Customer Satisfaction and Achievement of Business Objectives: Inaccurate supply management can result in parts shortages, inventory overage, or missed shipments. Testing Strategy:

1. Review orders based on products that did not meet scheduled commitments, and/or have significant inventory overages or shortages. Test for the following:
 - a. Execution of requirements generation recommendations
 - b. Actions taken to monitor and control short-lead-time orders and firm orders in excess of lead-time
2. Verify reconciliation of open orders between locations that are tracked and aged. (Aged items are resolved timely.)
3. Verify that open purchase requests are aged and tracked. (Aged items are resolved timely.)
4. Review cancellation charges and check to see if root cause analysis was performed and that proper approvals were in place.
5. Ensure materials that were identified as critical, short parts, and on back-order, are aged, reviewed, and resolved timely.
6. Request list of unplanned/manual requisitions. Select a sample and test for:
 - a. Reason for manual requisition
 - b. Measured, tracked, and properly reviewed. Validate that the unplanned/manual requisitions are measured (should be a report) and tracked (reviewed & validated why they are existing and whether they are necessary/applicable).
7. Request list of receipt referrals. Select sample and test for:
 - a. Aging: Check whether there is a report showing the number of days/weeks of the referral of the receipt. Focus on the ones with the longest days/weeks referred.
 - b. Activity is being reviewed. If the activity is in control and an escalation process is in place in case it takes too long, etc.
 - c. Resolved timely: For external suppliers, there is a contractual delivery time and a described escalation process when higher level management should be involved when timely resolution is not reached. The escalation process should be in the guideline.
8. Review BNR/RNB and INR/RNI activity for audit period. Determine if excessive, verify management involvement, verify current action plans are in place to resolve issues.

OVERVIEW

AUDIT PROGRAM #50-00-00

CONTROL ASSESSMENT QUESTIONS –

OTHER UNIQUE PROCESSES THAT COULD ARISE IN AN OVERVIEW REVIEW

Key Control Question: 3. Parts Logistics

Primary Test: Supply Order Management (PL001.P)

(Continued)

IDR

1. List of unplanned/manual requisitions for the audit period
2. List of receipt referrals for the audit period

Reference Material

None

Data Mining

1. Review list of unplanned/manual requisitions for re-occurring part numbers and analyze parts to determine if a pattern exists.
2. Review list of receipt referral for re-occurring part numbers, purchase orders, and analyze parts to determine if a pattern exists.

Note: Billed not received (BNR) refers to goods that have been billed from an internal IBM vendor and not received by the plant. Invoiced not received (INR) refers to goods that have been invoiced from an external vendor and not received by the plant. The RNB/RNI relationship is the same as above with goods that have been received by the plant and not billed or invoiced. The excessive aging of all four of these (BNR/RNB and INR/RNI) are control concerns, because IBM cannot be confident that cost and inventory is properly stated if these have not been reconciled.

OVERVIEW

AUDIT PROGRAM #50-00-00

CONTROL ASSESSMENT QUESTIONS –

OTHER UNIQUE PROCESSES THAT COULD ARISE IN AN OVERVIEW REVIEW

Key Control Question: 3. Parts Logistics

Primary Test: Excess Surplus and Scrap (PL002.P)

Objective:

Are there adequate controls and reviews for identifying, processing, and resolving excess, surplus, and scrap inventory?

Approach:

Process Risk

Noncompliance to corporate instructions CP10.12 and CP10.13

Testing Strategy

- Determine if a site's operating procedure and organization exists to support excess surplus and scrap (ES&Z) management principles as defined in CP-10.12.
- Determine that site metrics and corporate measurements are accurate, reported timely, and problem areas are highlighted with corrective action plans in place. Reference CP-10.12 (monthly reports).
- Determine that the ES&Z code definitions are adhered to. If not, has the division controller approved of the business rationale and notified the CHQ director of ISC processes and operations? Reference CP-10.12 (section 1.2).
- Determine if the quality of the site declaration for ES&Z meets 'Buyer Criteria'. Reference CP-10.12 (section 4.4).
- Verify that blocking codes for site declarations are utilized. Reference CP 10.12 (section 4.2).
- Determine that site purchasing recognizes ES&Z as preferred supply and that vendor terms and conditions provide maximum flexibility to allow optimum ES&Z usage. Reference CP10.12.
- Determine that parts recommended for scrap are first reviewed for potential external sales opportunities in accordance with section 4.10 of CP-10.13.

Achievement of Business Objectives

- Determine that the site is utilizing all available tools and reports to minimize ES&Z inventory. Examples of tools and reports are: the PSG Impact tool, WWW inventory tool, and the interplant logistic system (IPLS) weekly declaration, missed opportunity, and high value reports.
- Determine if multi-level-balancing opportunities exist and if a management system is in place to maximize the multi-level balancing opportunity prior to sale/scrap/salvage operations. Note: Balancing means that if there is overage inventory at one IBM location and a shortage at another IBM location that the inventory is offered by the overage location and ordered by the shortage location to avoid scrap at the overage location and buying externally at the shortage location. Multi-level refers to the fact that balancing can happen between SPO locations within a geography (level 1), between SPO geographies (Americas, EMEA, AP (level 2)) and across business units (SPO, GARS, manufacturing).

Loss of assets and fraud being undetected

- Determine that the separation of duties (SOD) supports the basic ES&Z management principles. Request a copy of the ES&Z SOD assessment and review for conflicting job responsibilities for ES&Z personnel. Reference CP-10.12 (management principles and responsibilities).

OVERVIEW

AUDIT PROGRAM #50-00-00

CONTROL ASSESSMENT QUESTIONS –

OTHER UNIQUE PROCESSES THAT COULD ARISE IN AN OVERVIEW REVIEW

Key Control Question: 3. Parts Logistics

Primary Test: Excess Surplus and Scrap (PL002.P)

(Continued)

IDR

- ES&Z metrics for audit period
- Site ES&Z code definition
- List of ES&Z scrap for audit period, including part number, quantity, unit cost, extended cost, APC code, and scrap reference number
- SOD assessment supporting ES&Z process

Reference Material

- CP10.12 Excess and Surplus Parts Inventories
- CP10.13 Asset Protection: Normal & Sensitive Parts Security
- ES&Z = Excess Surplus and Scrap: Definitions in CP-10.12:
<http://w3.ibm.com/articles/downloads/doc/CorporateProcedure1012.doc>

Data Mining

None

OVERVIEW

AUDIT PROGRAM #50-00-00

CONTROL ASSESSMENT QUESTIONS –

OTHER UNIQUE PROCESSES THAT COULD ARISE IN AN OVERVIEW REVIEW

Key Control Question: 3. Parts Logistics

Primary Test: Receiving (PL003.P)

Objective:

To determine if the LLP's business controls processes, testing results, measurements and related documentation were effective in ensuring the timely and safe receipt of commodities and materials. To confirm that commodities and materials, including sensitive parts, were effectively and safely received, in an accurate and timely manner, and moved to the point of usage or storage.

Approach:

Process Objectives

Does the Control Tower have adequate controls to validate that LLP has reviewed and validated input from 3PL suppliers which demonstrates receipt of commodities, that materials are accurately and timely recorded, and moved to the point of usage or storage.

Process Risk

Customer Satisfaction: Untimely, inaccurate receipt of materials can result in missed parts and inventory integrity issues.

Testing Strategy

Obtain documentation from contracted supplier which demonstrates validation of:

- Proof of Delivery (POD)
- All receipts were processed accurately and within established time frames, including referrals, adjustments, quality holds or parts with potential quality issues which need to be held separately, etc.
- Sensitive parts shipments were correctly entered into the Corporate Asset Tracking System (CATS) system.

Undetected Fraud

The Control Tower has adequate controls to validate that LLP has controls in place to ensure that the concealment of irregular activity or fraudulent payments does not occur.

Testing Strategy: Performed as part of SOD testing.

IDR

- Sample documentation from the Control Tower which demonstrates their validation ("audit") of the contracted supplier, LLP, that the receipt process has been executed according to the Statement of Work (SOW). The sample documentation and conclusions of the Control Tower should demonstrate that the LLP has validated and demonstrated that the 3PL suppliers executed the receipt process according to the SOW.
- Sample documentation from the Control Tower, which demonstrates the audit by Control Tower of LLP. The sample documentation and conclusions of the Control Tower should demonstrate that LLP has validated and demonstrated that the 3PL suppliers executed the receipt process according to the SOW.

Reference Material

Corporate Procedure 10.13: <http://w3-1.ibm.com/chq/environment/apcc/CP1013v5.htm>

Data Mining

None

OVERVIEW

AUDIT PROGRAM #50-00-00

CONTROL ASSESSMENT QUESTIONS –

OTHER UNIQUE PROCESSES THAT COULD ARISE IN AN OVERVIEW REVIEW

Key Control Question: 3. Parts Logistics

Primary Test: Shipping (PL004.P)

Objective:

To verify that all shipped assets and materials were accounted for and protected against loss.

Approach:

Process Risk

- Financial Misstatement: Incomplete or inaccurate information can result in misstated financial information, penalties, and losses to IBM.
- Customer Satisfaction: Untimely, inaccurate shipment of product/materials can result in missed shipments and can affect customer satisfaction.
- Loss of Assets: Access to materials by unauthorized individuals and failure to account for all assets can result in undetected losses.
- Undetected Fraud: An individual with job responsibilities and/or system access capability which would permit the initiation and concealment of irregular activity could lead to undetected fraudulent activities.

Testing Strategy

- Review the LLP's on-time delivery metrics to demonstrate that parts delivery date expectations are met.
- Verify that procedures were being followed to record shipped assets and the movement from inventory. Obtain a current listing of shipments for the audit period, select a sample, and test for the following attributes:
 - Verify parts inventory against shipment documentation for variances.
 - Verify parts shipment documentation against customer receipt information.
 - Determine if variances exist between shipments and staged inventory.
 - Determine if shipment variances were timely resolved and in accordance with local procedures.
- For the shipment of sensitive parts, determine that procedures exist for proper packaging and use of tamper proof materials.
 - Select a sample of past sensitive parts to determine if these entries were correctly recorded in the Corporate Asset Tracking System (CATS) system.
 - Determine if there have been any lost in transit shipments of sensitive parts.
 - Verify that there are no open shipments of Asset Protection Code 4 (APC4) parts from this location to the next with a ship date greater than 60 days.
- Perform SOD testing.

IDR

List of parts shipments for audit period, including location, ship date, part number, quantity, order number, type (code) of shipment.

Data Mining

Review list of shipments to determine if they were shipped on time.

OVERVIEW

AUDIT PROGRAM #50-00-00

CONTROL ASSESSMENT QUESTIONS –

OTHER UNIQUE PROCESSES THAT COULD ARISE IN AN OVERVIEW REVIEW

Key Control Question: 3. Parts Logistics

Primary Test: Import Reconciliation (PL005.P)

Objective:

To determine that risks were adequately managed to validate that the value paid equals the value declared to customs.

Approach:

Global Logistics

- Were billings (both inter-company and accounts payable) reconciled to amounts declared to customs? For intercompany payments the International Distribution Data Exchange (IDDE) invoice is used as the billing invoice for the purpose of the import reconciliation (accounting responsible for Common Intercompany Accounting System (CIAS) reconciliation).
- Were differences promptly resolved and reported?
- Were unreconciled items aged, tracked, resolved, and presented to management for review?
- Were SPI requirements followed:
 - Were supplier shipping invoices complete and accurate per the SPI?
 - Were supplier billing invoices reconcilable to the declaration per Customs requirements?
 - Were revisions to declarations and billings performed accurately and in a timely manner?
- Were records, including evidence of the reconciliation, and entries which were adjusted when required, maintained in accordance with local customs requirements for the proper period stated by the country regulation from the date of entry?
- Were periodic self-reviews performed?
- Were controls in place to reduce the occurrences of external entries and invoices caused by misrouting of shipments, or usage of non-standard shippers and forwarders?

World Trade Accounting Services (WTAS)

- Were entries in variance reported to the sites for assistance?
- Were controls in place to account for non-standard billing mechanisms (e.g., journal entries or miscellaneous intercompany billings, such as Intercompany Agreement (ICA))?

Global Procurement

- Were SPI requirements communicated to suppliers?
- Were effective actions taken to resolve supplier variances?

OVERVIEW

AUDIT PROGRAM #50-00-00

CONTROL ASSESSMENT QUESTIONS –

OTHER UNIQUE PROCESSES THAT COULD ARISE IN AN OVERVIEW REVIEW

Key Control Question: 3. Parts Logistics

Primary Test: Import Classification of Goods (PL006.P)

Objective:

To determine that risks were adequately managed to ensure timely, accurate, and consistent classification of all imported parts and products.

Approach:

Review classification activity to determine the following:

- Have country-unique import classification requirements been identified? Were programs in place to provide adequate training to both management and staff—including personnel at Customer Solutions Centers (CSC)?
- Were classifications timely, accurate, and consistent? Review both system logic applied classifications and manually researched classifications to determine that classifications were assigned.
- Are classification reviews/validations routinely performed (including high-volume, high-value goods, reclassified parts, and parts subject to high rates of duty or special duty programs)? Were shipments made from Customer Solutions Centers (CSCs) included in samples?
- Were challenges to IBM classifications by customs reviewed by management? Was follow-up to the challenges performed in a timely and effective manner with action plans established to address the cause? Was the classification system timely updated? Were the challenges trended and root cause analysis performed?
- Review misclassifications that resulted in penalties. Were the penalties trended and root cause analysis performed? Were corrective action plans developed and tracked to address the cause(s)?
- Were reasonable controls in place to detect and prevent unauthorized changes to classification?
- Was there a process to confirm that back-owed duties were paid or requests for refunds were considered when classification changes resulted in duty changes? Were these changes tracked, trended, and dispositioned properly?
- Were classifications for multiple shipments of the same product or part number consistent?
- Were classifications for high-risk goods periodically sampled to confirm classification accuracy, and results reported to management?
- Was there a process to confirm that multiple shipments of the same part number were consistent?

OVERVIEW

AUDIT PROGRAM #50-00-00

CONTROL ASSESSMENT QUESTIONS –
OTHER UNIQUE PROCESSES THAT COULD ARISE IN AN OVERVIEW REVIEW
Key Control Question: 3. Parts Logistics
Primary Test: Import Classification of Goods (PL006.P)
(Continued)

Manufacturing / Development

- Did the classification system provide adequate information to determine correct classification?
- Did Development/Engineering have a process in place to follow the parts release process and provide required information for classification?
- Was there a process to ensure that the invoice descriptions for unassembled or disassembled articles were clear?
- Did invoices for assembled parts reflect a single part number representing the assembled article, rather than the component part numbers?
- Was there a process in place to inform Global Logistics when goods (sub-assemblies) were actually received as component parts?

OVERVIEW

AUDIT PROGRAM #50-00-00

CONTROL ASSESSMENT QUESTIONS –

OTHER UNIQUE PROCESSES THAT COULD ARISE IN AN OVERVIEW REVIEW

Key Control Question: 3. Parts Logistics

Primary Test: Denied Party List Screening (PL007.P)

Objective:

To determine if operations were adequately managed to prevent transactions with parties on the IBM Denied Parties List (DPL).

Approach:

Global Logistics Foreign Trade Compliance and Sites

- Was there a written procedure describing how DPL screening was completed?
- Had a person and backup been designated to be responsible for coordinating the receipt and local redistribution of DPL updates?
- Had the site determined what functions, if any, should be responsible for screenings?
- Had the screeners received education on U.S. export requirements and their responsibilities within the past 12 months, and are they able to explain what they are doing and why they are doing it?
- Did the procedure require screening of all new customers and suppliers before the customer or supplier was established in the customer and supplier master file?
- Did the procedure require screening of all DPL updates within seven working days of the publication of the customer and supplier master file in order to identify any existing customers and suppliers that may have been added to the DPL?
- Were the customer and supplier screenings documented with the date and the identity of the person conducting the screening?
- Was the screening process conducted in accordance with guidelines?
- Did the procedure identify the local process for evaluating potential matches with the DPL entities? The process must include communication of potential matches to relevant functions, process for stopping business activities, and escalation to the ERE, ERC, or ERO, as necessary.
- What controls or measurements are in place in the Global Logistics control tower organization that ensure LLPs' (Lead Logistics Providers) use of the IBM Denied Parties List (DPL) is consistent with IBM requirements and LLP's operational responsibilities on behalf of IBM?

OVERVIEW

AUDIT PROGRAM #50-00-00

CONTROL ASSESSMENT QUESTIONS –
OTHER UNIQUE PROCESSES THAT COULD ARISE IN AN OVERVIEW REVIEW

Key Control Question: 4. Employee Payments Review

Objective:

** This information comes from the Marketing, Communication, and Events program. ATL must validate whether this is relevant to be reviewed in the audit.

Are all expenses claimed reasonable, documented, and approved, processed, and in compliance with IBM policies?

Risk/Exposure:

Improper or invalid payments may be made to employees or processed inaccurately which could result in inappropriate or excessive expenses being incurred by IBM.

The giving of unreasonable gifts and gratuities could be construed as seeking special favors for IBM.

OVERVIEW

AUDIT PROGRAM #50-00-00

CONTROL ASSESSMENT QUESTIONS –

OTHER UNIQUE PROCESSES THAT COULD ARISE IN AN OVERVIEW REVIEW

Key Control Question: 4. Employee Payments Review

Primary Test: Invalid Payments (EP001.P)

Objective:

To identify potential invalid payments such as duplicate payments.

Data Mining

Focus should be on the same payment amount for the same invoice and more than one TEA for the same day.

Approach:

Suggested items to focus on are:

- Employees with same last date of travel
- Expenses claimed twice for the same date
- Employees with same dollar amount
- Employees with high volume of TEAs
- Individual expenses such as hotel, meal, airline, and car rental with same date (these queries are possible using NEDS)).

For non-US audits, determine what the local travel industry's air ticket discount and rebate policies are. Are discounts and rebates clearly identified, or are they given directly to the ticket purchases without visibility to IBM? If discounts are given, review charge receipt and airline ticket.

OVERVIEW

AUDIT PROGRAM #50-00-00

CONTROL ASSESSMENT QUESTIONS –
OTHER UNIQUE PROCESSES THAT COULD ARISE IN AN OVERVIEW REVIEW
Key Control Question: 4. Employee Payments Review
Primary Test: GEMCAPS Review (EP002.P)

Objective:

To identify potential invalid payments such as duplicate or unapproved payments.

****Even when a separate travel and expense program was not included, the Audit team leaders should understand which the participation is of travel expense in the total unit budget/results, to review the management monitoring process supported by GEMCAPS, if applicable.**

Approach:

Review the process by which managers are provided with GEMCAPS reports and verify:

- Reports are being consistently reviewed once received.
- When evidence of deviations is noted, employees are interviewed, and an action plan is implemented to avoid recurrence.
- Analysis performed is properly documented and follow up is performed over action plans implemented.